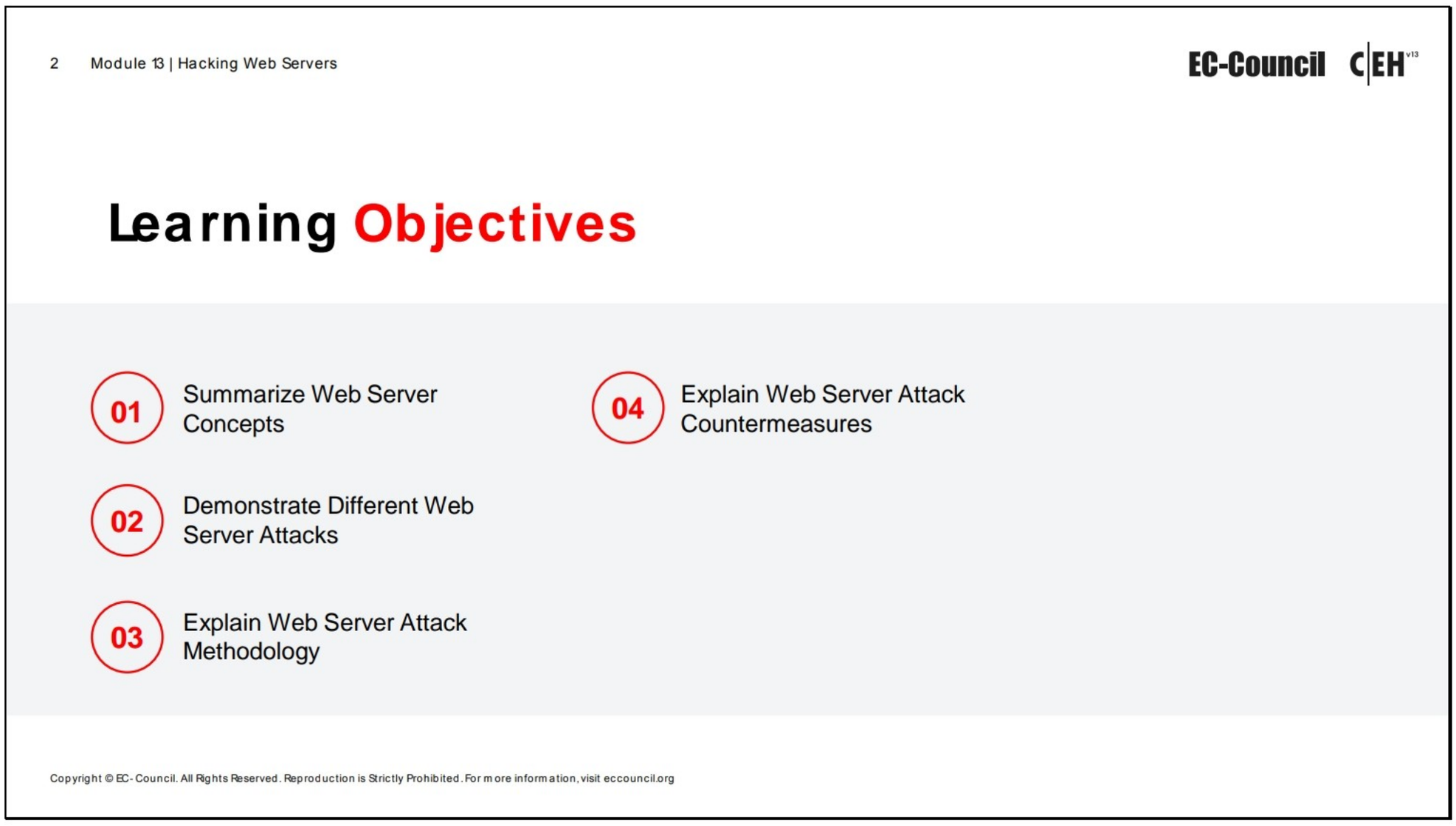
Module 13

Hacking Web Servers

EC-Council
Official Curricula

EC-Council C|EH v13 Certified Ethical Hacker

This page is intentionally left blank.



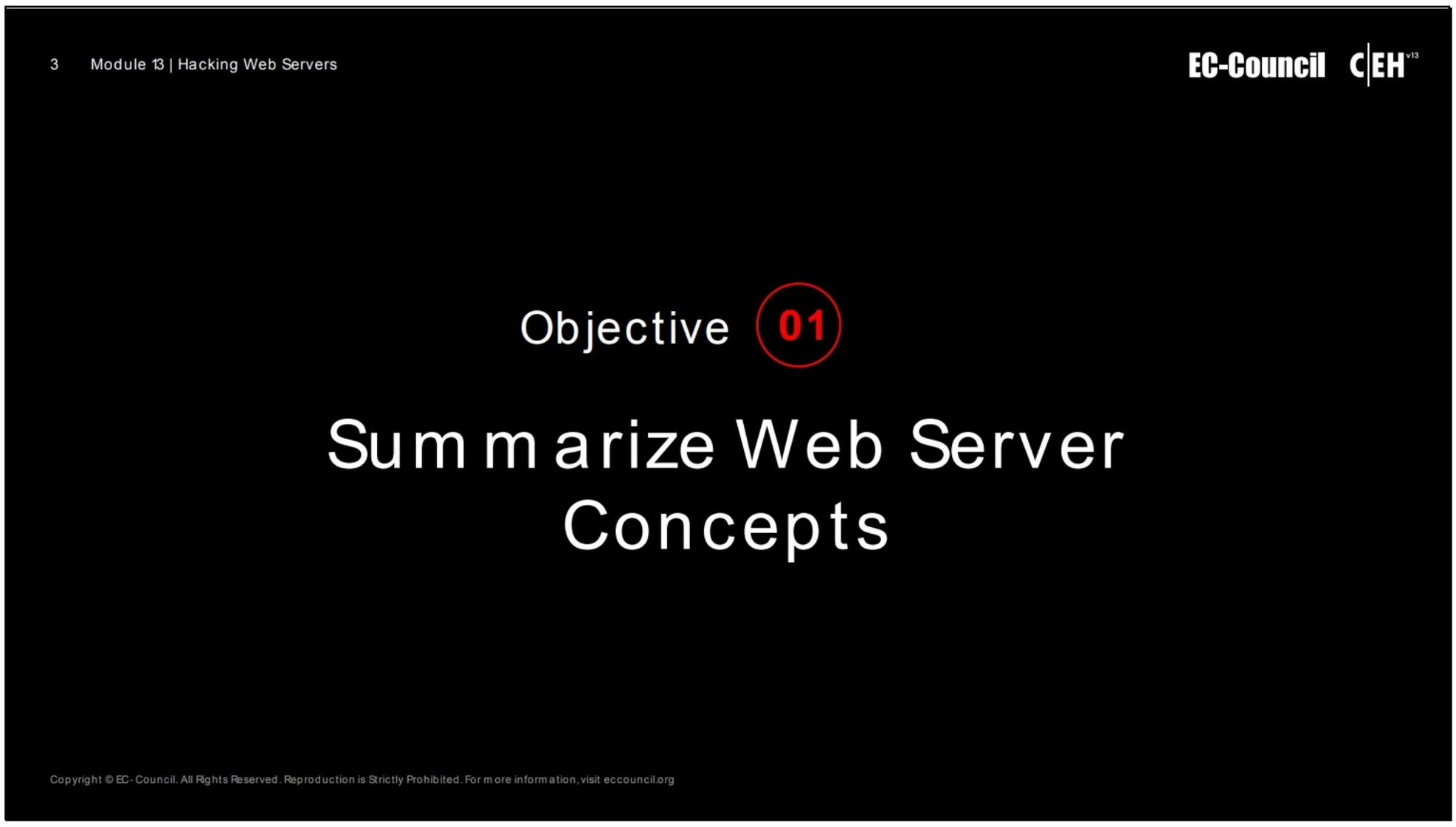
Learning Objectives

Most organizations consider their web presence to be an extension of themselves. Organizations maintain websites associated with their business on the World Wide Web to establish their web presence. Web servers are a critical component of web infrastructure. A single vulnerability in web server configuration may lead to a security breach on websites. Therefore, web server security is critical to the normal functioning of an organization.

At the end of this module, you will be able to do the following:

- Describe web server concepts
- Perform various web server attacks
- Describe web server attack methodology
- Use different web server attack tools
- Apply web server attack countermeasures
- Use different web server security tools

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.



Web Server Concepts

To understand web server hacking, it is essential to understand web server concepts, including what a web server is, how it functions, and other elements associated with it.

This section provides a brief overview of a web server and its architecture. It will also explain common factors or mistakes that allow attackers to hack a web server. This section also describes the impact of attacks on web servers.

Web Server Operations

A web server is a computer system that stores, processes, and delivers web pages to global clients via the Hypertext Transfer Protocol (HTTP). In general, a client initiates a communication process through HTTP requests. When a client desires to access any resource such as web pages, photos, and videos, the client's browser generates an HTTP request that is sent to the web server. Depending on the request, the web server collects the requested information/content from the data storage or application servers and responds to the client's request with an appropriate HTTP response. If a web server cannot find the requested information, then it generates an error message.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

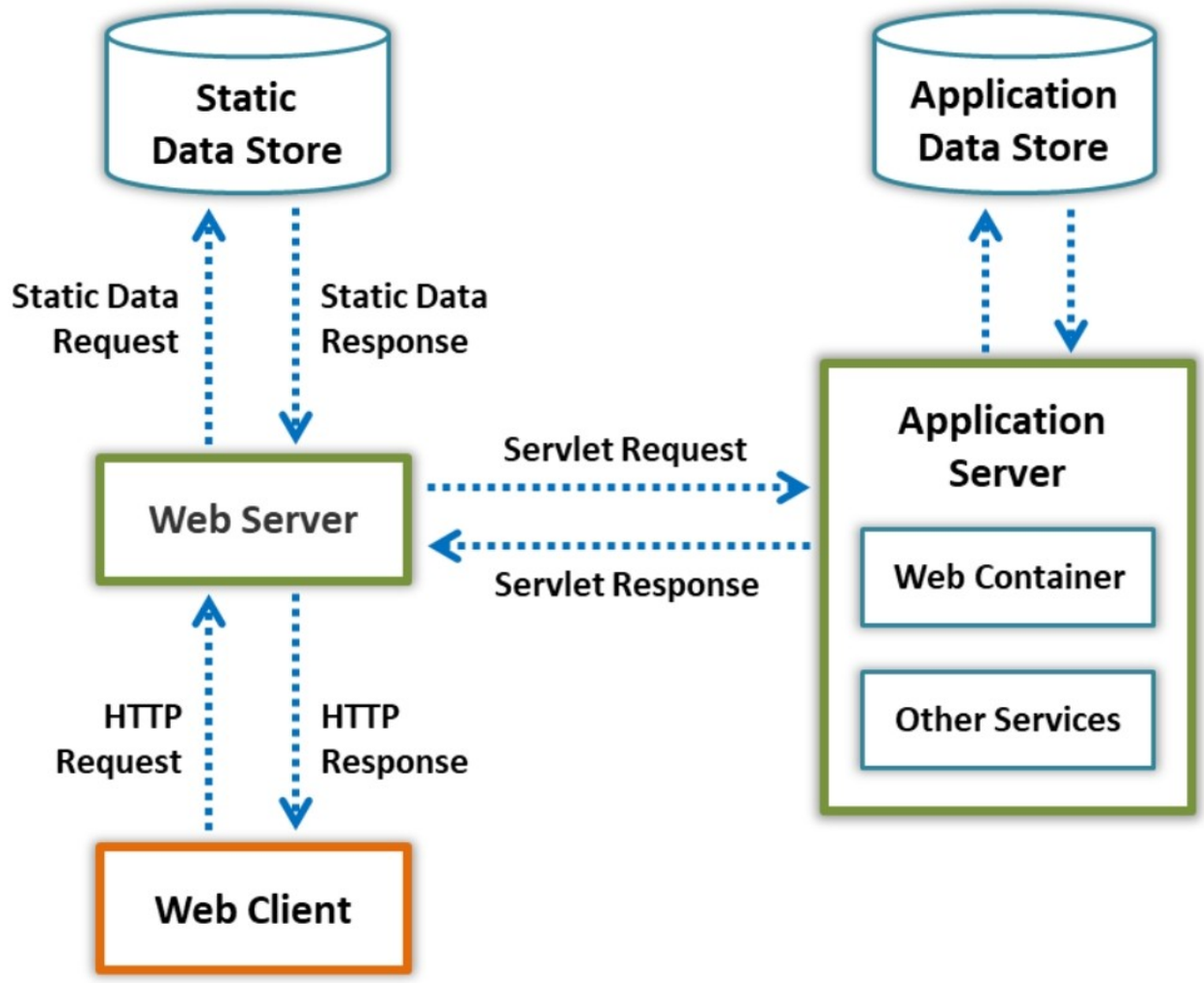


Figure 13.1: Typical client–server communication in web server operation

Components of a Web Server

A web server consists of the following components:

- **Document Root**

  The document root is one of the root file directories of the web server that stores critical HTML files related to the web pages of a domain name, which will be sent in response to requests.

  For example, if the requested URL is *www.certifiedhacker.com* and the document root is named "certroot" and is stored in the directory */admin/web*, then */admin/web/certroot* is the document directory address.

  If the complete request is *www.certifiedhacker.com/P-folio/index.html*, the server will search for the file path */admin/web/certroot/P-folio/index.html*.

- **Server Root**

  The server root is the top-level directory in the directory tree, where the server configuration files, log files, and executable files are stored. This is the root directory for the web server configuration. Typically, it contains several sub-directories:

  - **conf:** This directory holds the server's configuration files.
  - **logs:** This directory stores server log files, including access and error logs.
  - **cgi-bin:** This directory is where common gateway interface (CGI) scripts or other server-side executables are located.

  The server root may also contain other directories or files depending on the specific server software and its configuration.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

- **Virtual Document Tree**

  A virtual document tree provides storage on a different machine or disk after the original disk becomes full. It is case-sensitive and can be used to provide object-level security.

  In the above example under document root, for a request of *www.certifiedhacker.com/P-folio/index.html*, the server can also search for the file path */admin/web/certroot/P-folio/index.html* if the directory *admin/web/certroot* is stored in another disk.

- **Virtual Hosting**

  It is a technique of hosting multiple domains or websites on the same server. This technique allows the sharing of resources among various servers. It is employed in large-scale companies, in which company resources are intended to be accessed and managed globally.

  The following are the types of virtual hosting:

  - Name-based hosting
  - Internet Protocol (IP)-based hosting
  - Port-based hosting

- **Web Proxy**

  A proxy server is located between the web client and web server. Owing to the placement of web proxies, all requests from clients are passed on to the web server through the web proxies. They are used to prevent IP blocking and maintain anonymity.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Web Server Security Issues

Network and **OS level attacks** can be well defended using proper network security measures such as firewalls, IDS, etc. However, web servers can be accessed from anywhere via the Internet, which renders them **highly vulnerable** to attacks

Why are Web Servers Compromised?

- **Improper** file and directory **permissions**
- **Unnecessary** default, backup, or sample **files**
- **Misconfigurations** in web server, operating systems, and networks
- **Bugs** in server software, OS, and web applications
- Administrative or **debugging functions** that are **enabled** or accessible on web servers
- Use of **self-signed certificates** misconfigured SSL certificates, default certificates, and encryption settings
- Not using **dedicated server** for web services

Impact of Web Server Attacks

- Compromise of user accounts
- Website defacement
- Secondary attacks from the website
- Root access to other applications or servers
- Data tampering and data theft
- Reputational damage of the company

Copyright © EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit eccouncil.org

Web Server Security Issues

A web server is a hardware/software application that hosts websites and makes them accessible over the Internet. A web server, along with a browser, successfully implements client–server model architecture. In this model, the web server plays the role of the server, and the browser acts as the client. To host websites, a web server stores the web pages of websites and delivers a particular web page upon request. Each web server has a domain name and an IP address associated with that domain name. A web server can host more than one website. Any computer can act as a web server if it has specific server software (a web server program) installed and is connected to the Internet.

Web servers are chosen based on their capability to handle server-side programming, security characteristics, publishing, search engines, and site-building tools. Apache, Microsoft IIS, Nginx, Google, and Tomcat are some of the most widely used web server software. An attacker usually targets vulnerabilities in the software component and configuration errors to compromise web servers.

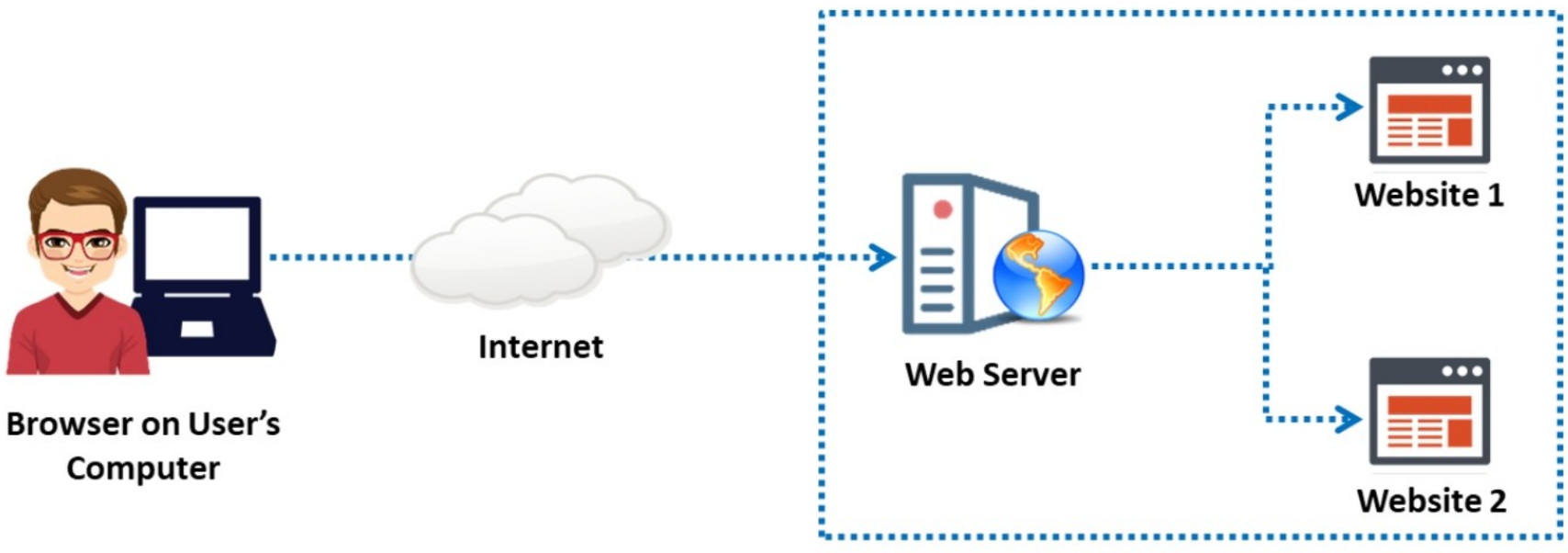


Figure 13.2: Conceptual diagram of a web server: the user visits websites hosted on a web server

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Organizations can defend most network-level and OS-level attacks by adopting network security measures such as firewalls, intrusion detection systems (IDSs), and intrusion prevention systems (IPSs) and by following security standards and guidelines. This forces attackers to turn their attention to web-server- and web-application-level attacks because a web server that hosts web applications is accessible from anywhere over the Internet. This makes web servers an attractive target. Poorly configured web servers can create vulnerabilities in even the most carefully designed firewall systems. Attackers can exploit poorly configured web servers with known vulnerabilities to compromise the security of web applications. Furthermore, web servers with known vulnerabilities can harm the security of an organization. As shown in the below figure, organizational security includes seven levels from stack 1 to stack 7.

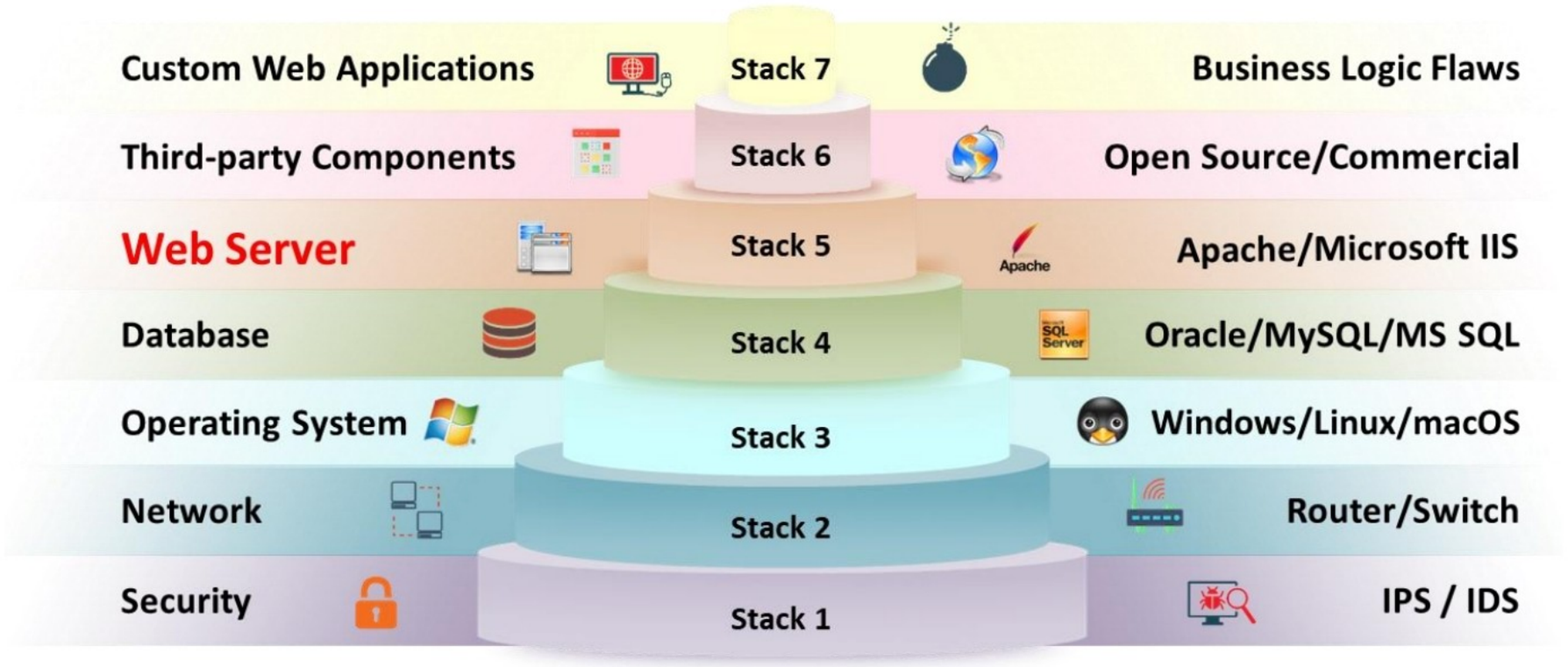


Figure 13.3: Levels of organizational security

Common Goals behind Web Server Hacking

Attackers perform web server attacks with certain goals in mind. These goals may be either technical or non-technical. For example, attackers may breach the security of a web server and steal sensitive information for financial gains or merely for the sake of curiosity.

The following are some common goals of web server attacks:

- Stealing credit-card details or other sensitive credentials using phishing techniques
- Integrating the server into a botnet to perform denial of service (DoS) or distributed DoS (DDoS) attacks
- Compromising a database
- Obtaining closed-source applications
- Hiding and redirecting traffic
- Escalating privileges

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Some attacks are performed for personal reasons, rather than financial gains:

- For pure curiosity
- For completing a self-set intellectual challenge
- For damaging the target organization's reputation

Dangerous Security Flaws Affecting Web Server Security

A web server configured by poorly trained system administrators may have security vulnerabilities. Inadequate knowledge, negligence, laziness, and inattentiveness toward security can pose the greatest threats to web server security.

The following are some common oversights that make a web server vulnerable to attacks:

- Failing to update the web server with the latest patches
- Using the same system administrator credentials everywhere
- Allowing unrestricted internal and outbound traffic
- Running unhardened applications and servers
- Providing complete error messages with server version information
- Using outdated SSL/TLS encryption algorithms
- Using third-party plugins in the web application

Impact of Web Server Attacks

Attackers can cause various kinds of damage to an organization by attacking a web server. The following are some of the types of damage that attackers can cause to a web server.

- **Compromise of user accounts**: Web server attacks mostly focus on compromising user accounts. If the attacker compromises a user account, they can gain a large amount of useful information. The attacker can use the compromised user account to launch further attacks on the web server.
- **Website defacement**: Attackers can completely change the appearance of a website by replacing its original data. They deface the target website by changing the visuals and displaying different pages with messages of their own.
- **Secondary attacks from the website**: An attacker who compromises a web server can use the server to launch further attacks on various websites or client systems.
- **Root access to other applications or server**: Root access is the highest privilege level to log in to a server, irrespective of whether the server is a dedicated, semi-dedicated, or virtual private server. Attackers can perform any action once they attain root access to the server.
- **Data tampering**: An attacker can alter or delete the data of a web server and even replace the data with malware to compromise users who connect to the web server.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

- **Data theft**: Data are among the primary assets of an organization. Attackers can attain access to sensitive data such as financial records, future plans, or the source code of a program.
- **Damage reputation of the company**: Web server attacks may expose the personal information of a company's customers to the public, damaging the reputation of the company. Consequently, customers lose faith in the company and become afraid of sharing their personal details with the company.

Why are Web Servers Compromised?

There are inherent security risks associated with web servers, the local area networks (LANs) that host websites, and the end users who access these websites using browsers.

- **Webmaster's perspective**: From a webmaster's perspective, the greatest security concern is that a web server can expose the LAN or corporate intranet to threats posed by the Internet. These threats may be in the form of viruses, Trojans, attackers, or the compromise of data. Bugs in software programs are often sources of security lapses. Web servers, which are large and complex devices, also have these inherent risks. In addition, the open architecture of web servers allows arbitrary scripts to run on the server side while responding to remote requests. Any Common Gateway Interface (CGI) script installed in the web server may contain bugs that are potential security holes.
- **Network administrator's perspective**: From a network administrator's perspective, a poorly configured web server causes potential holes in the LAN's security. While the objective of the web server is to provide controlled access to the network, excess control can make the web almost impossible to use. In an intranet environment, the network administrator must configure the web server carefully so that legitimate users are recognized and authenticated, and groups of users are assigned distinct access privileges.
- **End user's perspective**: Usually, the end user does not perceive any immediate threat because surfing the web appears safe and anonymous. However, advanced active content such as JavaScript and WebAssembly can introduce risks by allowing malicious code to run in the browser. Harmful applications such as malware and ransomware can exploit these technologies to infiltrate user systems. Moreover, active content from a website can act as a pathway for malicious software to bypass traditional security measures such as firewalls and gain access to the local network (LAN).

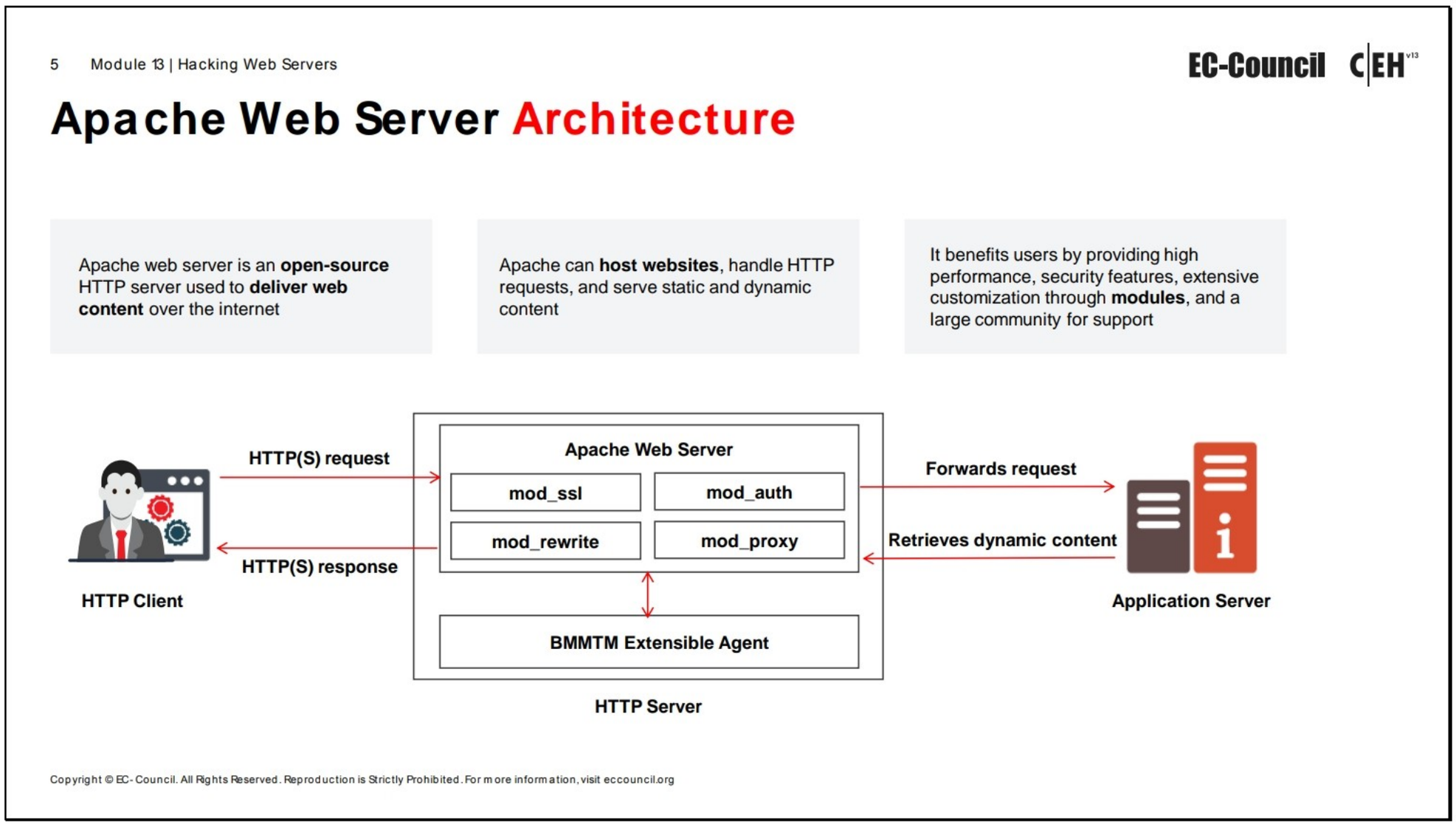
The following are some oversights that can compromise a web server:

- Improper file and directory permissions
- Installing the server with default settings
- Unnecessary services enabled, including content management and remote administration
- Security conflicts with the business' ease-of-use requirements
- Lack of proper security policy, procedures, and maintenance

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

- Improper authentication with external systems
- Default accounts with default or no passwords
- Unnecessary default, backup, or sample files
- Misconfigurations in the web server, OS, and networks
- Bugs in server software, OS, and web applications
- Misconfigured Secure Sockets Layer (SSL) certificates and encryption settings
- Administrative or debugging functions that are enabled or accessible on web servers
- Use of self-signed certificates and default certificates
- Not using dedicated server for web services
- Granting excessive privileges to users or processes, or failing to implement the principle of least privilege.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.



Apache Web Server Architecture

The Apache web server is an open-source HTTP server used to deliver web content over the Internet. It is widely used owing to its robustness, flexibility, and support for various web technologies. Apache can host websites, handle HTTP requests, and serve both static and dynamic content. It benefits users by providing high performance, security features, extensive customization through modules, and a large support community. These attributes render Apache a popular choice for web hosting and development.

The block diagram of the Apache web server architecture is shown below:

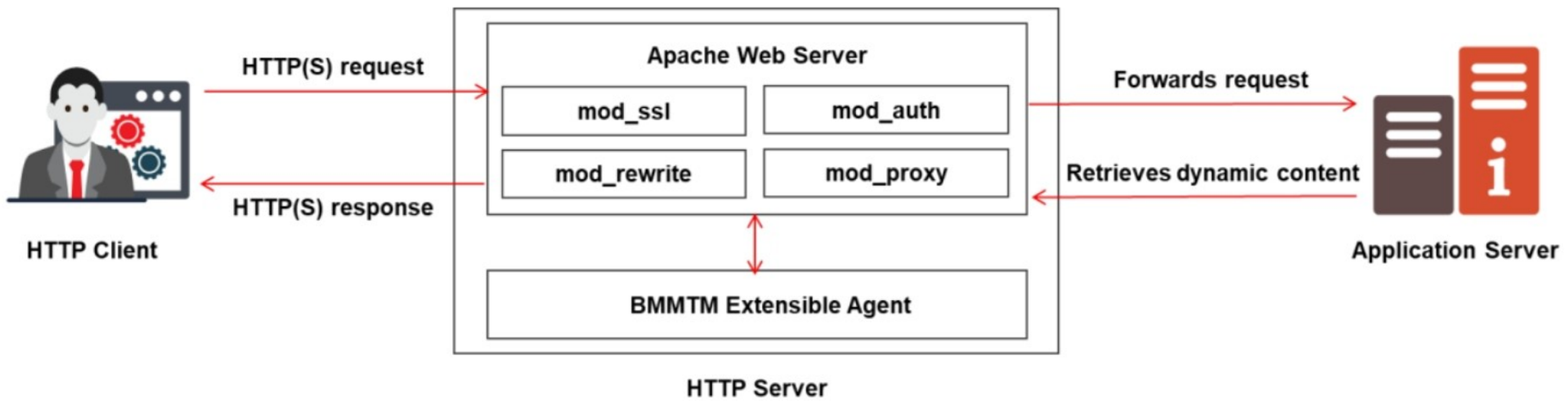


Figure 13.4: Illustration of Apache web server architecture

The functionalities of the various components of the Apache webserver architecture are discussed below:

- **HTTP Client**: It is a browser or software that initiates requests to the Apache server, asking for web pages, files, or other resources.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

- **HTTP Server (Core):** The core module handles HTTP(S) requests and responses, interfacing with modules such as mod_ssl, mod_rewrite, mod_proxy, and mod_auth to provide additional functionalities.
  - **mod_auth:** Manages user authentication, ensuring that only authorized users can access specific web resources based on the configured credentials.
  - **mod_ssl:** Provides SSL/TLS encryption to secure communication between the server and the clients.
  - **mod_rewrite:** Enables URL rewriting, customized URLs, and redirection based on specified rules.
  - **mod_proxy:** Functions as a proxy and gateway, enabling the forwarding of requests to other servers and load balancing.
- **BMMTM Extensible Agent:** Intercepts HTTP(S) requests and responses to gather detailed transaction data. It enhances monitoring and performance analysis by providing insights into the interactions between clients and servers.
- **Application Server:** Executes backend applications, processes data, and generates dynamic content, functioning separately from the web server that handles the HTTP requests. It is used to run applications written in various programming languages (e.g., PHP, Java, and Python), generating dynamic content that is subsequently served by the Apache web server.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Apache Vulnerabilities

Vulnerability	Description
HTTP response splitting	This vulnerability occurs when **improperly validated input** allows attackers to **inject malicious headers into HTTP responses**, leading to XSS, cache poisoning, or sensitive information disclosure
HTTP/2 DoS by memory exhaustion on endless continuation frames	This vulnerability occurs when **attackers send continuous HTTP/2 headers**, causing excessive memory consumption and leading to server unresponsiveness or crash
mod_macro buffer over-read	This vulnerability occurs when the **mod_macro module improperly handles macro expansion**, causing **buffer over-reads** that attackers exploit with crafted requests to access sensitive adjacent memory
DoS in HTTP/2 with initial window size 0	This vulnerability arises when an attacker sets the HTTP/2 initial window size to 0, **blocking data transmission** and causing a denial of service (DoS)
HTTP/2 stream memory not reclaimed right away on RST	This vulnerability occurs when HTTP/2 stream memory is not freed on reset, allowing attackers to cause **memory exhaustion** and **denial of service** (DoS)

Vulnerability	Description
Insecure default configuration	This vulnerability arises from insecure default admin credentials, leading to **remote code execution** (RCE) when attackers use these credentials to gain **admin access**
Improper authorization	This vulnerability arises from improper authorization within the Submarine server's core components, allowing attackers to exploit **faulty checks for unauthorized access or privilege escalation**
DNS rebinding in import functionality	This vulnerability allows attackers to **manipulate DNS responses** and **access internal services** due to inadequate input validation in Apache Allura
Path traversal	Improper directory path limitations in Apache OFBiz allows attackers to **access files outside the intended directory** and potentially execute code or access sensitive data
SQL injection	This vulnerability caused by improper neutralization of SQL elements in Apache Submarine Server Core, which allows attackers to **execute arbitrary SQL queries**, leading to unauthorized access and data manipulation

https://httpd.apache.org

Copyright © EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit eccouncil.org

Apache Vulnerabilities

Source: *https://httpd.apache.org*

The following are some of the common vulnerabilities found in Apache Servers:

Vulnerability	Description
HTTP response splitting	▪ This vulnerability occurs when improperly validated input allows attackers to inject malicious headers into HTTP responses. ▪ Attackers can leverage this to manipulate web traffic, potentially leading to cross-site scripting (XSS), cache poisoning attacks or sensitive information disclosure.
HTTP/2 DoS by memory exhaustion on endless continuation frames	▪ This vulnerability occurs when attackers send continuous HTTP/2 headers, leading to excessive memory consumption and a potential denial of service (DoS). ▪ Attackers take advantage of this by exhausting the server's memory, which results in the server becoming unresponsive or crashing.
mod_macro buffer over-read	▪ This vulnerability occurs when the mod_macro module improperly handles macro expansion, causing it to read beyond the buffer's end. ▪ Attackers exploit this by sending specially crafted requests that trigger the over-read, potentially revealing sensitive information stored in adjacent memory locations.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

DoS in HTTP/2 with initial window size 0	▪ This vulnerability arises when an attacker sets the HTTP/2 initial window size to 0, which blocks the server from sending data. ▪ Attackers exploit this by sending requests that set the window size to 0, causing the server to wait indefinitely for window size updates, leading to a denial of service (DoS).
HTTP/2 stream memory not reclaimed right away on RST	▪ This vulnerability occurs when memory allocated for an HTTP/2 stream is not immediately freed upon receiving a stream reset (RST) frame. ▪ Attackers exploit this by repeatedly creating and resetting streams, causing memory to be consumed without being released, eventually leading to memory exhaustion and a denial of service (DoS).
Insecure default configuration	▪ This vulnerability arises from insecure default admin credentials, leading to remote code execution (RCE). ▪ Attackers exploit this by using the default credentials to gain admin access and execute arbitrary code.
Improper authorization	▪ This vulnerability arises from improper authorization mechanisms within the server's core components. ▪ Attackers can leverage this by exploiting the faulty authorization checks to gain unauthorized access or escalate their privileges to access and perform restricted actions.
DNS rebinding in import functionality	▪ This vulnerability occurs because of inadequate input validation in the import functionality of Apache Allura. ▪ It allows attackers to manipulate DNS responses and access internal services, potentially exposing sensitive information.
Environment variable injection	▪ This vulnerability arises from improper handling of environment variables, allowing attackers to override configurations such as `ZEPPELIN_INTP_CLASSPATH_OVERRIDES` in Apache Zeppelin. ▪ Attackers leverage this by injecting malicious code or commands into these variables, leading to arbitrary code execution on the server.
Code injection	▪ This vulnerability arises when connecting to a MySQL database via the JDBC driver in Apache Zeppelin. ▪ Attackers can inject sensitive configuration or malicious code during the database connection setup, leading to remote code execution.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

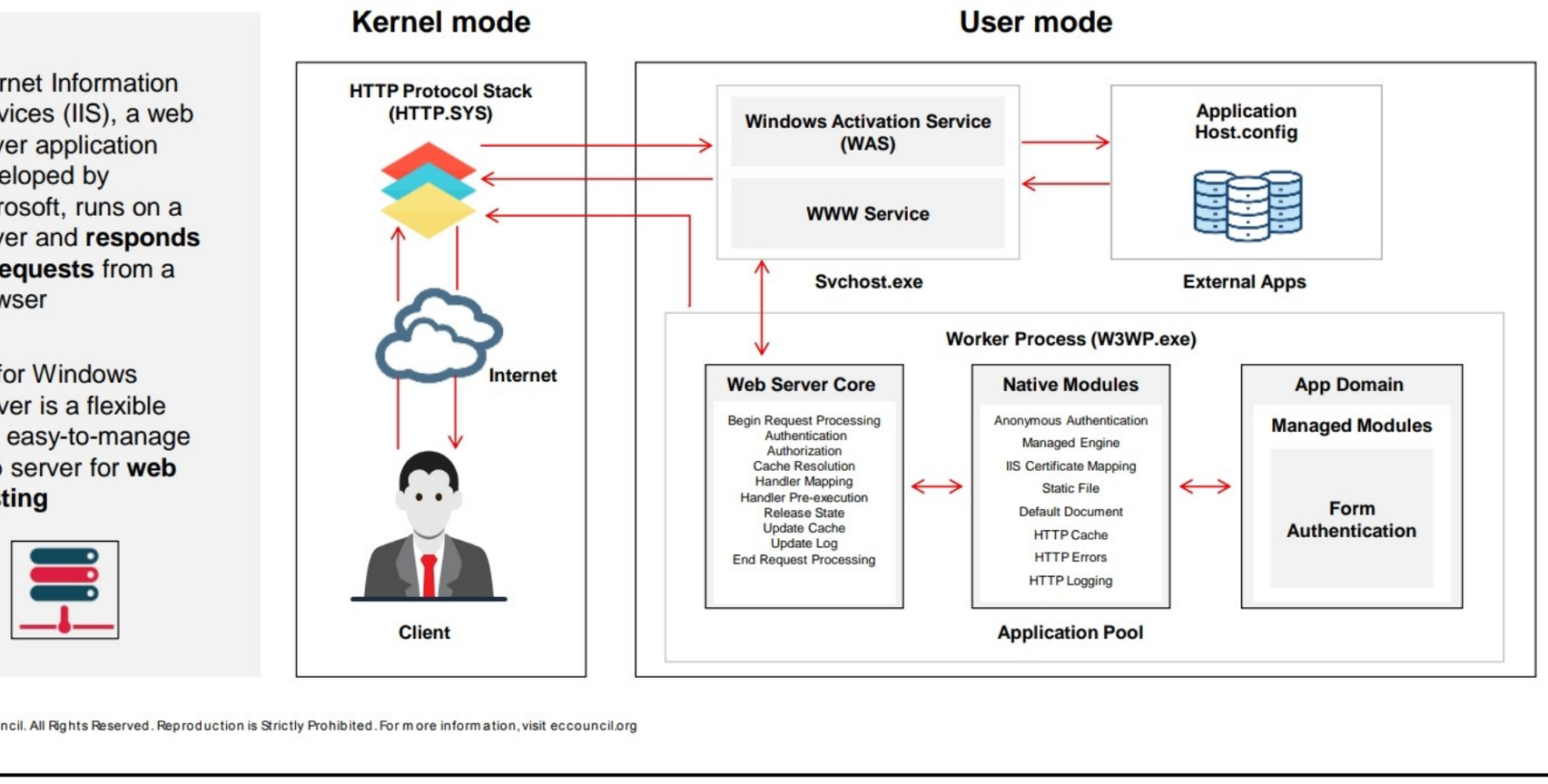
Improper certificate validation	▪ This vulnerability arises from improper certificate validation in FTP_TLS connections of Apache Airflow. ▪ Attackers can leverage this by intercepting or manipulating FTP traffic, potentially leading to man-in-the-middle (MITM) attacks.
Cross-site scripting (XSS)	▪ This vulnerability arises due to improper input handling which attackers can leverage to perform cross-site scripting (XSS) attacks by injecting malicious scripts into log entries. ▪ This vulnerability enables an attacker to insert harmful data into the task instance logs in Apache Airflow.
Path-traversal vulnerability	▪ This vulnerability arises due to improper limitation of pathname to a restricted directory, allowing attackers to access files and directories outside the intended directory in Apache OFBiz. ▪ Attackers leverage this vulnerability to potentially execute arbitrary code or access sensitive information by navigating to unintended directories.
SQL injection	▪ This vulnerability is caused by improper neutralization of special elements in SQL commands of Apache Submarine Server Core. ▪ This allows attackers to execute arbitrary SQL queries, leading to unauthorized access, data retrieval, or modification of the database.

Table 13.1: Apache server vulnerabilities

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

IIS Web Server Architecture

- Internet Information Services (IIS), a web server application developed by Microsoft, runs on a server and **responds to requests** from a browser
- IIS for Windows Server is a flexible and easy-to-manage web server for **web hosting**



Copyright © EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit eccouncil.org

IIS Web Server Architecture

Internet Information Services (IIS), a web server application developed by Microsoft, runs on a server and responds to browser requests. It supports HTTP, HTTP Secure (HTTPS), File Transfer Protocol (FTP), FTP Secure (FTPS), Simple Mail Transfer Protocol (SMTP), and Network News Transfer Protocol (NNTP). An IIS application uses HTML to present its user interface and the compiled Visual Basic code to process requests and respond to events in the browser. IIS for Windows is a flexible and easy-to-manage web server for web hosting.

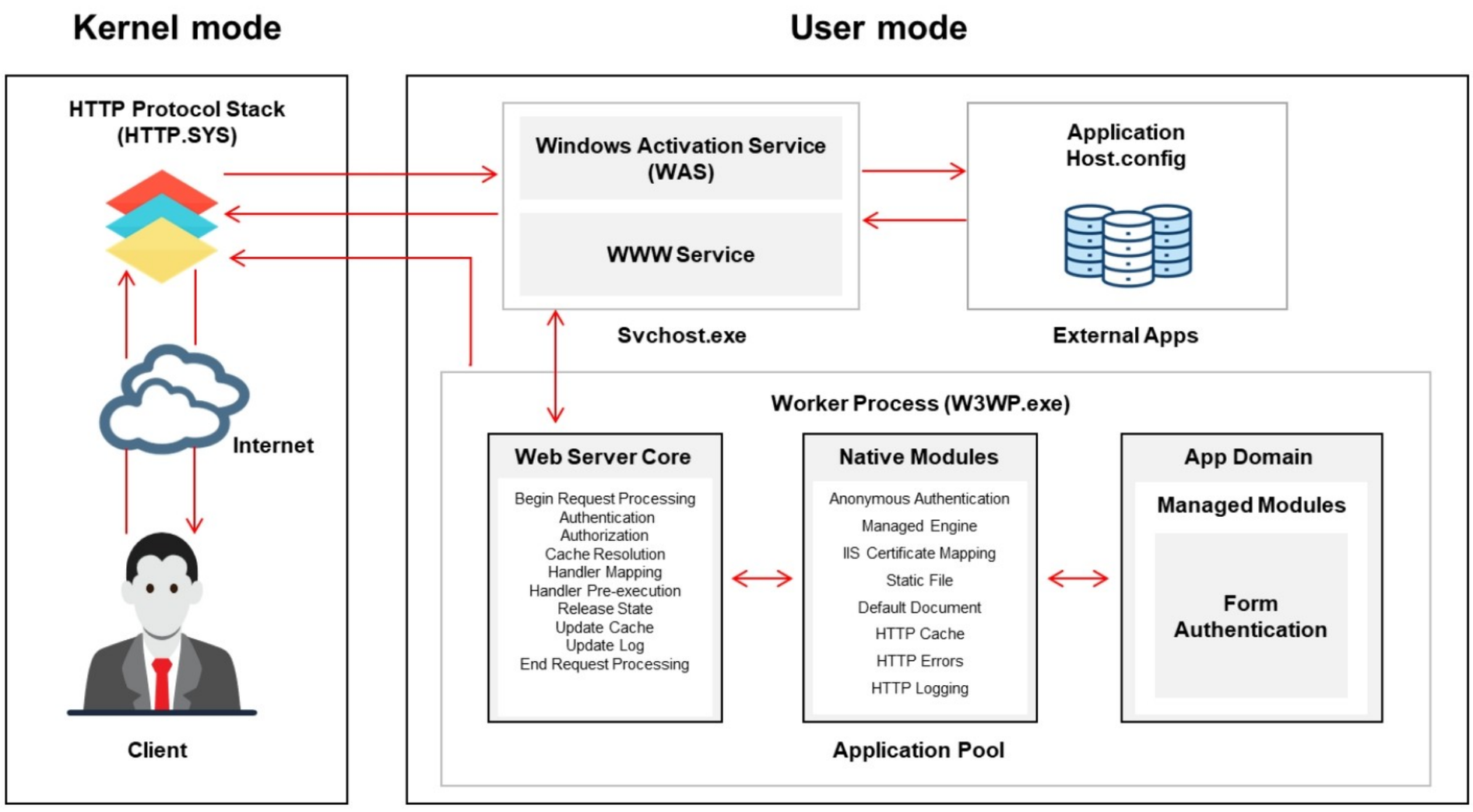


Figure 13.5: IIS web server architecture

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

IIS includes the following components:

- Protocol listeners (known as HTTP.sys)
- World Wide Web Publishing Service (known as WWW service)
- Windows Process Activation Service (WAS)

The responsibilities of the IIS components include the following:

- Listening to requests coming from the server
- Managing processes
- Reading configuration files

How IIS Server Components Function

- When an HTTP request for a resource is sent from the client browser to the web server, it is intercepted by HTTP.sys.
- HTTP.sys communicates with WAS to collect data from ApplicationHost.config, the root file in the configuration system in the IIS web server.
- WAS raises a request for configuration information, such as that of the site and application pool, to ApplicationHost.config, which is then sent to the WWW Service.
- The WWW Service utilizes the configuration information obtained to configure HTTP.sys
- A worker process is initiated by WAS for the application pool to which the request is intended.
- The request is then processed by the worker, and the response is returned to HTTP.sys.
- The client browser receives a response.

IIS depends mostly on a group of DLLs that work collectively with the main server process (inetinfo.exe), capturing different functions such as content indexing, server-side scripting, and web-based printing.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

IIS Vulnerabilities

Vulnerability	Description
Trust boundary violation vulnerability	**Inadequate privilege separation** in Telerik Report Server allows unauthenticated entity to access and manipulate restricted functionalities
Authentication bypass vulnerability	An issue in the **authentication process** can allow attackers to access restricted functionality and execute arbitrary code on the server
CRLF cross-site scripting vulnerability	**Misconfigurations in the SiteMinder Web Agent** for IIS allow attackers to execute arbitrary JavaScript in a client's browser
CCURE passwords exposed to administrators	Arises due to **improper handling** and **logging** of sensitive information within the IIS Server while hosting the C•CURE 9000 Web Server
Arbitrary file path access vulnerability	**Aquaforest TIFF Server's default configuration** allows attackers to access, enumerate, or traverse directories and files, potentially bypassing authentication

Vulnerability	Description
Windows IIS server elevation of privilege vulnerability	**Improper handling of user requests** in Windows IIS server allows attackers to gain unauthorized access and control the system
File and directory permissions vulnerability	**Incorrect default permissions in Hitachi JP1/Performance Management** allows attackers to manipulate files and directories unauthorizedly
TYPO3 cross-site scripting (XSS) vulnerability	Unfiltered use of the server environment variable **PATH_INFO** in the **GeneralUtility::getIndpEnv()** allows attacker to inject malicious HTML code into uncached pages
MailEnable vulnerability	**Improper handling of file paths** allows authenticated mail users to add files with unsanitized content in public folders where the IIS user has permission to access
XSS in password manager	Improper **neutralization of user-controllable** input within the /isapi/PasswordManager.dll can allow unauthorized entity to inject malicious scripts and steal sensitive information

https://cve.mitre.org

Copyright © EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit eccouncil.org

IIS Vulnerabilities

Source: *https://cve.mitre.org*

The following are some of the vulnerabilities associated with Microsoft IIS servers:

Vulnerability	Description
Trust boundary violation vulnerability	▪ This vulnerability results from inadequate separation of privilege boundaries, allowing an unauthenticated entity to access restricted functionality in the Telerik Report Server. ▪ Exploiting this flaw may lead to unauthorized server operations manipulation.
Authentication bypass vulnerability	▪ It occurs due to specific issues in the implementation of the authentication process where an insecure endpoint allows unauthenticated access to restricted server functionality. ▪ Attackers can leverage this vulnerability to circumvent authentication and execute arbitrary code on the server.
CRLF cross-site scripting vulnerability	▪ This vulnerability arises due to certain misconfigurations in the SiteMinder Web Agent for IIS Web Server. ▪ Attackers can execute arbitrary JavaScript code in a client's browser by exploiting this vulnerability.
CCURE passwords exposed to administrators	▪ This vulnerability arises due to improper handling and logging of sensitive information within the Microsoft Internet Information Server (IIS) while hosting the C•CURE 9000 Web Server. ▪ Attackers can exploit this vulnerability and access these logs to retrieve sensitive Windows credentials.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Arbitrary file path access vulnerability	▪ This vulnerability occurs due to the default configuration of the Aquaforest TIFF Server, which improperly restricts access to file paths. ▪ Attackers can exploit this vulnerability to access, enumerate, or traverse directories and files, potentially bypassing authentication or accessing restricted files.
Windows IIS server elevation of privilege vulnerability	▪ This vulnerability occurs due to the server's improper handling of specific user requests in Windows IIS server. ▪ Attackers can leverage this vulnerability to obtain unauthorized access and take control of the system.
File and directory permissions vulnerability	▪ This vulnerability arises due to incorrect default permissions in the Hitachi JP1/Performance Management software on Windows. ▪ Attackers can leverage this vulnerability to manipulate files and directories unauthorizedly.
TYPO3 cross-site scripting (XSS) vulnerability	▪ This vulnerability occurs due to unfiltered use of the server environment variable PATH_INFO in the GeneralUtility::getIndpEnv() component of the TYPO3 Content Management Framework. ▪ Attackers exploit this vulnerability by injecting malicious HTML code into uncached pages, potentially affecting other visitors.
MailEnable vulnerability	▪ This vulnerability occurs due to improper handling of file paths in certain conditions. ▪ This vulnerability allows authenticated mail users to add files with unsanitized content in public folders where the IIS user has permission to access, potentially leading to arbitrary code execution.
XSS in password manager	▪ This vulnerability occurs due to the improper neutralization of user-controllable input within the /isapi/PasswordManager.dll ResultURL parameter. ▪ Attackers can exploit this vulnerability to inject malicious scripts and steal sensitive information.

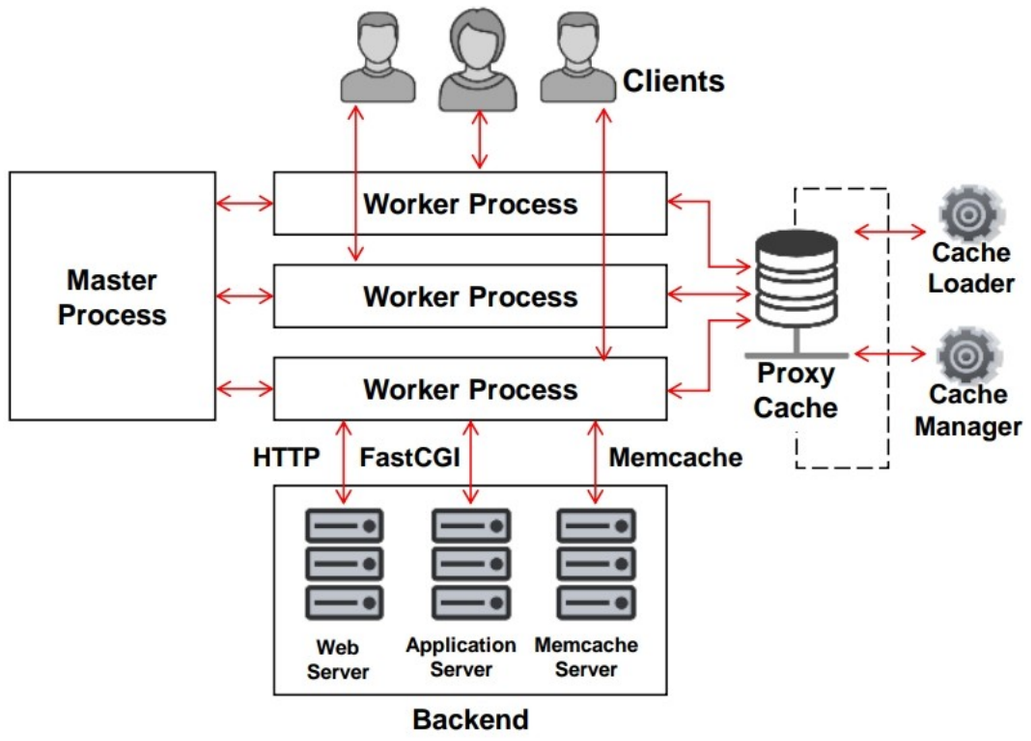
Table 13.2: IIS vulnerabilities

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

EC-Council C|EH v13

Nginx Web Server Architecture

- Nginx is a high-performance, scalable **web server**, reverse proxy, and **load balancer** that operates on a master-worker architecture
- The architecture comprises a **master process** that oversees various worker processes responsible for handling client requests
- Each **worker process** utilizes non-blocking I/O to manage multiple connections within a single-threaded loop
- Nginx also supports advanced **load balancing**, robust caching, **SSL/TLS termination**, and detailed logging



Copyright © EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit eccouncil.org

Nginx Web Server Architecture

Nginx is a high-performance scalable web server, reverse proxy, and load balancer that operates on a master-worker architecture. It employs a single-threaded, event-driven, asynchronous, and non-blocking model to efficiently manage multiple connections. The core of Nginx's architecture comprises a master process that oversees various worker processes responsible for handling client requests.

This modular architecture allows extensive customization through various HTTP, streams, mail, and third-party modules. Nginx supports advanced load balancing, robust caching, SSL/TLS termination, and detailed logging. Its security features, including access control, authentication, and rate-limiting, make it suitable for high-traffic and mission-critical applications.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

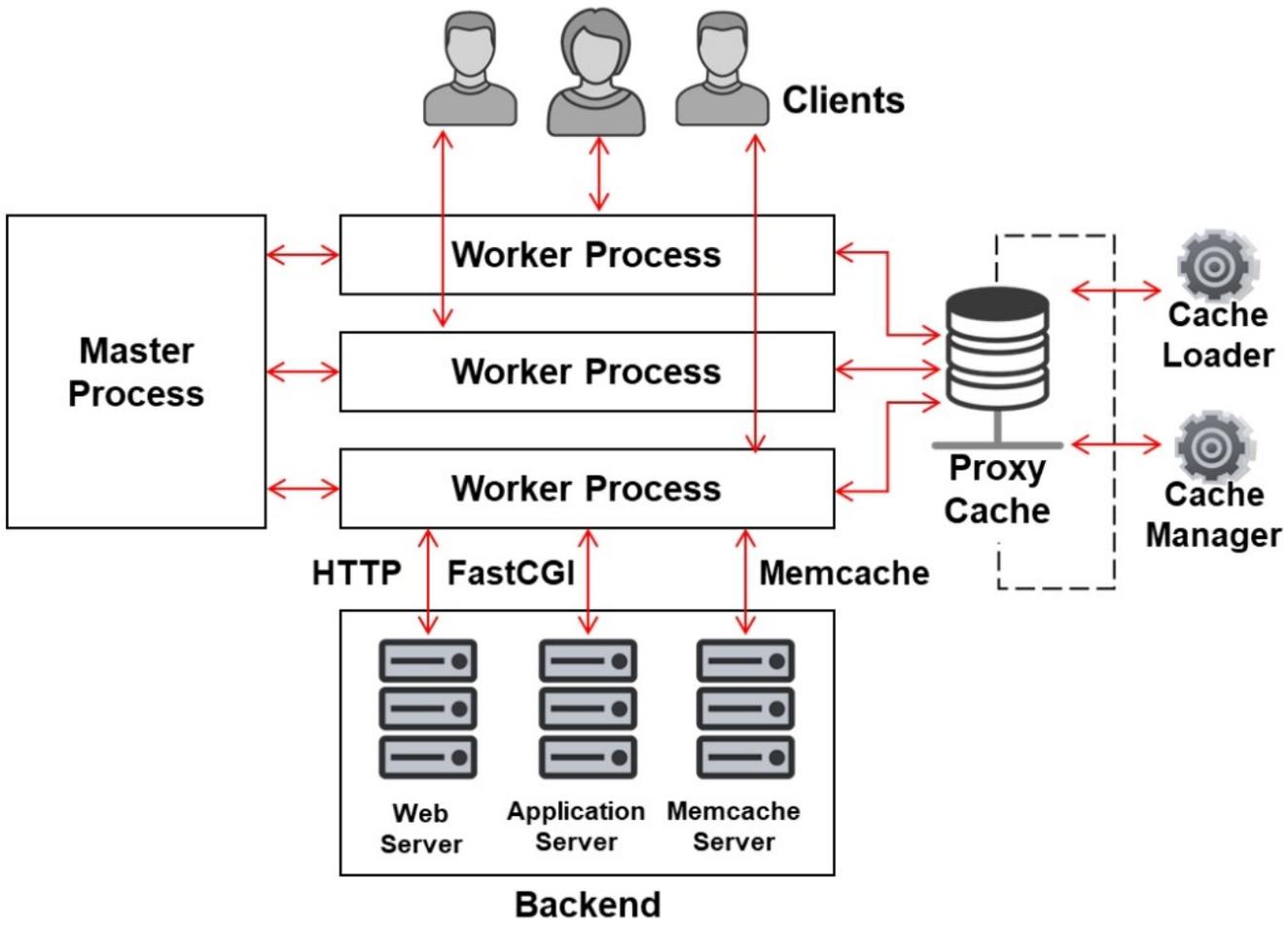


Figure 13.6: NGINX architecture

The various components of the Nginx architecture are discussed below:

- **Master Process:** The master process in Nginx is responsible for reading and validating configuration files; creating, binding, and closing sockets; and managing worker processes. It performs administrative tasks and ensures that worker processes are properly configured and run efficiently.
- **Worker Processes:** Nginx worker processes handle client requests by accepting connections, reading/writing data, and communicating with upstream servers. Each single-threaded worker uses non-blocking I/O to handle over 1000 connections simultaneously. After processing the request, a response is sent back to the client. Shared memory zones associated with each worker process enable communication and data sharing.
- **Proxy Cache:** The proxy cache stores copies of requested content, reduces backend server load, and speeds up response times by serving frequently accessed content directly from the cache memory. The Nginx cache quickly renders pages by retrieving them from the cache instead of the server.
  - **Cache Loader:** The cache loader loads cache metadata into memory at Nginx start-up, ensuring that the cache is ready to immediately serve requests. It scans the cache directories and initializes the in-memory cache structures.
  - **Cache Manager:** The cache manager periodically checks the cache for expired content and removes old or unused cache entries into free space, ensuring that the cache does not grow beyond its configured limits.
- **Web Server:** The web server component of Nginx handles HTTP requests sent by clients, serving static content, and forwarding dynamic content requests to the application servers.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

- **Application Server:** The application server component processes requests from clients by running server-side scripts or applications and delivers dynamic content to clients.
- **Memcache:** Memcache serves as a caching layer that stores data in memory for the rapid retrieval of frequently accessed data, thereby reducing the need for repeated database queries.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

10 Module 13 | Hacking Web Servers

EC-Council C|EH v13

Nginx Vulnerabilities

Vulnerability	Description
NULL pointer dereference in HTTP/3	This vulnerability occurs due to a NULL pointer dereference in **Nginx's QUIC** module, allowing attackers to launch DoS or **remote code execution**
Server-side request forgery (SSRF) vulnerability	This vulnerability in **mintplex-labs/anything-llm** allows attackers to perform port scanning, access non-public apps, and delete files
Remote code execution vulnerability	This vulnerability arises from **exposed configuration settings in Nginx-UI**, allowing attackers to perform remote code execution, privilege escalation, or information disclosure
Improper certificate validation	This vulnerability arises due to improper input validation in **Nginx-UI's Import Certificate feature**, allowing attackers to perform arbitrary file writes
SQL injection vulnerability	This vulnerability arises from **improper neutralization of SQL elements**, allowing attackers to execute arbitrary SQL queries for unauthorized access or data breaches

Vulnerability	Description
Unauthenticated private keys access	This vulnerability occurs because **Nginx does not support .htaccess files**, allowing attackers to read private keys
Excessive memory usage and CPU exhaustion in HTTP/2	This vulnerability arises from **improper memory handling** and **excessive CPU usage in HTTP/2 requests**, allowing attackers to disrupt operations by flooding the server
OS command injection in nginxWebUI	This vulnerability is caused by **improper handling of file arguments** in the upload feature, allowing attackers to inject and execute OS commands remotely
Default file permissions vulnerability	This vulnerability occurs because the Nginx Management Suite sets default file permissions allowing attackers to **modify sensitive files**

https://cve.mitre.org

Copyright © EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit eccouncil.org

Nginx Vulnerabilities

Source: *https://cve.mitre.org*

Some of the common vulnerabilities found in Nginx servers are discussed below:

Vulnerability	Description
NULL pointer dereference in HTTP/3	▪ This vulnerability occurs due to a NULL pointer dereference in Nginx's QUIC module when handling HTTP/3 requests, causing worker processes to terminate. ▪ Attackers can trigger this flaw by sending crafted requests to a vulnerable Nginx server, causing denial of service or potential remote code execution.
Server-side request forgery (SSRF) vulnerability	▪ This vulnerability occurs due to Server-side request forgery (SSRF) in the upload link feature of mintplex-labs/anything-llm. ▪ Attackers can exploit this vulnerability by hosting a malicious website, allowing them to perform internal port scanning, access non-public web applications, execute arbitrary file deletion, and carry out local file inclusion.
Remote code execution vulnerability	▪ This vulnerability arises due to the exposed configuration settings via Nginx-UI. ▪ Attackers can exploit this vulnerability to perform remote code execution, privilege escalation, or information disclosure.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Improper certificate validation	▪ This vulnerability occurs due to the improper validation of user input in the Import Certificate feature of Nginx-UI. ▪ Attackers can exploit this vulnerability to perform arbitrary file writes.
SQL injection vulnerability	▪ This vulnerability occurs due to improper neutralization of special SQL elements, allowing unsanitized user-controlled parameters to be appended to queries. ▪ Attackers can exploit this vulnerability to execute arbitrary SQL queries for unauthorized access or data breaches.
Unauthenticated private keys access	▪ This vulnerability occurs due to the reliance on .htaccess for security, which fails on Nginx servers that do not support .htaccess files. ▪ Attackers can exploit this vulnerability to read private keys by accessing the site on a server that does not support .htaccess files.
Excessive memory usage and CPU exhaustion in HTTP/2	▪ This vulnerability arises from improper memory handling and excessive CPU usage in HTTP/2 requests. ▪ By exploiting this vulnerability, attackers flood the server with HTTP/2 requests to consume server memory and CPU, disrupting normal operations.
OS command injection in nginxWebUI	▪ This vulnerability occurs due to improper handling of file arguments in the upload feature. ▪ Attackers exploit this vulnerability to manipulate file arguments to inject and execute OS commands remotely on the server.
Default file permissions vulnerability	▪ This vulnerability occurs because the Nginx Management Suite sets default file permissions that allow authenticated modification of sensitive files. ▪ Attackers leverage this vulnerability to modify sensitive files on the Nginx Instance Manager and Nginx API Connectivity Manager.

Table 13.3: Nginx vulnerabilities

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

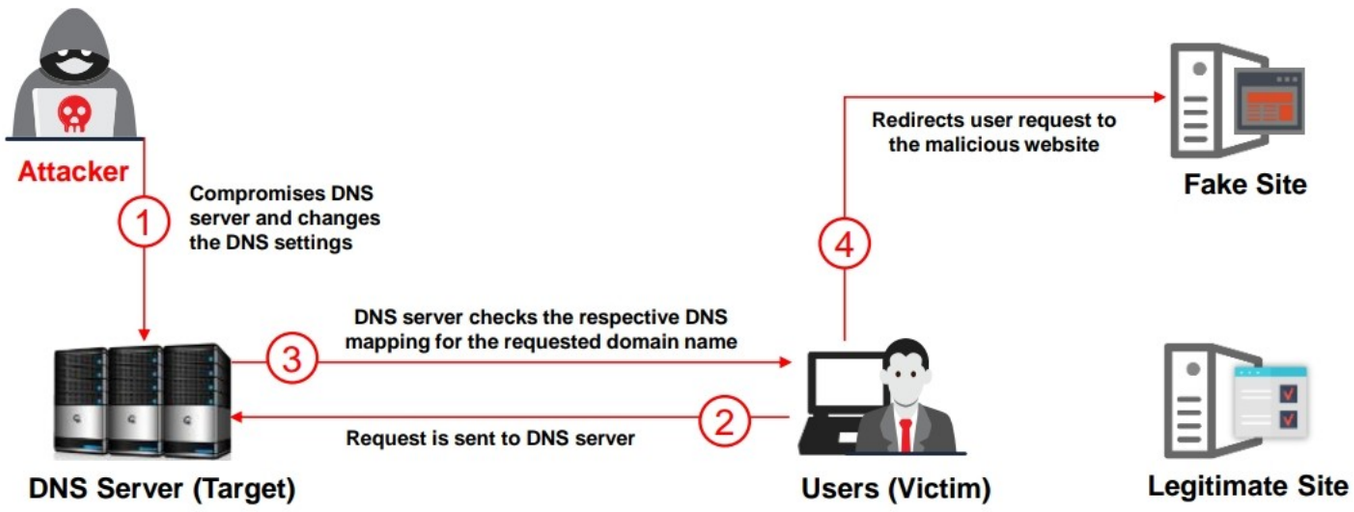
Web Server Attacks

An attacker can use many techniques to compromise a web server, such as DoS/DDoS, Domain Name System (DNS) server hijacking, DNS amplification, directory traversal, man in the middle (MITM)/sniffing, phishing, website defacement, web server misconfiguration, HTTP response splitting, web cache poisoning, Secure Shell (SSH) brute force, and web server password cracking. This section describes these attack techniques in detail.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

DNS Server Hijacking

Attacker compromises the DNS server and **changes the DNS settings** so that all the requests coming towards the target web server are redirected to his/her own malicious server



Copyright © EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit eccouncil.org

DNS Server Hijacking

The Domain Name System (DNS) resolves a domain name to its corresponding IP address. A user queries the DNS server with a domain name, and the DNS server responds with the corresponding IP address.

In DNS server hijacking, an attacker compromises a DNS server and changes its mapping settings to redirect toward a rogue DNS server that would redirect the user's requests to the attacker's rogue server. Consequently, when the user enters a legitimate URL in a browser, the settings will redirect to the attacker's fake site.

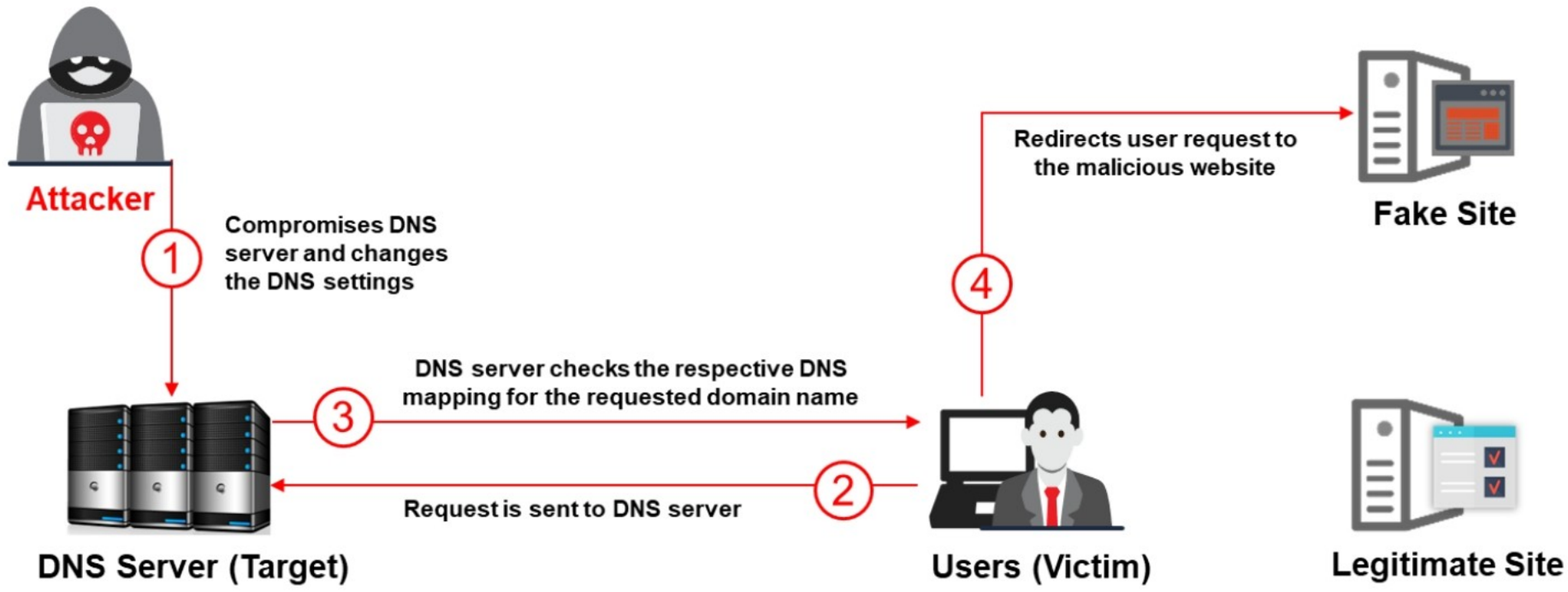


Figure 13.7: DNS server hijacking

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

DNS Amplification Attack

Recursive DNS query is a method of requesting DNS mapping. The query goes through DNS servers recursively until it fails to find the specified domain name to IP address mapping.

The following are the steps involved in processing recursive DNS requests; these steps are illustrated in the below figure.

- **Step 1:**

  Users who desire to resolve a domain name to its corresponding IP address send a DNS query to the primary DNS server specified in its Transmission Control Protocol (TCP)/IP properties.

- **Steps 2 to 7:**

  If the requested DNS mapping does not exist on the user's primary DNS server, the server forwards the request to the root server. The root server forwards the request to the .com namespace, where the user can find DNS mappings. This process repeats recursively until the DNS mapping is resolved.

- **Step 8:**

  Ultimately, when the system finds the primary DNS server for the requested DNS mapping, it generates a cache for the IP address in the user's primary DNS server.

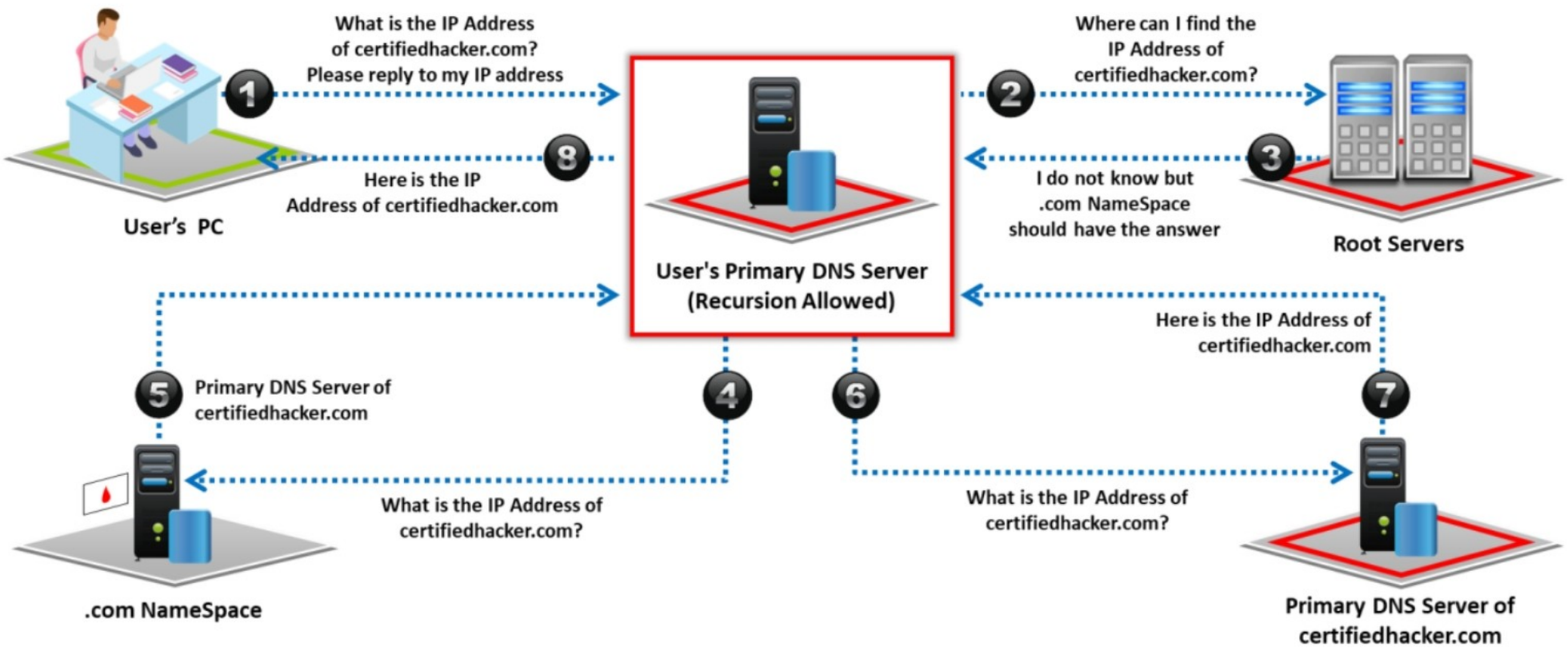


Figure 13.8: Recursive DNS query

Attackers exploit recursive DNS queries to perform a DNS amplification attack that results in DDoS attacks on the victim's DNS server.

The following are the steps involved in a DNS amplification attack; these steps are illustrated in the below figure.

- **Step 1:**

  The attacker instructs compromised hosts (bots) to make DNS queries in the network.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

- **Step 2:**

  All the compromised hosts spoof the victim's IP address and send DNS query requests to the primary DNS server configured in the victim's TCP/IP settings.

- **Steps 3 to 8:**

  If the requested DNS mapping does not exist on the victim's primary DNS server, the server forwards the requests to the root server. The root server forwards the request to the .com or respective top-level domain (TLD) namespaces. This process repeats recursively until the victim's primary DNS server resolves the DNS mapping request.

- **Step 9:**

  After the primary DNS server finds the DNS mapping for the victim's request, it sends a DNS mapping response to the victim's IP address. This response goes to the victim because bots use the victim's IP address. The replies to copious DNS mapping requests from the bots result in DDoS on the victim's DNS server.

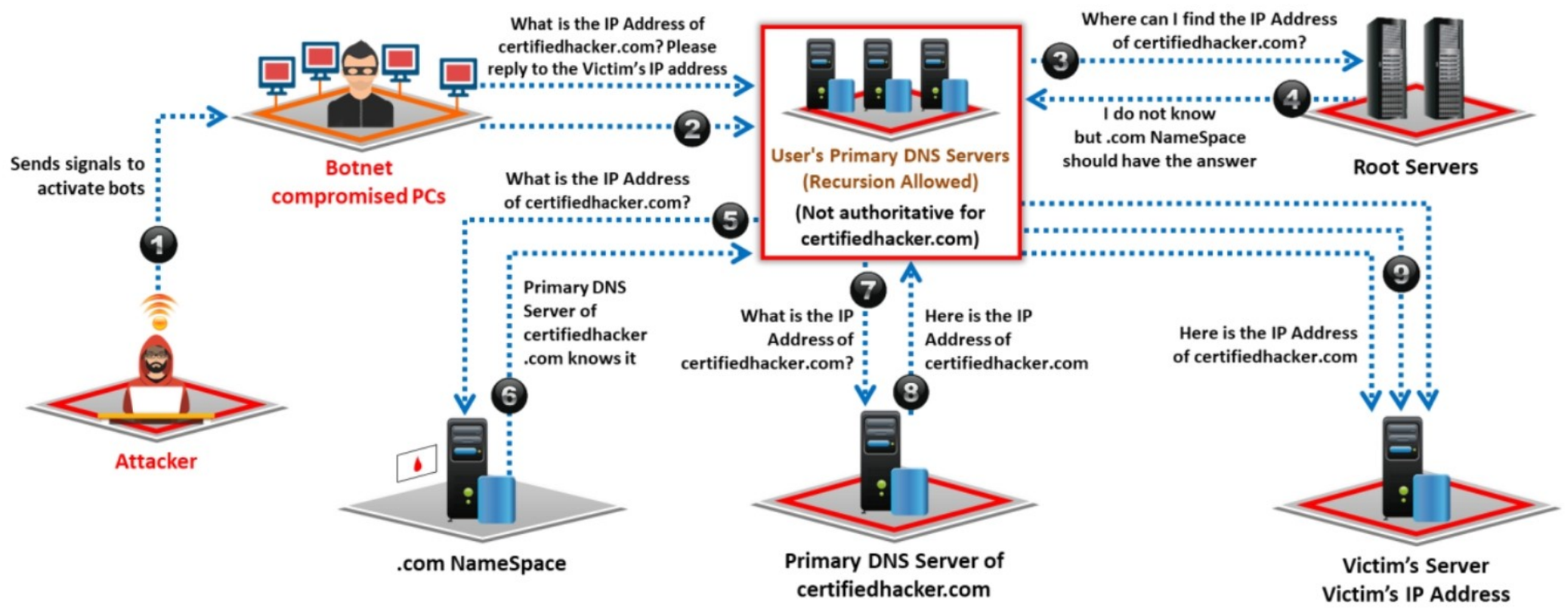


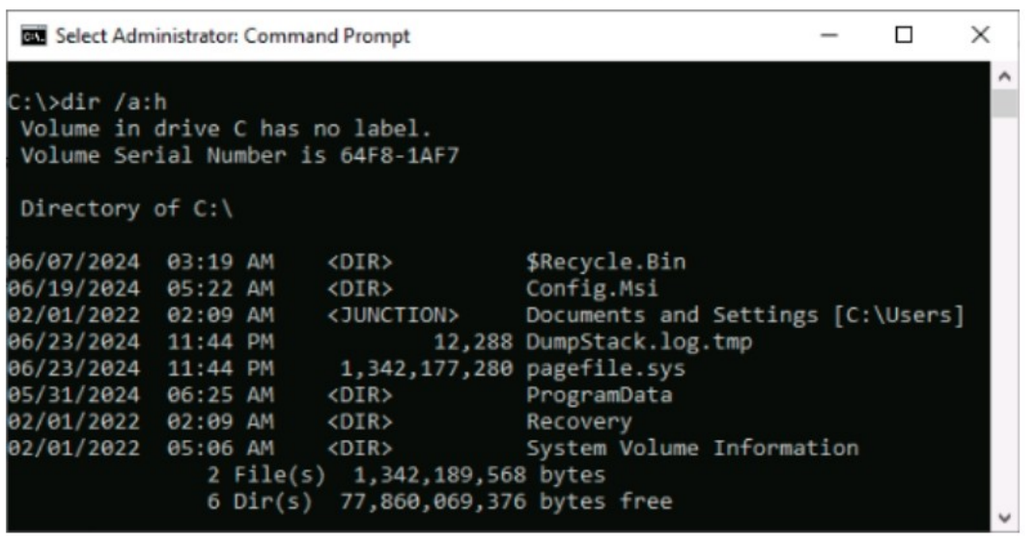
Figure 13.9: DNS amplification attack

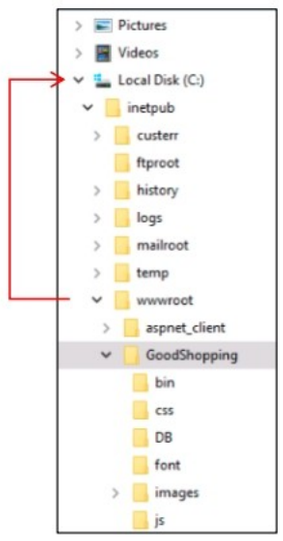
Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Directory Traversal Attacks

- In directory traversal attacks, attackers use the **../ (dot-dot-slash)** sequence to access restricted directories outside the web server root directory
- Attackers can use the **trial and error method** to navigate outside the root directory and access sensitive information in the system

http://server.com/scripts/..%5c../Windows/System32/cmd.exe?/c+dir+c:\





Copyright © EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit eccouncil.org

Directory Traversal Attacks

An attacker may be able to perform a directory traversal attack owing to a vulnerability in the code of a web application. In addition, poorly patched or configured web server software can make the web server vulnerable to a directory traversal attack.

The design of web servers limits public access to some extent. Directory traversal is the exploitation of HTTP through which attackers can access restricted directories and execute commands outside the web server's root directory by manipulating a Uniform Resource Locator (URL). In directory traversal attacks, attackers use the dot-dot-slash (../) sequence to access restricted directories outside the web server's root directory. Attackers can use the trial-and-error method to navigate outside the root directory and access sensitive information in the system.

An attacker exploits the web server software (web server program) to perform directory traversal attacks. The attacker usually performs this attack with the help of a browser. A web server is vulnerable to this attack if it accepts input data from a browser without proper validation.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

http://server.com/scripts/..%5c../Windows/System32/cmd.exe?/c+dir+c:

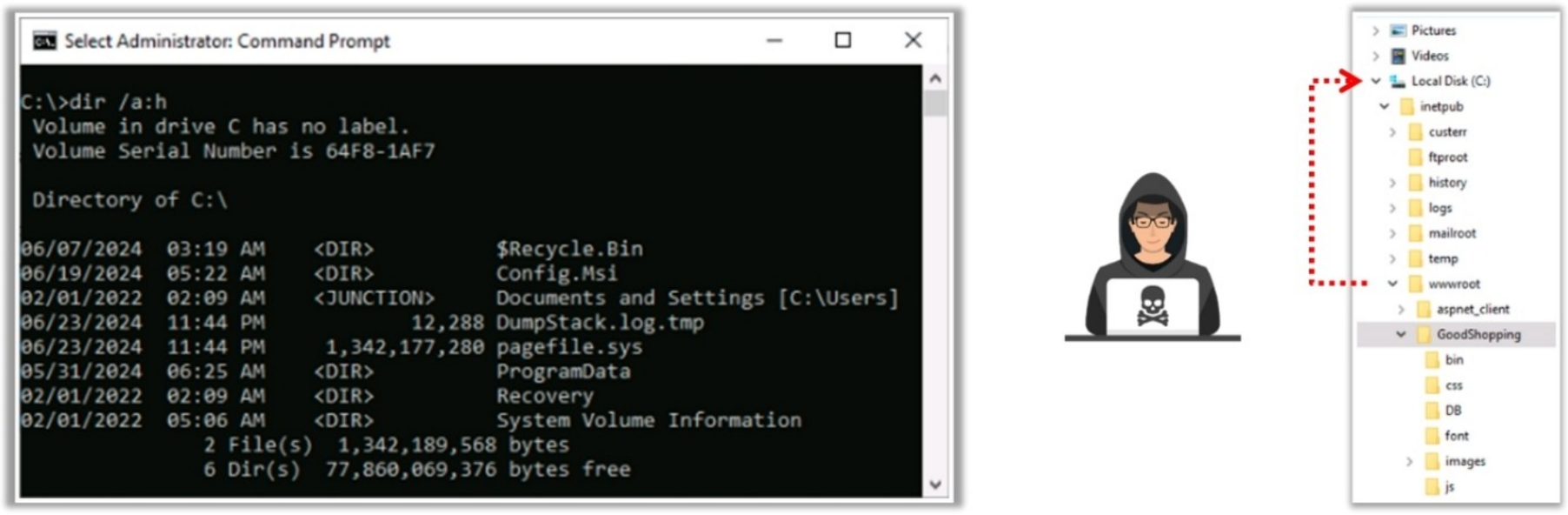


Figure 13.10: Directory traversal attack

Website Defacement

Website defacement refers to unauthorized changes made to the content of a single web page or an entire website, resulting in changes to the visual appearance of the web page or website. Hackers break into web servers and alter the hosted website by injecting code to add images, popups, or text to a page in such a manner that the visual appearance of the page changes. In some cases, the attacker may replace the entire website instead of just changing a single page.

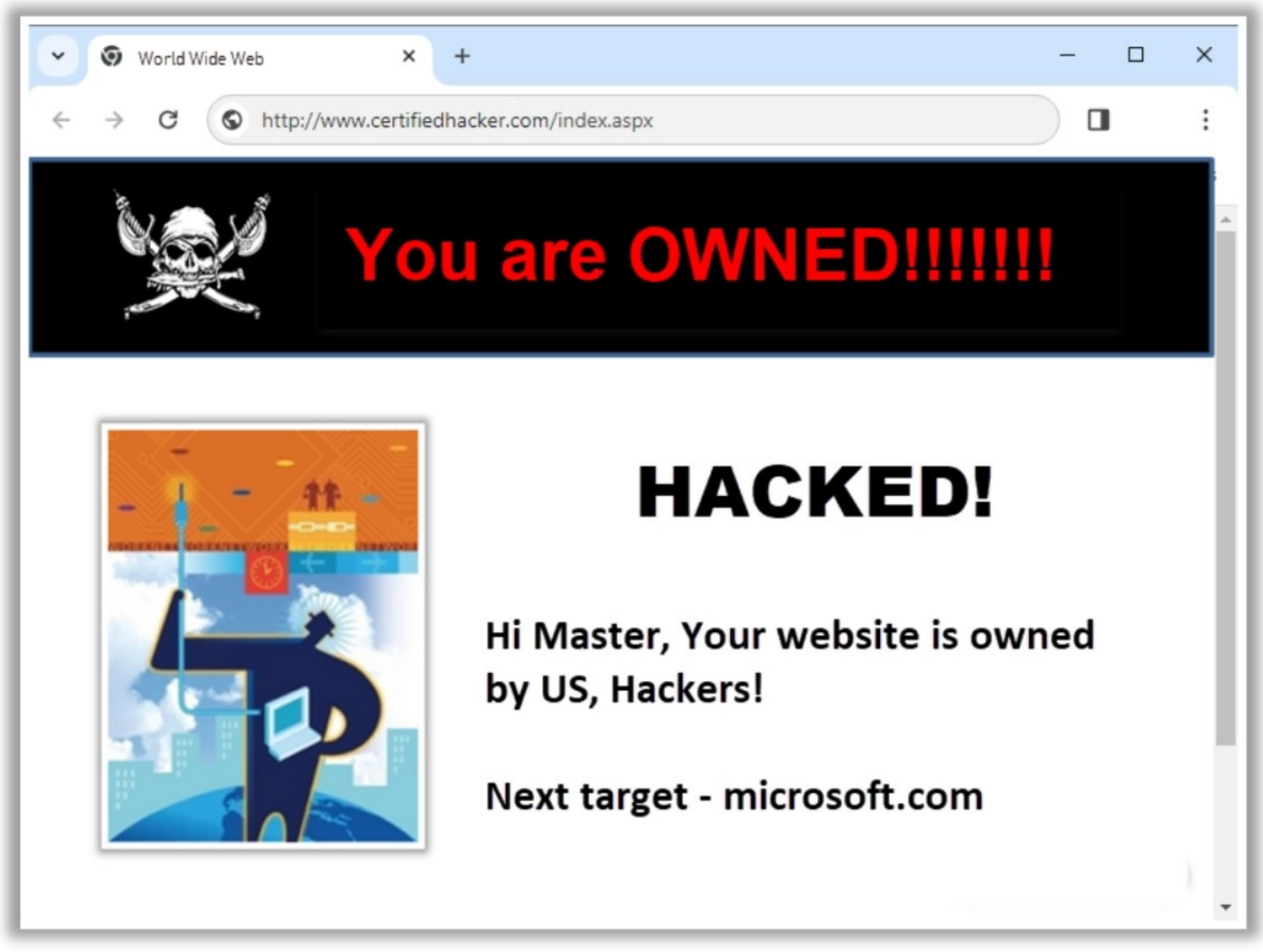
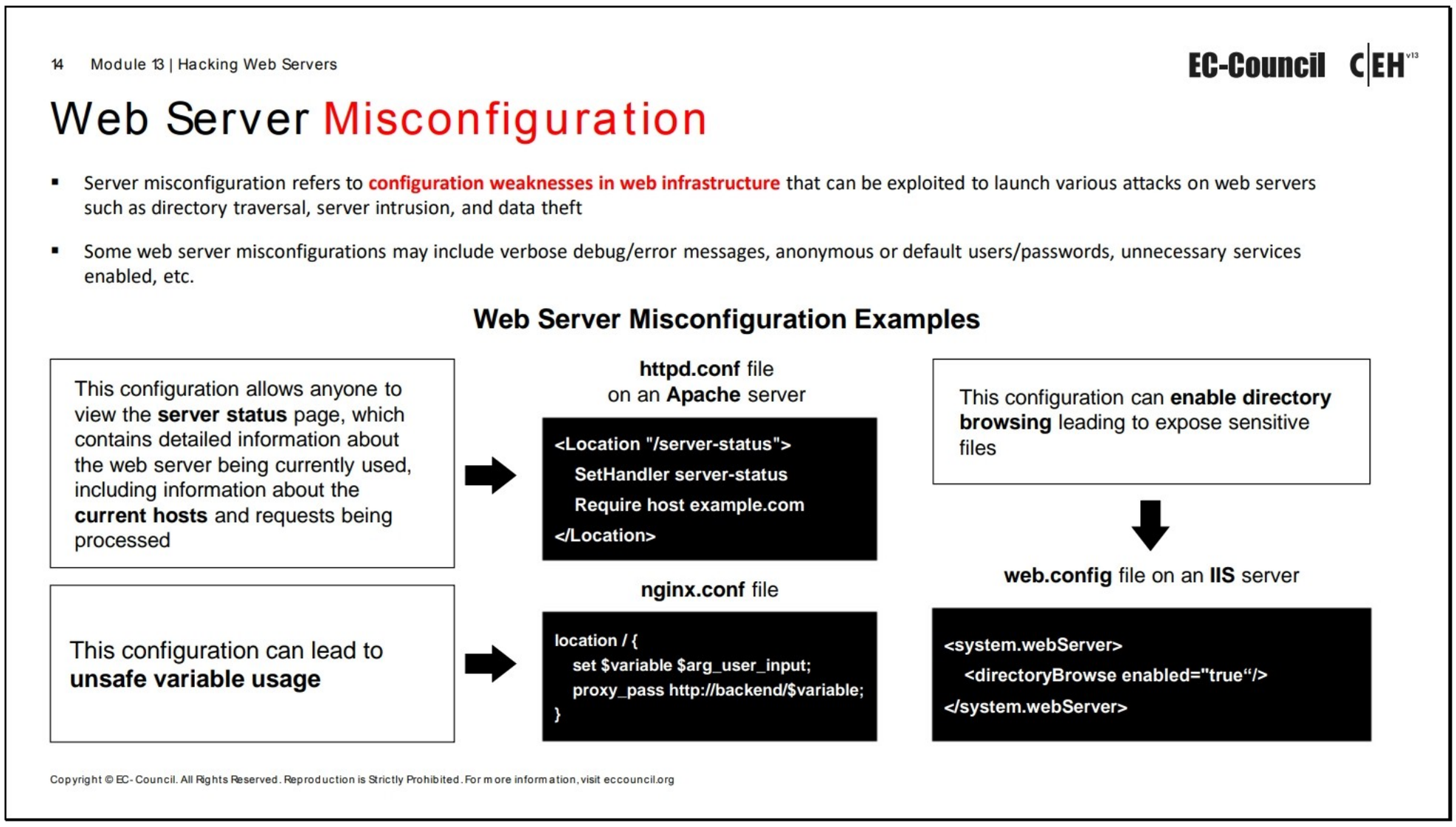


Figure 13.11: Screenshot displaying a website defacement attack

Defaced pages expose visitors to propaganda or misleading information until the unauthorized changes are discovered and corrected. Attackers use a variety of methods, such as MySQL injection, to access a website to deface it. In addition to changing the visual appearance of the target website, attackers deface websites for infecting the computers of visitors by making the website vulnerable to virus attacks. Thus, website defacement not only embarrasses the target organization by changing the appearance of its website but is also intended to harm its visitors.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.



Web Server Misconfiguration

Web server misconfiguration refers to the configuration weaknesses in web infrastructure that can be exploited to launch various attacks on web servers, such as directory traversal, server intrusion, and data theft. The following are some web server misconfigurations:

- Verbose debug/error messages
- Anonymous or default users/passwords
- Sample configuration and script files
- Remote administration functions
- Unnecessary services enabled
- Misconfigured/default SSL certificates

Examples of Web Server Misconfigurations

"**Keeping the server configuration secure requires vigilance**"—Open Web Application Security Project (OWASP)

Administrators who configure web servers improperly may leave serious loopholes in the web server, thereby providing an attacker the chance to exploit the misconfigured web server to compromise its security and obtain sensitive information. The vulnerabilities of improperly configured web servers may be related to configuration, applications, files, scripts, or web pages. An attacker searches for such vulnerable web servers to launch attacks. The misconfiguration of a web server provides the attacker a path to enter the target network of an organization. These loopholes in the server can also help an attacker bypass user

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

authentication. Once detected, these problems can be easily exploited and may result in the total compromise of a website hosted on the target web server.

As shown in the below figure, the configuration may allow anyone to view the server status page, which contains detailed information about the current use of the web server, including information about the current hosts and requests being processed.

```
<Location "/server-status">
    SetHandler server-status
    Require host example.com
</Location>
```

Figure 13.12: Screenshot displaying the httpd.conf file on an Apache server

As shown in the below figure, the configuration may give verbose error messages.

```
display_error = On
log_errors = On
error_log = syslog
ignore_repeated_errors = Off
```

Figure 13.13: Screenshot displaying the php.ini file

The figure below shows a misconfiguration in the **`web.config`** file of the IIS web server that enables directory browsing, allowing users to see the content of the directories, which can expose sensitive files.

```
<system.webServer>
    <directoryBrowse enabled="true"/>
</system.webServer>
```

Figure 13.14: Screenshot displaying the web.config file

The figure below shows another misconfiguration in the IIS web server that allows unrestricted file uploads, where the server allows users to upload files without proper validation or security checks.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

```
<system.webServer>
   <security>
       <requestFiltering>
          <requestLimits maxAllowedContentLength="30000000" />
       </requestFiltering>
   </security>
</system.webServer>
```

Figure 13.15: Screenshot showing IIS misconfiguration

This can lead to security risks, such as attackers uploading malicious files (e.g., web shells) that can be executed on the server, leading to remote code execution.

In addition, the figure below shows the misconfiguration in an Nginx web server where the root location (`location / {}`) is missing. This can lead to undefined behaviors, potentially exposing directory listings or default server configurations.

```
server {
    listen 80;
    server_name example.com;

    # Missing root location block
}
```

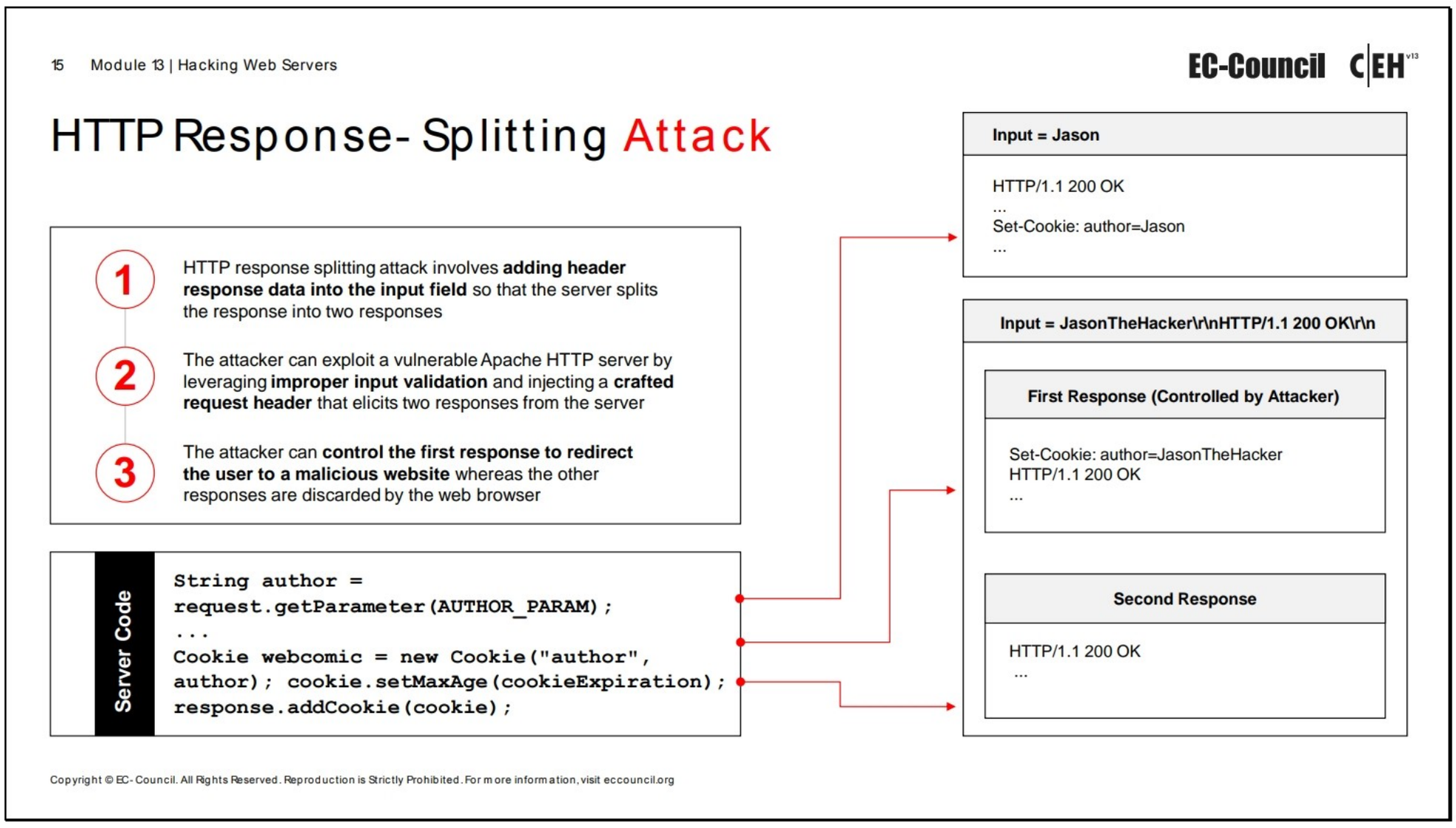
Figure 13.16: Screenshot showing the missing root location in the Nginx web server configuration

In addition, the direct use of user input in variables without sanitization can lead to injection attacks. User inputs must be validated and sanitized to prevent malicious payloads from being executed.

```
location / {
    set $variable $arg_user_input;
    proxy_pass http://backend/$variable;
}
```

Figure 13.17: Screenshot displaying Nginx web server misconfiguration

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.



HTTP Response-Splitting Attack

An HTTP response-splitting attack is a web-based attack in which the attacker tricks the server by injecting new lines into response headers, along with arbitrary code. It involves adding header response data into the input field so that the server splits the response into two responses. This type of attack exploits vulnerabilities in input validation. Cross-site scripting (XSS), cross-site request forgery (CSRF), and Structured Query Language (SQL) injection are examples of this type of attack.

An attacker can exploit a vulnerable Apache HTTP server by leveraging improper input validation and sending a clinically constructed request header that elicits two responses from the server. The attacker alters a single request to appear as two requests by adding header response data into the input field. The web server, in turn, responds to each request. The attacker can pass malicious data to a vulnerable application, and the application includes the data in an HTTP response header. The attacker can control the first response to redirect the user to a malicious website, whereas the web browser will discard other responses.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

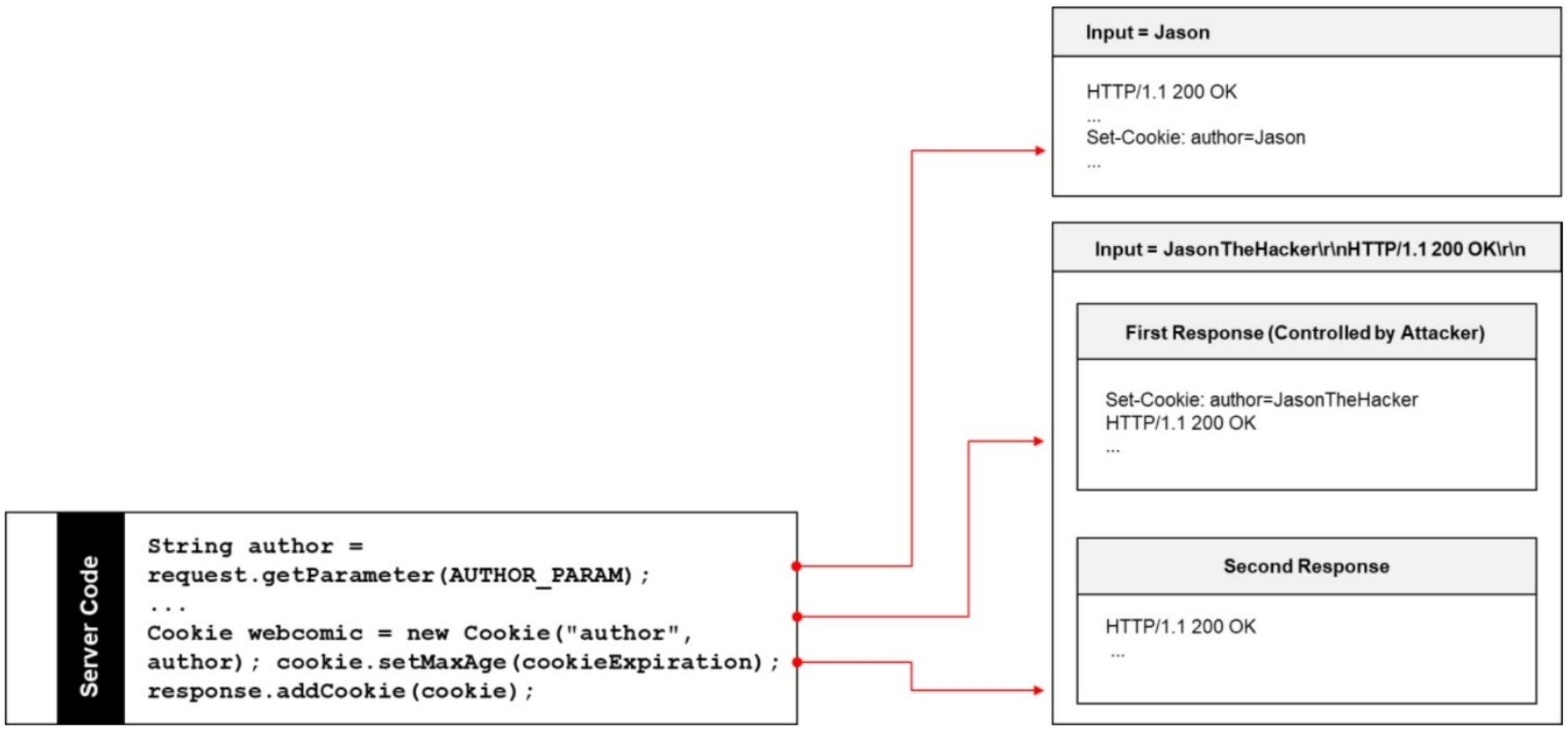


Figure 13.18: HTTP Response-Splitting attack

Example of an HTTP Response-Splitting Attack

In this example, the attacker sends a response-splitting request to the web server. The server splits the response into two and sends the first response to the attacker and the second response to the victim. After receiving the response from the web server, the victim requests service by providing credentials. Simultaneously, the attacker requests for the index page. Subsequently, the web server sends the response to the victim's request to the attacker, and the victim remains uninformed.

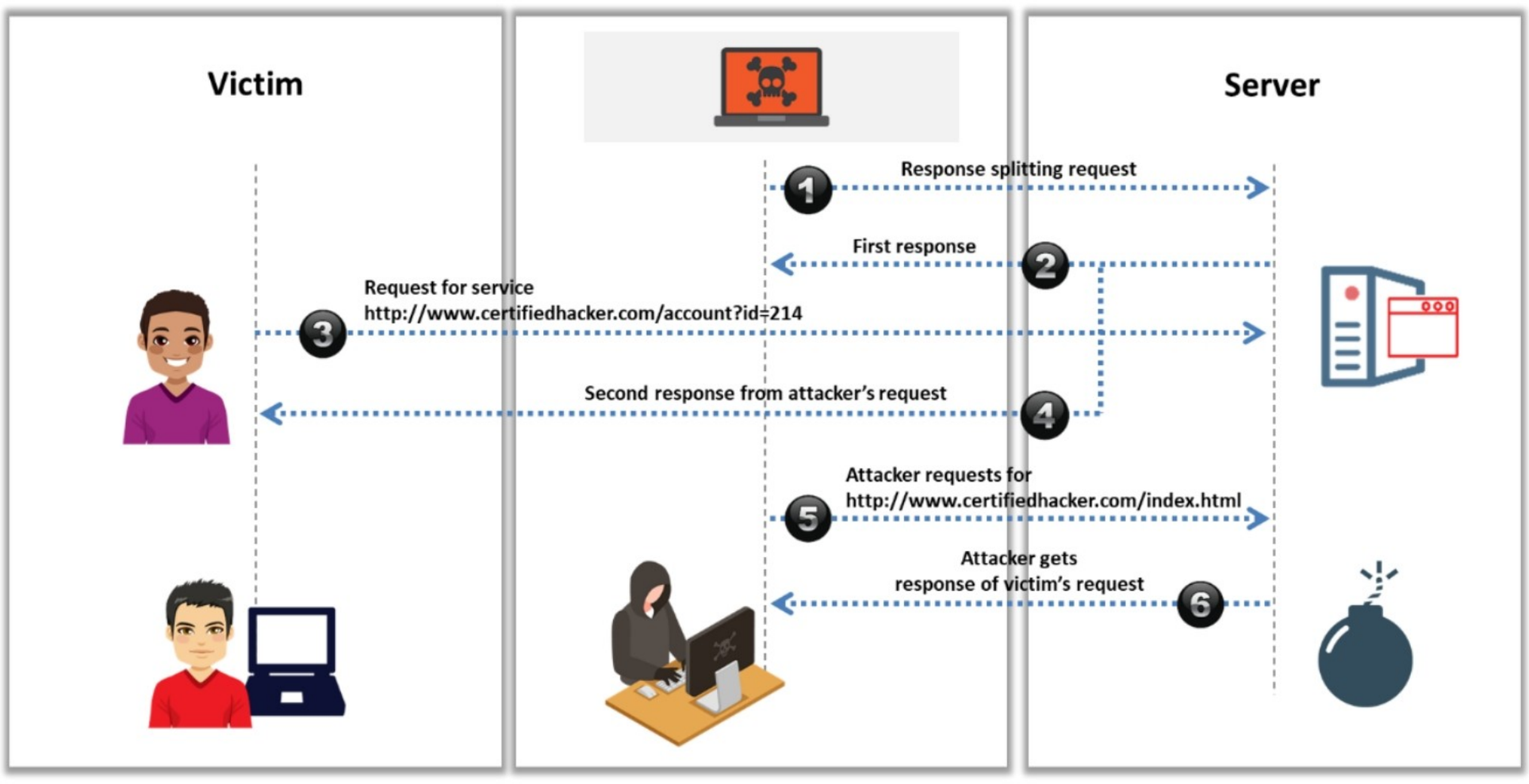
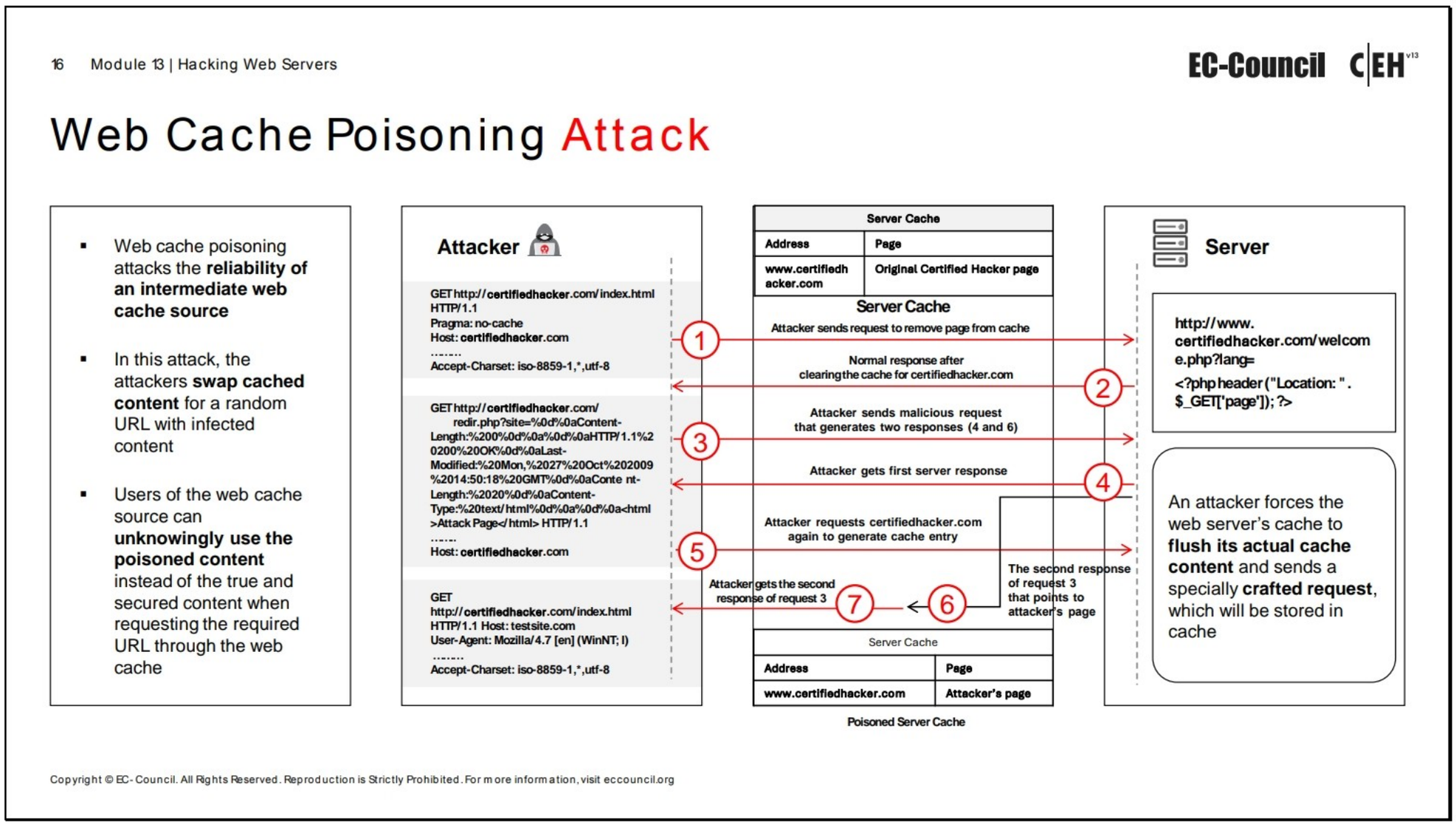


Figure 13.19: Example of an HTTP response-splitting attack

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.



Web Cache Poisoning Attack

Web cache poisoning damages the reliability of an intermediate web cache source. In this attack, an attacker swaps cached content for a random URL with infected content. Users of the web cache source may unknowingly use the poisoned content instead of the true and secured content when requesting the required URL through the web cache.

An attacker forces the web server's cache to flush its actual cache content and sends a specially crafted request to store in the cache. In this case, all the users of that web server cache will receive malicious content until the servers flush the web cache. Web cache poisoning attacks are possible if the web server and application have HTTP response-splitting flaws.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

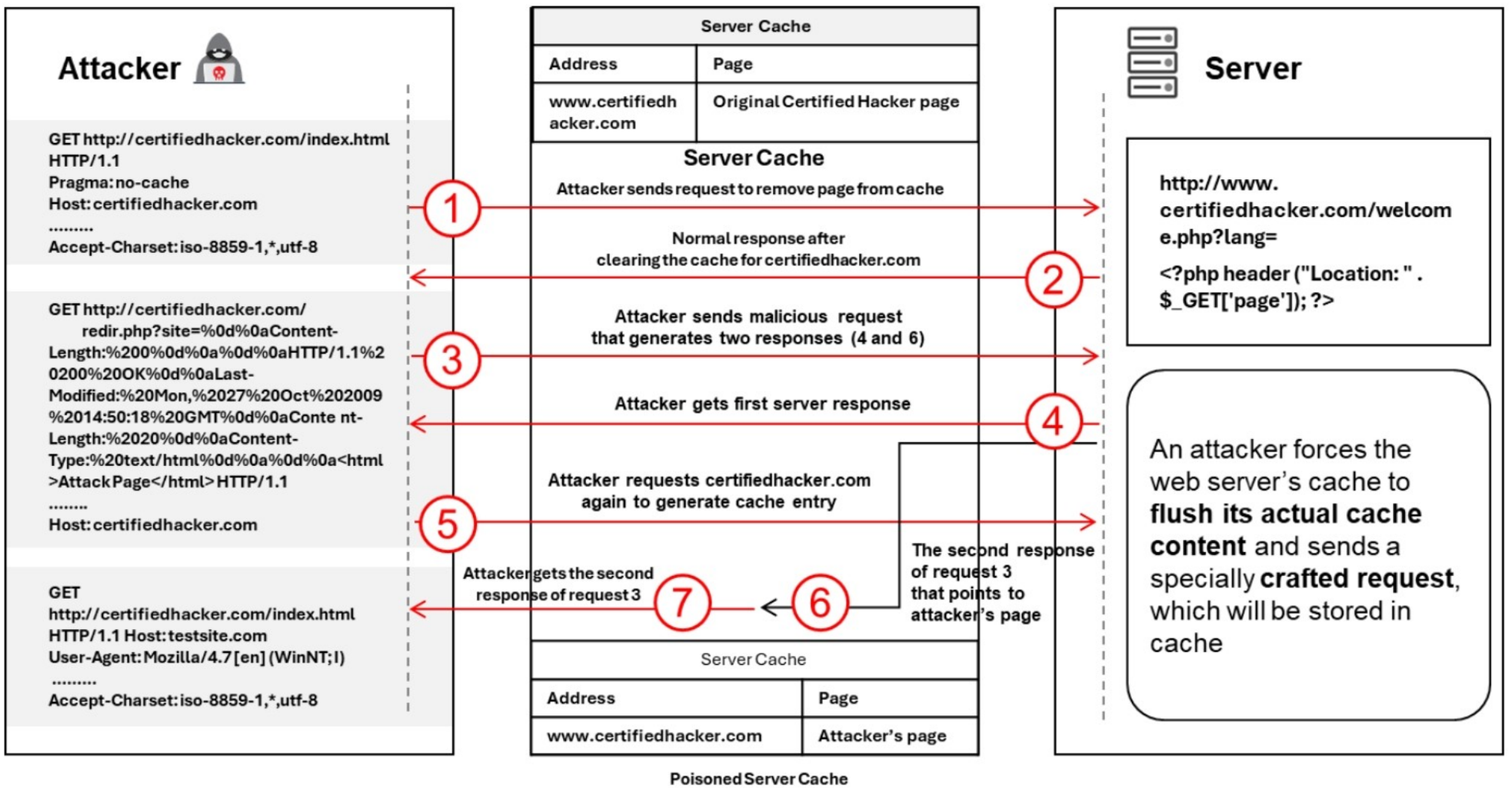
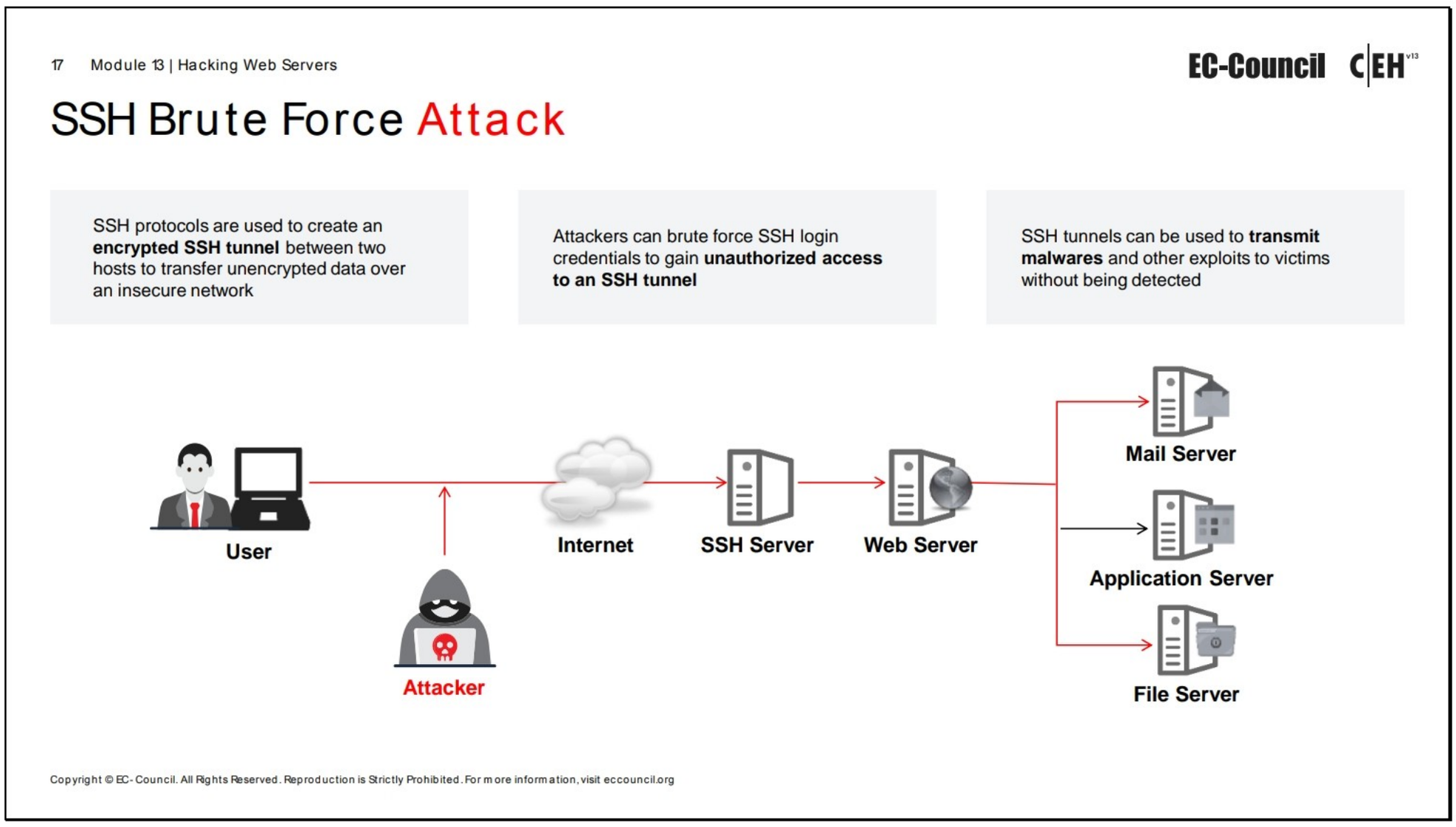


Figure 13.20: Web cache poisoning attack

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.



SSH Brute Force Attack

Attackers use SSH protocols to create an encrypted SSH tunnel between two hosts to transfer unencrypted data over an insecure network. Usually, SSH runs on TCP port 22. To perform an attack on SSH, an attacker scans the entire SSH server using bots (performs a port scan on TCP port 22) to identify possible vulnerabilities. With the help of a brute-force attack, the attacker obtains login credentials to gain unauthorized access to an SSH tunnel. An attacker who obtains the login credentials of SSH can use the same SSH tunnels to transmit malware and other means of exploitation to victims without being detected. Attackers use tools such as Nmap and Ncrack on a Linux platform to perform an SSH brute-force attack.

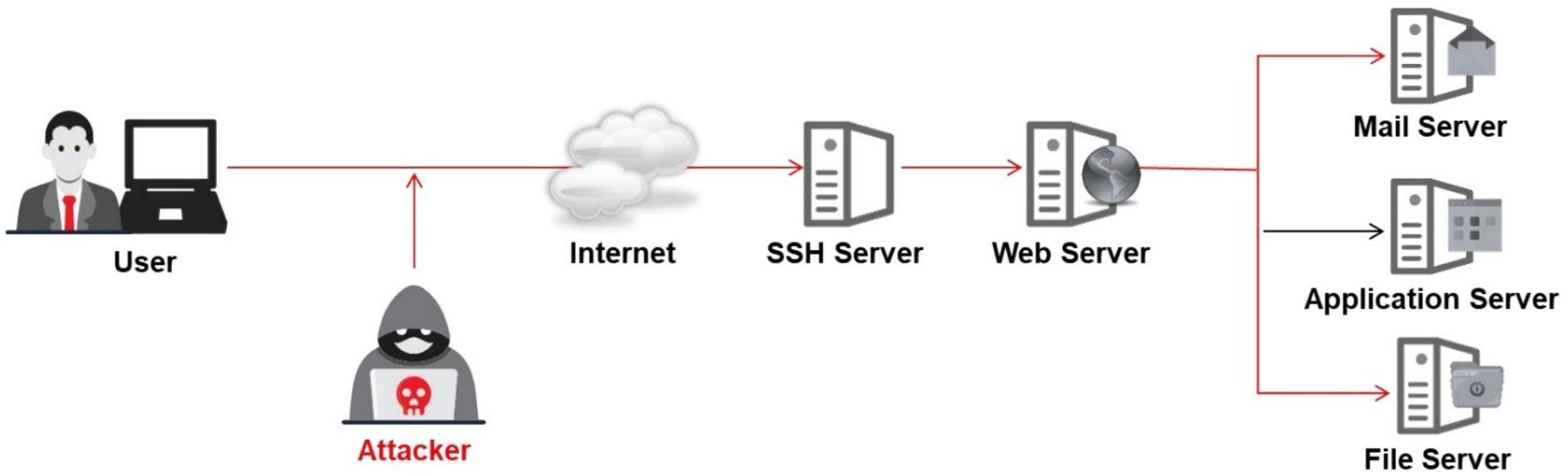


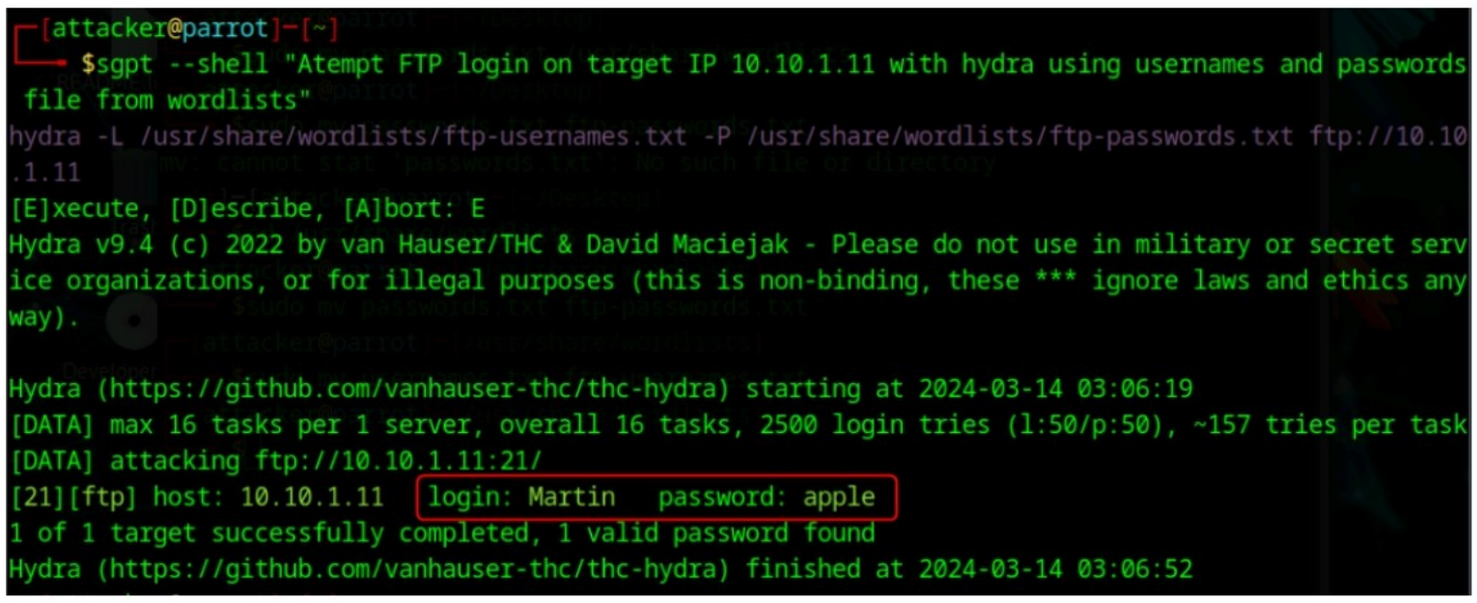
Figure 13.21: SSH Brute Force attack

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

FTP Brute Force with AI

An attacker can also leverage AI-powered ChatGPT or other generative AI technology to perform this task by using an appropriate prompt such as

- ***"Attempt FTP login on target IP 10.10.1.11 with hydra using usernames and passwords from wordlists"***



Copyright © EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit eccouncil.org

FTP Brute Force with AI

Attackers can leverage AI-powered technologies to enhance and automate brute-force attempts. With the aid of AI, attackers can effortlessly perform brute-force attacks on targets.

For example,

An attacker can use ChatGPT to perform this task by using an appropriate prompt such as

"Attempt FTP login on target IP 10.10.1.11 with hydra using usernames and passwords from wordlists"

The output of this prompt results in the following command:

```
hydra -L/usr/share/wordlists/ftp-usernames.txt -p
/usr/share/wordlists/ftp-passwords.txt ftp://10.10.1.11
```

This command will use Hydra to perform a brute-force attack against the FTP server running on the IP address "10.10.1.11", using the usernames and passwords specified in the provided wordlists.

- **`hydra`:** This is the command to execute the Hydra tool.
- **`-L /usr/share/wordlists/ftp-usernames. txt`:** Specifies the path to the file containing a list of usernames to use for the brute-force attack. The `-L` flag indicates that the provided file contains a list of usernames.
- **`-P /usr/share/wordlists/ftp-passwords. txt`:** Specifies the path to the file containing a list of passwords to use for the brute-force attack. The `-P` flag indicates that the provided file contains a list of passwords.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

- **`ftp://10.10.1.11`:** Specifies the protocol (FTP) and the target IP address (10.10.1.11) where the brute-force attack will be directed.

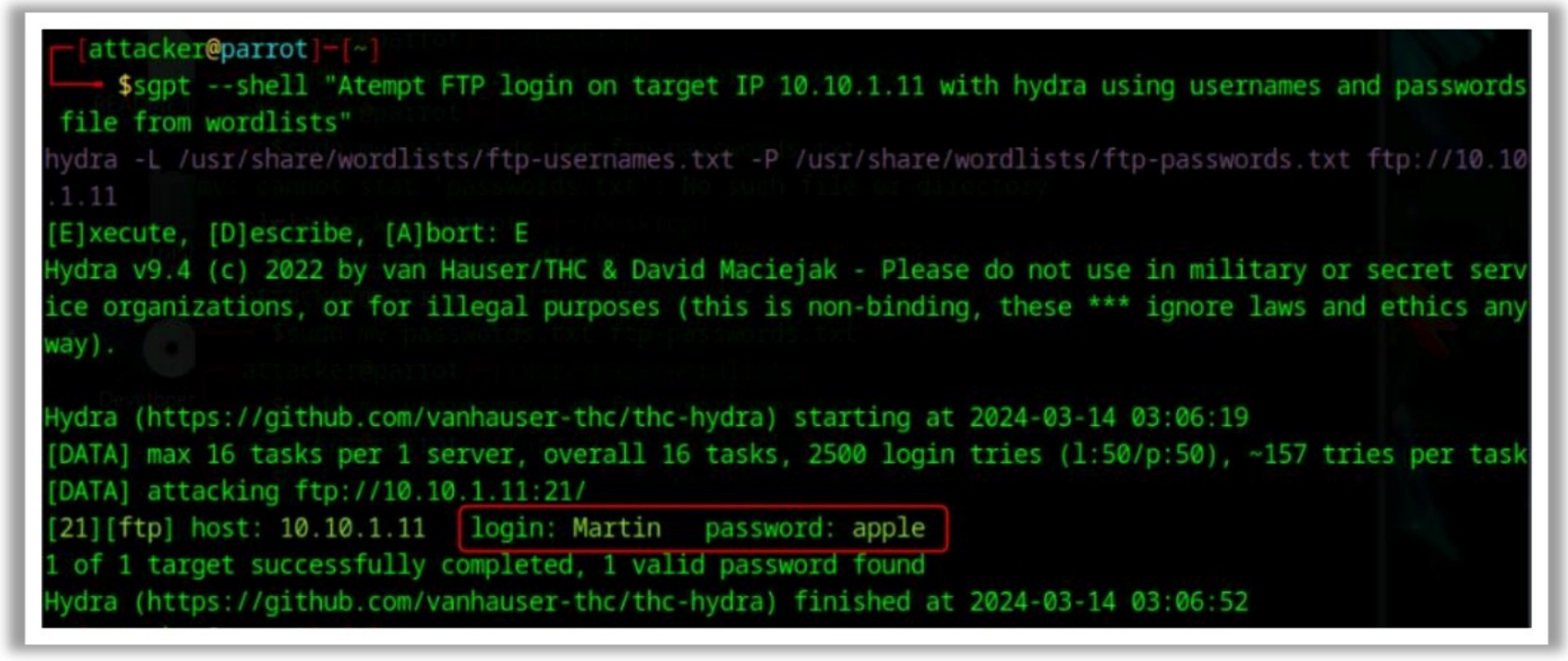


Figure 13.22: To perform a brute-force attack against the FTP server running on the IP address

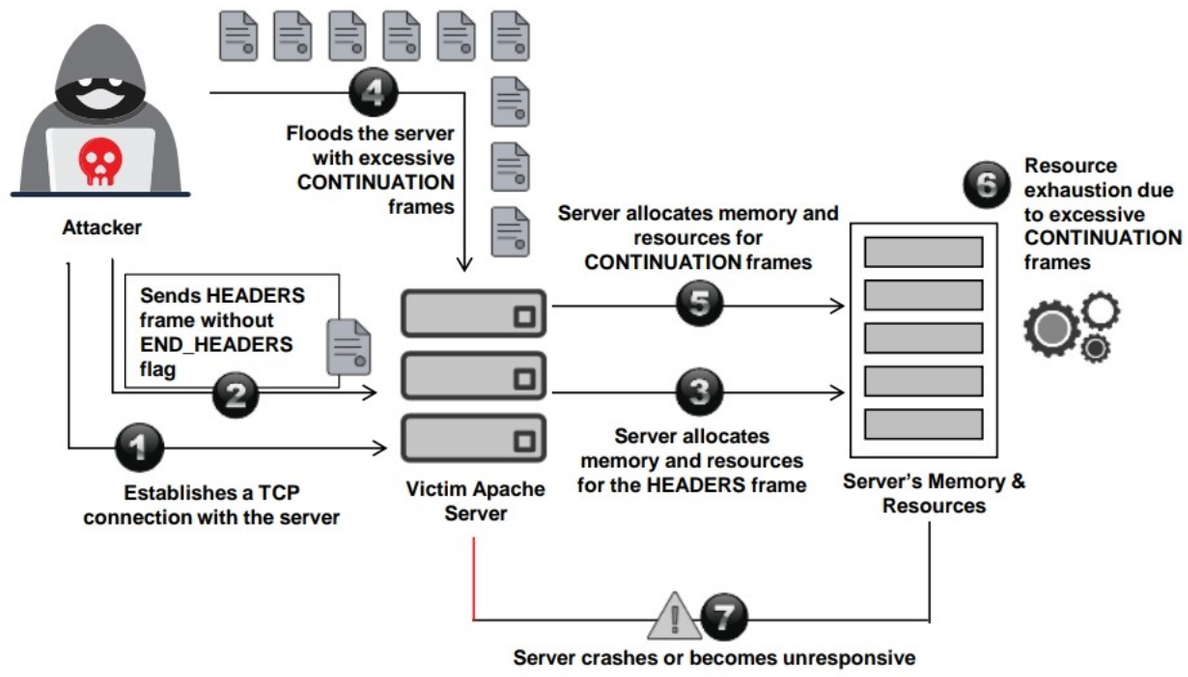
Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

19 Module 13 | Hacking Web Servers

EC-Council CEH v13

HTTP/2 Continuation Flood Attack

- The HTTP/2 continuation flood attack involves exploiting the **handling mechanism** of **HTTP/2 CONTINUATION frames**
- Attackers send numerous CONTINUATION frames over a **single TCP connection**, overwhelming the Apache server's resources, causing a **Denial-of-Service condition** on the target server



Copyright © EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit eccouncil.org

HTTP/2 Continuation Flood Attack

The HTTP/2 continuation flood attack involves exploiting the handling mechanism of HTTP/2 CONTINUATION frames to exhaust the target Apache server. In HTTP/2, headers that are too large to fit into a single HEADERS frame can be divided into multiple frames. The initial portion of the headers is sent in a HEADERS frame, and the remaining parts are sent in CONTINUATION frames. Attackers exploit this mechanism by sending numerous CONTINUATION frames over a single TCP connection without completing the headers, overwhelming the Apache server's resources, and causing a denial-of-service (DoS) condition on the server.

How HTTP/2 Continuation Flood Attack Works

- The attacker first establishes a TCP connection with the target Apache server.
- The attacker then sends a legitimate HEADERS frame. This frame contains headers for a request, and more headers follow in the subsequent CONTINUATION frames.
- Upon receiving the HEADERS frame, the Apache server allocates its memory and resources to process the frame sent by the attacker.
- Instead of completing the header sequence by setting the END_HEADERS flag, the attacker sends several CONTINUATION frames. Each CONTINUATION frame indicates that additional header data are yet to be obtained.
- For each received CONTINUATION frame, the server allocates additional memory and processing resources to handle the incoming header data. The server remained in a state of anticipation and waited for the header sequence to be completed.
- As CONTINUATION frames increase, the server memory and CPU resources become overwhelmed, leading to resource exhaustion.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

- Eventually, the Apache server exhausts its memory or processing capacity, causing it to slow down, crash, or become unresponsive.

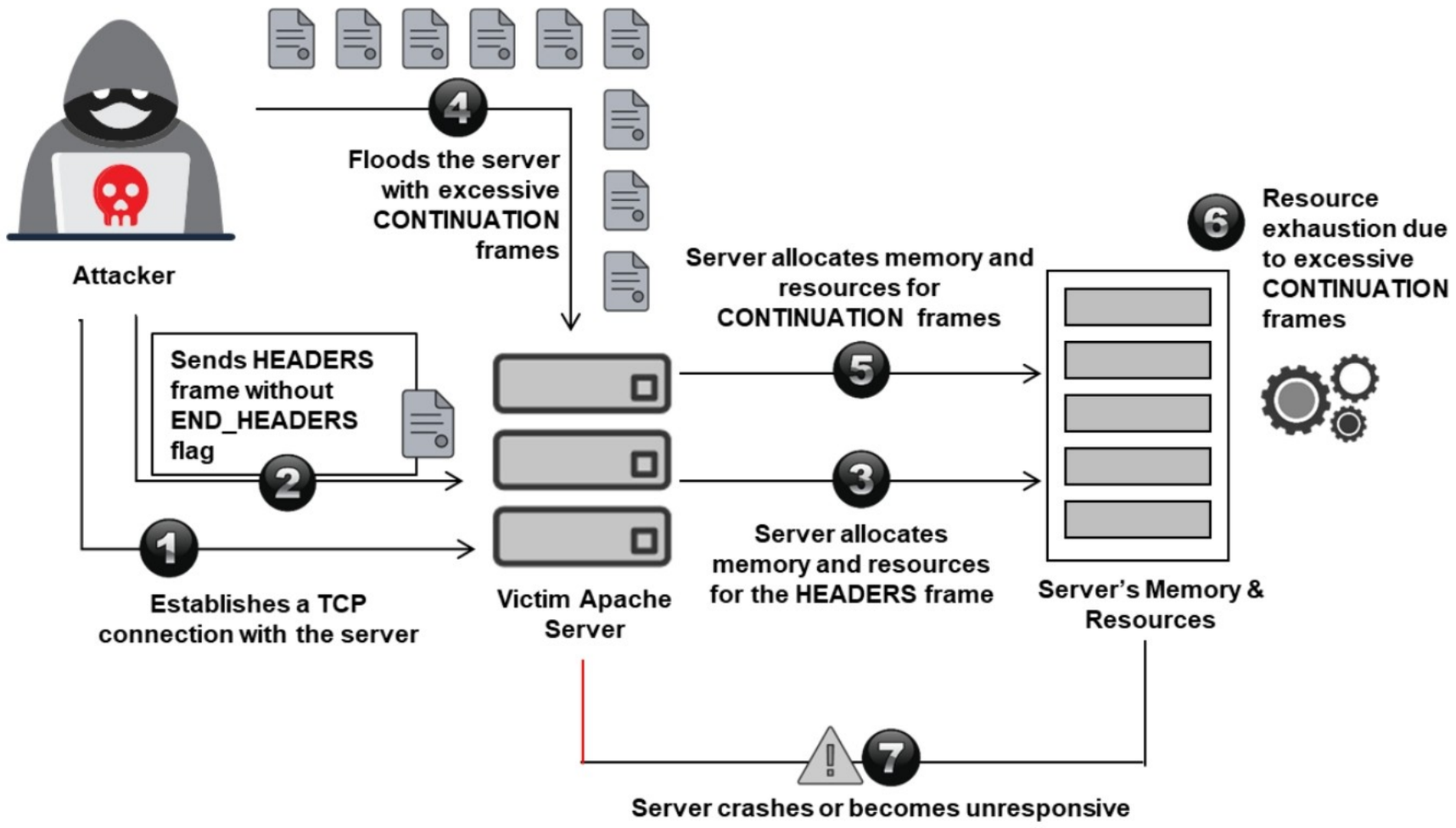
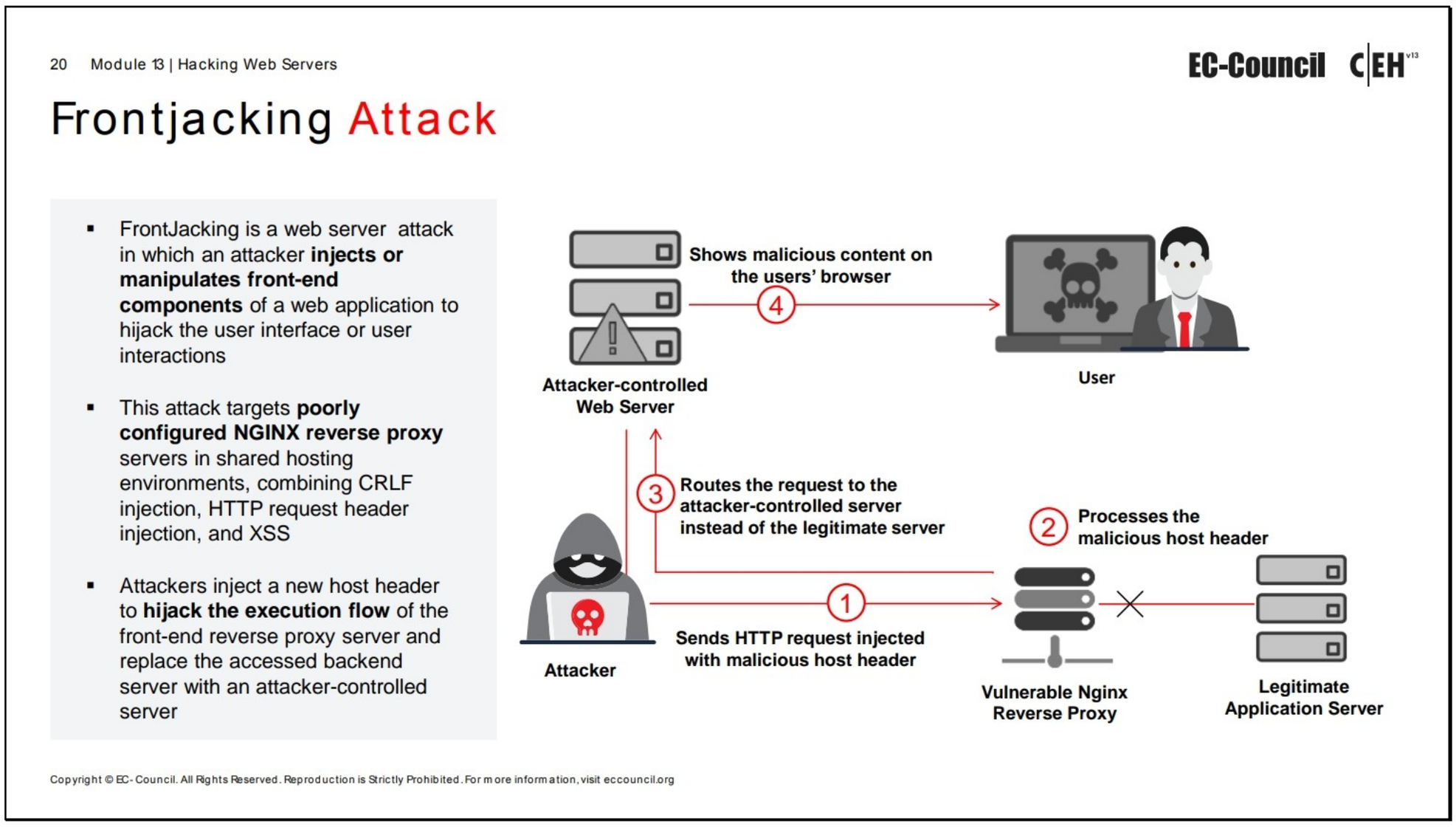


Figure 13.23: Illustration of HTTP/2 Continuation flood attack

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.



Frontjacking Attack

Front jacking is a type of web server attack in which an attacker injects or manipulates the front-end components of a web application, such as scripts or HTML elements, to hijack a user interface or user interactions. This attack often targets poorly configured Nginx reverse proxy servers in shared hosting environments by combining CRLF injection, HTTP request header injection, and XSS.

Attackers exploit flaws in the target reverse proxy configuration, such as improper sanitization of `$uri` and `$document_uri` variables, to inject a new host header. This hijacks the execution flow of the front-end reverse proxy server and consequently replaces the accessed backend server with an attacker-controlled server. This allows attackers to display malicious content, redirect users to fake websites, execute reflected XSS and phishing payloads, and inject harmful scripts.

How a Frontjacking Attack Works

- The attacker creates an HTTP request containing CRLF characters in the URI to inject a malicious host header and sends the request to the vulnerable reverse proxy server.
- The vulnerable reverse proxy accepts a request containing the malicious host header injected via the CRLF injection.
- Once the reverse proxy processes the injected host header, it routes the request to the attacker-controlled server instead of the legitimate backend server.
- The attacker-controlled server responds with malicious content such as phishing pages, malware, or other harmful scripts.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

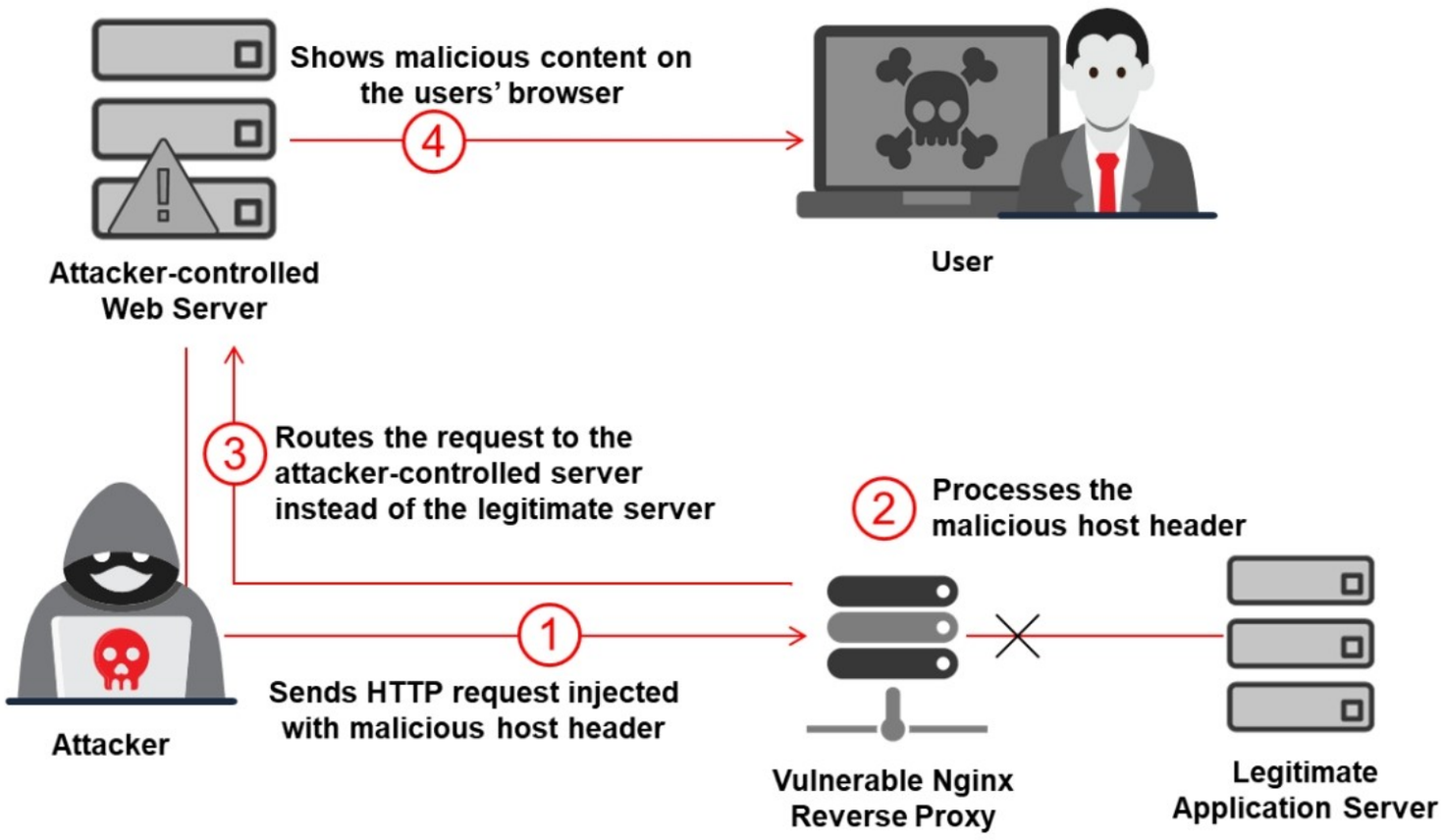
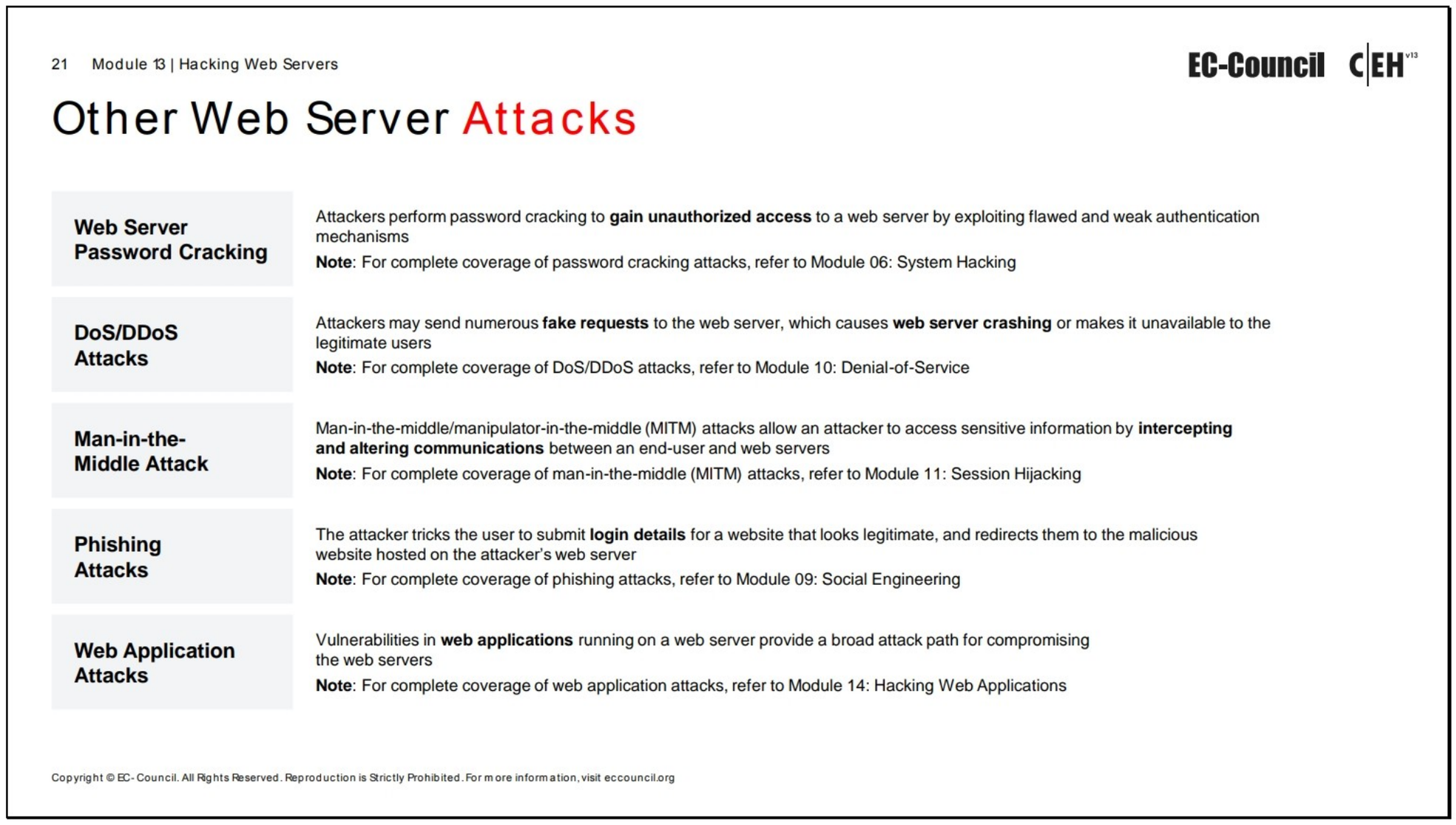


Figure 13.24: Illustration of frontjacking attack

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.



Other Web Server Attacks

Web Server Password Cracking

An attacker attempts to exploit weaknesses to hack well-chosen passwords. The most common passwords found are password, root, administrator, admin, demo, test, guest, qwerty, pet names, and so on. The attacker mainly targets the following through web server password cracking:

- SMTP and FTP servers
- Web shares
- SSH tunnels
- Web form authentication

Attackers use different methods such as social engineering, spoofing, phishing, a Trojan horse or virus, wiretapping, and keystroke logging to perform web server password cracking. In many hacking attempts, the attacker starts with password cracking to prove to the web server that they are a valid user.

Web Server Password Cracking Techniques

Password cracking is the most common method of gaining unauthorized access to a web server by exploiting flawed and weak authentication mechanisms. Once the password is cracked, an attacker can use the password to launch further attacks.

We present some details of various tools and techniques used by attackers to crack passwords. Attackers can use password cracking techniques to extract passwords from web servers, FTP servers, SMTP servers, and so on. They can crack passwords either manually or with automated

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

tools such as THC Hydra, and Ncrack. The following are some techniques attackers use to crack passwords:

- **Guessing**: This is the most common method of cracking passwords. In this method, the attacker guesses possible passwords either manually or by using automated tools provided with dictionaries. Most people tend to use their pets' names, loved ones' names, license plate numbers, dates of birth, or other weak passwords such as "QWERTY," "password," "admin," etc. so that they can remember them easily. The attacker exploits this human behavior to crack passwords.
- **Dictionary attack**: A dictionary attack uses a predefined file containing various combinations of words, and an automated program enters these words one at a time to check if any of them are the password. This might not be effective if the password includes special characters and symbols. If the password is a simple word, then it can be found quickly. Compared to a brute-force attack, a dictionary attack is less time-consuming.
- **Brute-force attack**: In the brute-force method, all possible character combinations are tested; for example, the test may include combinations of uppercase characters from A to Z, numbers from 0 to 9, and lowercase characters from a to z. This method is useful for identifying one-word or two-word passwords. If a password consists of uppercase and lowercase letters as well as special characters, it might take months or years to crack the password using a brute-force attack.
- **Hybrid attack**: A hybrid attack is more powerful than the above techniques because it uses both a dictionary attack and brute-force attack. It also uses symbols and numbers. Password cracking is easier with this method than with the above methods.

Note: For complete coverage of password cracking attacks, refer to Module 06: System Hacking.

DoS/DDoS Attacks

A DoS/DDoS attack involves flooding targets with copious fake requests so that the target stops functioning and becomes unavailable to legitimate users. By using a web server DoS/DDoS attack, an attacker attempts to take the web server down or make it unavailable to legitimate users. A web server DoS/DDoS attack often targets high-profile web servers such as bank servers, credit-card payment gateways, and even root name servers.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

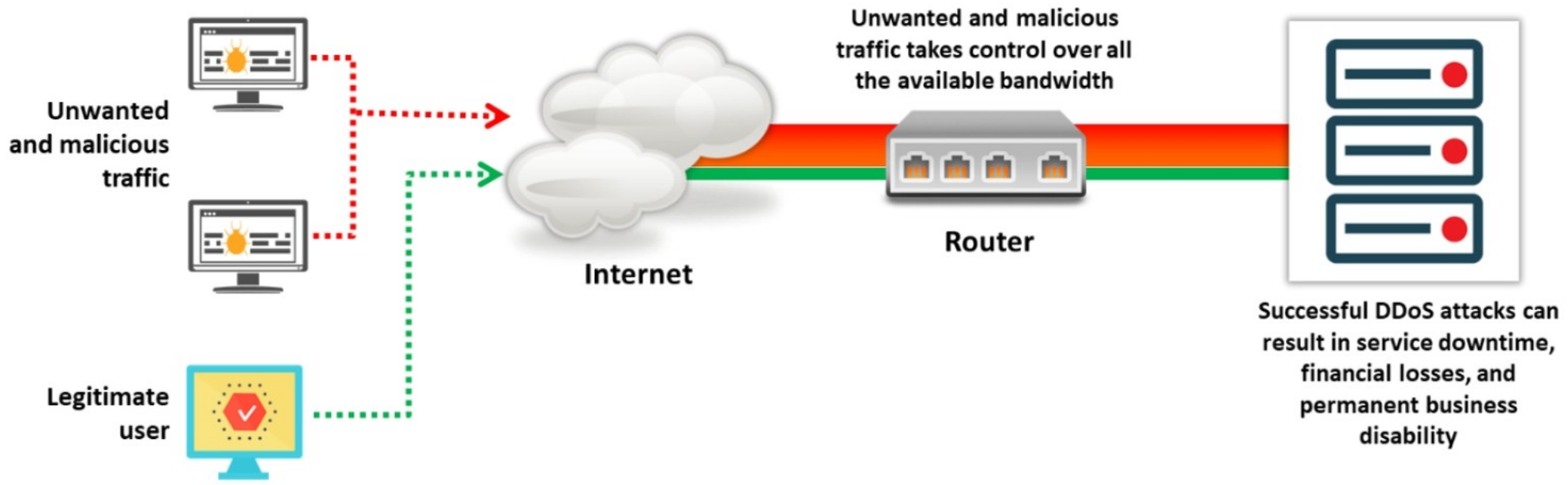


Figure 13.25: Web server DDoS attack

To crash a web server running an application, the attacker targets the following services to consume the web server's resources with fake requests:

- Network bandwidth
- Server memory
- Application exception handling mechanism
- CPU usage
- Hard-disk space
- Database space

Note: For complete coverage of DoS/DDoS attacks, refer to Module 10: Denial-of-Service.

Man-in-the-Middle Attack

Man-in-the-middle/manipulator-in-the-middle (MITM) attacks allow an attacker to access sensitive information by intercepting and altering communications between an end user and web servers. In an MITM attack or sniffing attack, an intruder intercepts or modifies the messages exchanged between the user and web server by eavesdropping or intruding into a connection. This allows an attacker to steal sensitive user information, such as online banking details, usernames, and passwords, transferred over the Internet to the web server. The attacker lures the victim to connect to the web server by pretending to be a proxy. If the victim believes and accepts the attacker's request, then all the communication between the user and web server passes through the attacker. In this manner, the attacker can steal sensitive user information.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

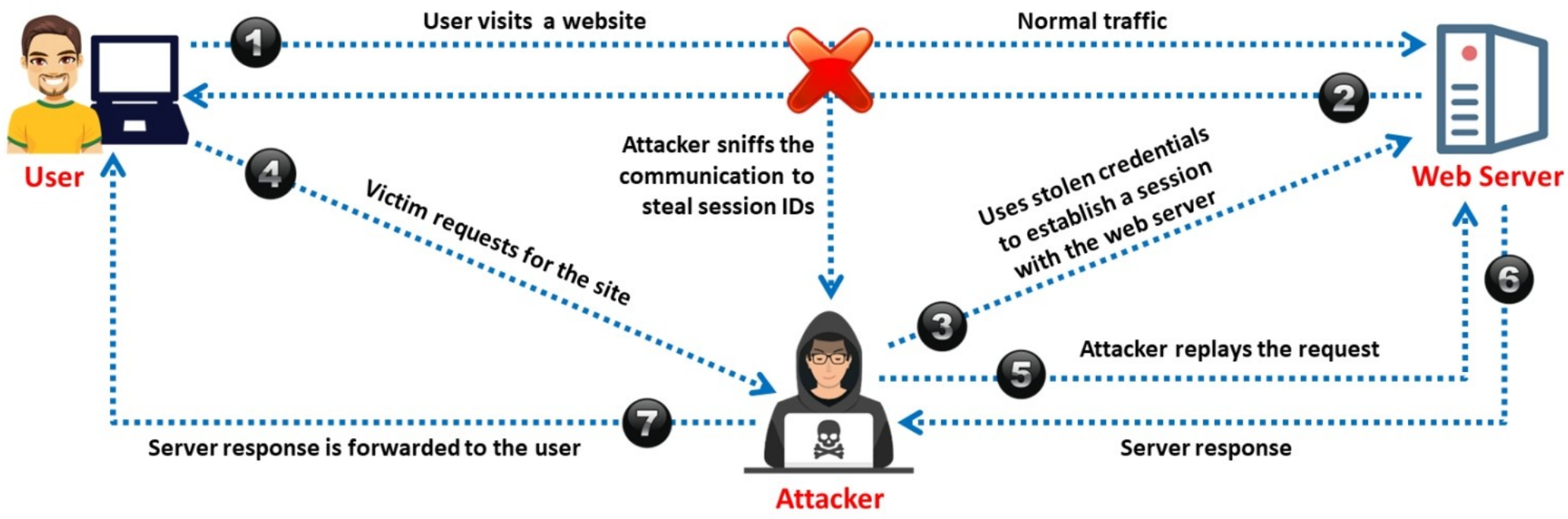


Figure 13.26: Man-in-the-middle/sniffing attack

Note: For complete coverage of man-in-the-middle (MITM) attacks, refer to Module 11: Session Hijacking.

Phishing Attacks

Attackers perform a phishing attack by sending an email containing a malicious link and tricking the user into clicking it. Clicking the link will redirect the user to a fake website that appears similar to the legitimate website. Attackers create such websites by hosting their address on web servers. When a victim clicks on the malicious link while believing the link to be a legitimate website address, the victim is redirected to the malicious website hosted on the attacker's server. The website prompts the user to enter sensitive information, such as usernames, passwords, bank account details, and social security numbers, and divulges the data to the attacker. Later, the attacker may be able to establish a session with the legitimate website by using the victim's stolen credentials to perform malicious operations on the target legitimate website.

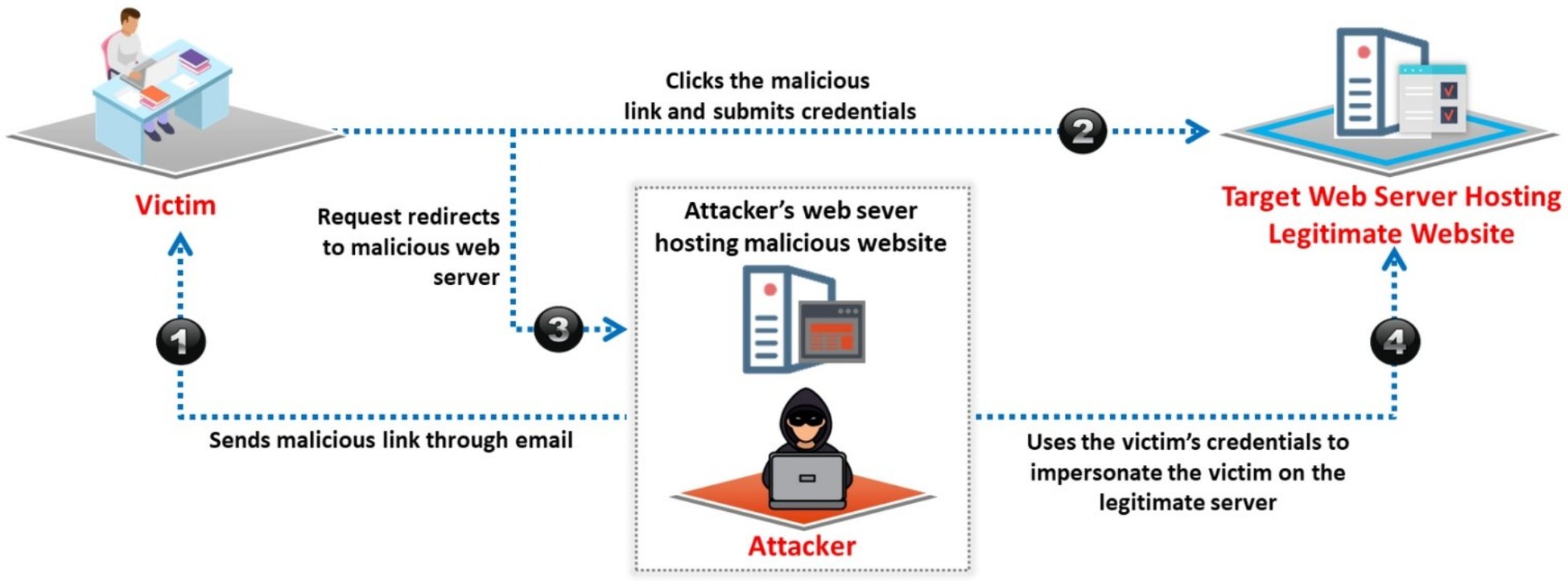


Figure 13.27: Phishing attacks

Note: For complete coverage of phishing attacks, refer to Module 09: Social Engineering.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Web Application Attacks

Even if web servers are configured securely or are secured using network security measures such as firewalls, a poorly coded web application deployed on the web server may provide a path for an attacker to compromise the web server's security. If web developers do not adopt secure coding practices while developing web applications, attackers may be able to exploit vulnerabilities and compromise web applications and web server security. An attacker can perform different types of attacks on vulnerable web applications to breach web server security.

- **Server-Side Request Forgery (SSRF) Attack:** Attackers exploit server-side request forgery (SSRF) vulnerabilities, which evolve from the unsafe use of functions in an application, in public web servers to send crafted requests to the internal or backend servers. The backend server believes that the request is made by the web server because they are on the same network and responds with the data stored in it.
- **Parameter/Form Tampering**: In this type of tampering attack, the attacker manipulates the parameters exchanged between the client and server to modify application data, such as user credentials and permissions as well as price and quantity of products.
- **Cookie Tampering**: Cookie-tampering attacks occur when a cookie is sent from the client side to the server. Different types of tools help in modifying persistent and non-persistent cookies.
- **Unvalidated Input and File Injection Attacks**: Unvalidated input and file-injection attacks are performed by supplying an unvalidated input or by injecting files into a web application.
- **Session Hijacking**: Session hijacking is an attack in which the attacker exploits, steals, predicts, and negotiates the real valid web session's control mechanism to access the authenticated parts of a web application.
- **SQL Injection Attacks**: SQL injection exploits the security vulnerability of a database for attacks. The attacker injects malicious code into the strings, which are later passed on to the SQL server for execution.
- **Directory Traversal**: Directory traversal is the exploitation of HTTP through which attackers can access restricted directories and execute commands outside of the web server's root directory by manipulating a URL.
- **Denial-of-Service (DoS) Attack**: A DoS attack is intended to terminate the operations of a website or server to make it unavailable for access by its intended users.
- **Cross-Site Scripting (XSS) Attacks**: In this method, an attacker injects HTML tags or scripts into a target website.
- **Buffer Overflow Attacks**: The design of most web applications helps them in sustaining some amount of data. If that amount exceeds the storage space available, the application may crash or exhibit some other vulnerable behavior. An attacker uses this

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

advantage and floods the application with an excess amount of data, causing a buffer overflow attack.

- **Cross-Site Request Forgery (CSRF) Attack**: An attacker exploits the trust of an authenticated user to pass malicious code or commands to the web server.
- **Command Injection Attacks**: In this type of attack, a hacker alters the content of the web page by using HTML code and by identifying the form fields that lack valid constraints.
- **Source Code Disclosure**: Source-code disclosure is a result of typographical errors in scripts or misconfiguration, such as failure to grant executable permissions to a script or directory. Source-code disclosure can occasionally allow attackers to access sensitive information about database credentials and secret keys to compromise the web server.

Note: For complete coverage of web application attacks, refer to Module 14: Hacking Web Applications.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Objective 03

Explain Web Server Attack Methodology

Copyright © EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit eccouncil.org

Web Server Attack Methodology

1. Information Gathering
2. Web Server Footprinting
3. Website Mirroring
4. Vulnerability Scanning
5. Session Hijacking
6. Web Server Passwords Hacking

Copyright © EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit eccouncil.org

Web Server Attack Methodology

The previous section described attacks that can be performed to compromise a web server's security. This section explains how the attacker proceeds toward performing a successful attack on a web server. It also introduces web server hacking tools that attackers may use. These tools extract critical information during the hacking process.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

A web server attack typically involves preplanned activities called an attack methodology that an attacker follows to reach the goal of breaching the target web server's security. Attackers hack a web server in multiple stages. At each stage, the attacker attempts to gather information about loopholes and to gain unauthorized access to the web server. The following are the various stages of the attack methodology for web servers.

- **Information Gathering**

  Every attacker tries to collect as much information as possible about the target web server. The attacker gathers the information and then analyzes it to find lapses in the current security mechanisms of the web server.

- **Web Server Footprinting**

  The purpose of footprinting is to gather information about the security aspects of a web server with the help of tools or footprinting techniques. Through footprinting, attackers can determine the web server's remote access capabilities, its ports and services, and other aspects of its security.

- **Website Mirroring**

  Website mirroring is a method of copying a website and its content onto another server for offline browsing. With a mirrored website, an attacker can view the detailed structure of the website.

- **Vulnerability Scanning**

  Vulnerability scanning is a method of finding the vulnerabilities and misconfigurations of a web server. Attackers scan for vulnerabilities with the help of automated tools known as vulnerability scanners.

- **Session Hijacking**

  Attackers can perform session hijacking after identifying the current session of the client. The attacker takes complete control over the user session through session hijacking.

- **Web Server Passwords Hacking**

  Attackers use password-cracking methods such as brute-force attacks, hybrid attacks, and dictionary attacks to crack the web server's password.

Information Gathering

Information gathering is the first and one of the most important steps toward hacking a target web server. In this step, an attacker collects as much information as possible about the target server by using various tools and techniques. The information obtained from this step helps the attacker in assessing the security posture of the web server. Attackers may search the Internet, newsgroups, bulletin boards, and so on for gathering information about the target organization. Attackers can use tools such as who.is and Whois Lookup to extract information such as the target's domain name, IP address, and autonomous system number.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

- **who.is**

  Source: *https://who.is*

  who.is is designed perform a variety of whois lookup functions. It lets the user perform a domain whois search, whois IP lookup, and whois database search for relevant information on domain registration and availability.

Figure 13.28: Screenshot of who.is

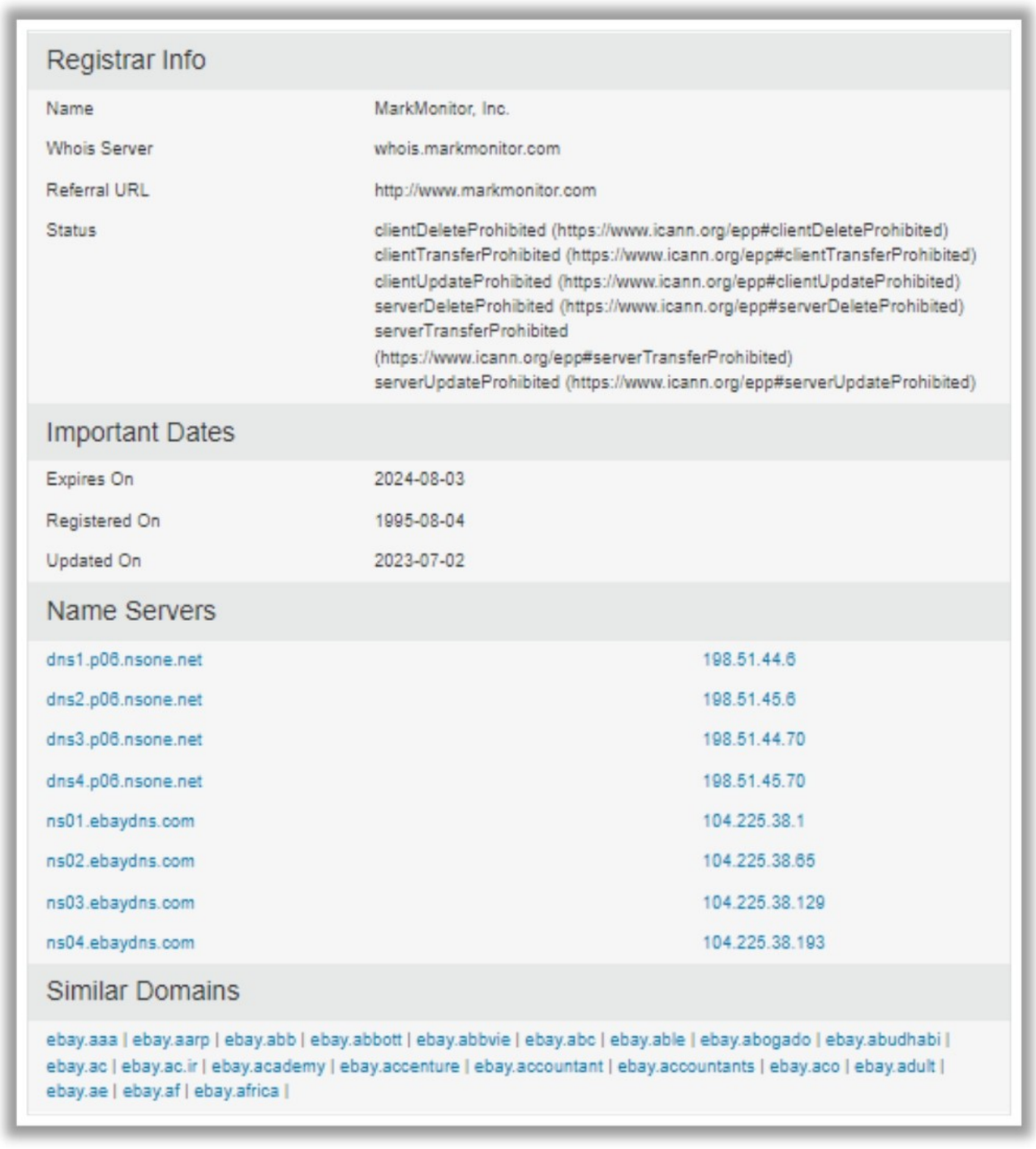


Figure 13.29: Screenshot displaying a who.is online search result

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

The following are some additional information-gathering tools:

- Whois Lookup (*https://whois.domaintools.com*)
- Whois (*https://www.whois.com*)
- Domain Dossier (*https://centralops.net*)
- Subdomain Finder (*https://pentest-tools.com*)

Note: For complete coverage of information-gathering techniques, refer to Module 02: Footprinting and Reconnaissance.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Information Gathering from Robots.txt File

- The robots.txt file contains the **list of the web server directories and files** that the web site owner wants to hide from web crawlers
- An attacker can simply request the Robots.txt file from the URL and retrieve sensitive information such as the **root directory structure** and **content management system information** about the target website
- An attacker can also download the Robots.txt file of a target website using the Wget tool

Copyright © EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit eccouncil.org

Information Gathering from Robots.txt File

A website owner creates a robots.txt file to list the files or directories a web crawler should index for providing search results. Poorly written robots.txt files can cause the complete indexing of website files and directories. If confidential files and directories are indexed, an attacker may easily obtain information such as passwords, email addresses, hidden links, and membership areas.

If the owner of the target website writes the robots.txt file without allowing the indexing of restricted pages for providing search results, an attacker can still view the robots.txt file of the site to discover restricted files and then view them to gather information.

An attacker types URL/robots.txt in the address bar of a browser to view the target website's robots.txt file. An attacker can also download the robots.txt file of a target website using the Wget tool.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

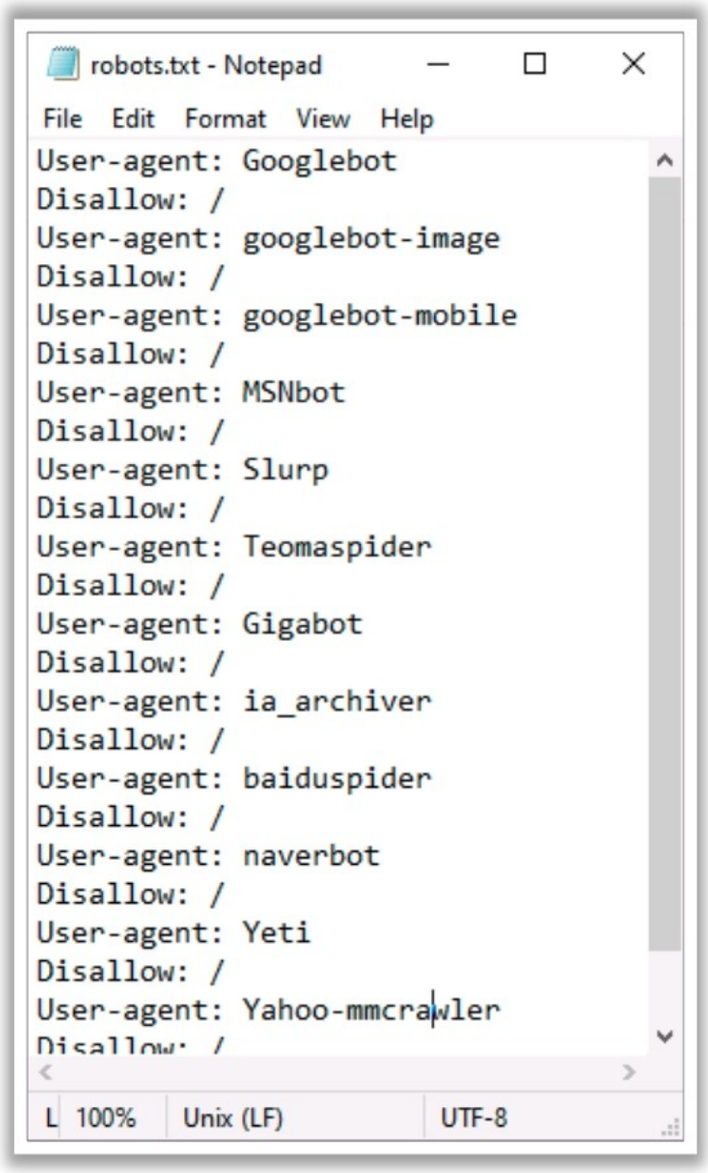


Figure 13.30: Screenshot displaying a robots.txt file

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Web Server Footprinting/Banner Grabbing

- Gather **valuable system-level data** such as account details, operating system, software versions, server names, and database schema details

Netcat

- This utility **reads and writes data across network connections**, using the TCP/IP protocol

  `# nc –vv www.microsoft.com 80` – press **[Enter]**

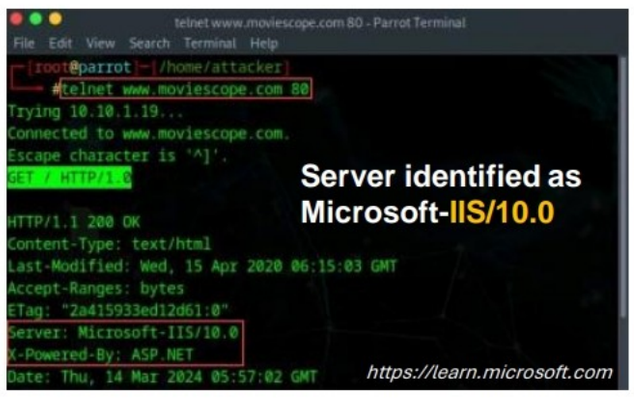
  `GET / HTTP/1.0` - Press **[Enter] twice**

Telnet

- This technique probes **HTTP servers** to determine the **Server field** in the HTTP response header

  `telnet www.moviescope.com 80` – press **[Enter]**

  `GET / HTTP/1.0` - Press **[Enter] twice**



Copyright © EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit eccouncil.org

Web Server Footprinting/Banner Grabbing

By performing web server footprinting, an attacker can gather valuable system-level data such as account details, OSs, software versions, server names, and database schema details. The Telnet utility can be used to footprint a web server and gather information such as server name, server type, OSs, and running applications running. Furthermore, footprinting tools such as httprecon, Uniscan, and Netcraft can be used to perform web server footprinting. These footprinting tools can extract information from the target server. Here, we examine the features and types of information these tools can collect from the target server.

Web Server Footprinting Tools

- **Netcat**

  Source: *https://netcat.sourceforge.net*

  Netcat is a networking utility that reads and writes data across network connections by using the TCP/IP protocol. It is a reliable "back-end" tool used directly or driven by other programs and scripts. It is also a network debugging and exploration tool.

  The following are the commands used to perform banner grabbing for www.moviescope.com as an example to gather information such as server type and version.

  - `# nc –vv www.moviescope.com 80` – press [**Enter**]
  - `GET / HTTP/1.0` - press [**Enter**] twice

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

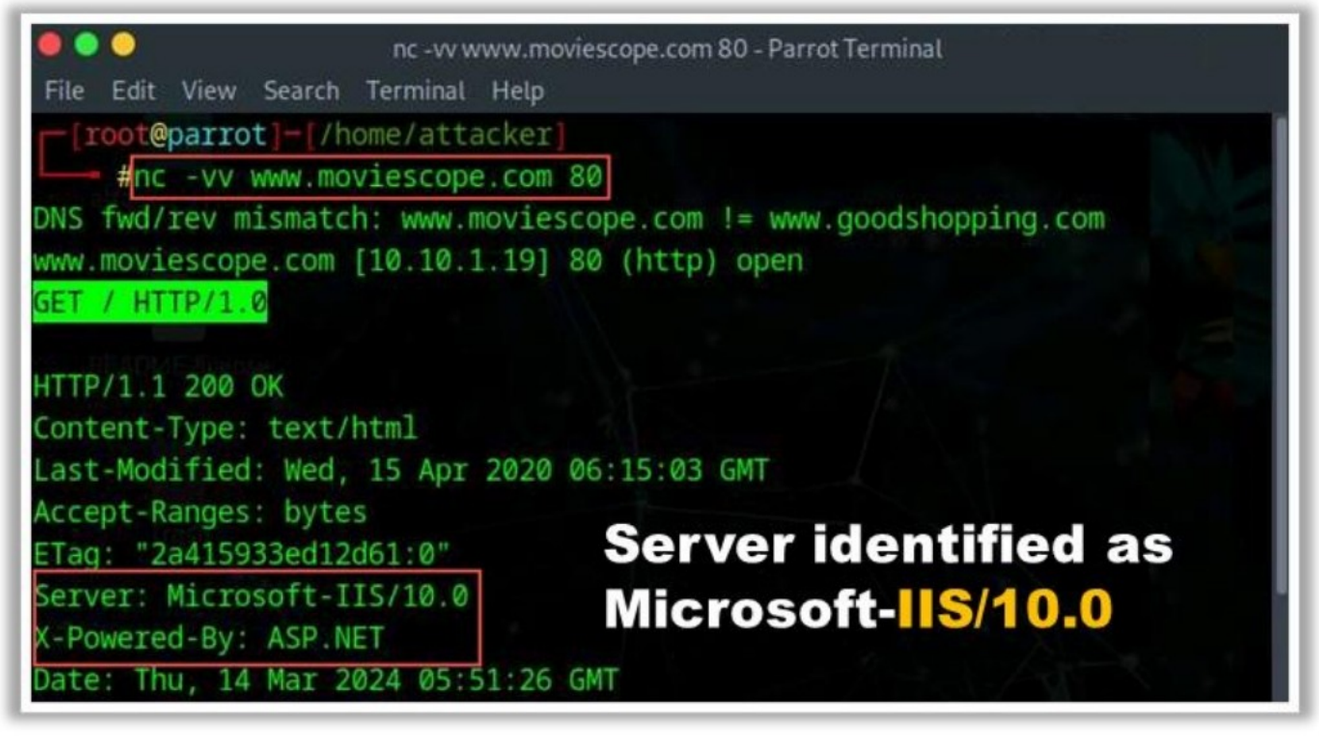


Figure 13.31: Netcat output

- **Telnet**

  Source: *https://learn.microsoft.com*

  Telnet is a client–server network protocol that is widely used on the Internet or LANs. It provides login sessions for a user on the Internet. A single terminal attached to another computer emulates the session by using Telnet. The primary security issues with Telnet are the following.

  - It does not encrypt data sent through the connection.
  - It lacks an authentication scheme.

  Telnet enables an attacker to perform a banner-grabbing attack. It probes HTTP servers to determine the server field in the HTTP response header.

  For instance, the following procedure is utilized to enumerate a host running on HTTP (TCP 80).

  - Request Telnet to connect to a host on a specific port with the command **`# telnet www.moviescope.com 80`** and press **Enter**. A blank screen appears.
  - Type **`GET / HTTP/1.0`** and press **Enter** twice.

  The HTTP server responds with the information shown in the screenshot.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

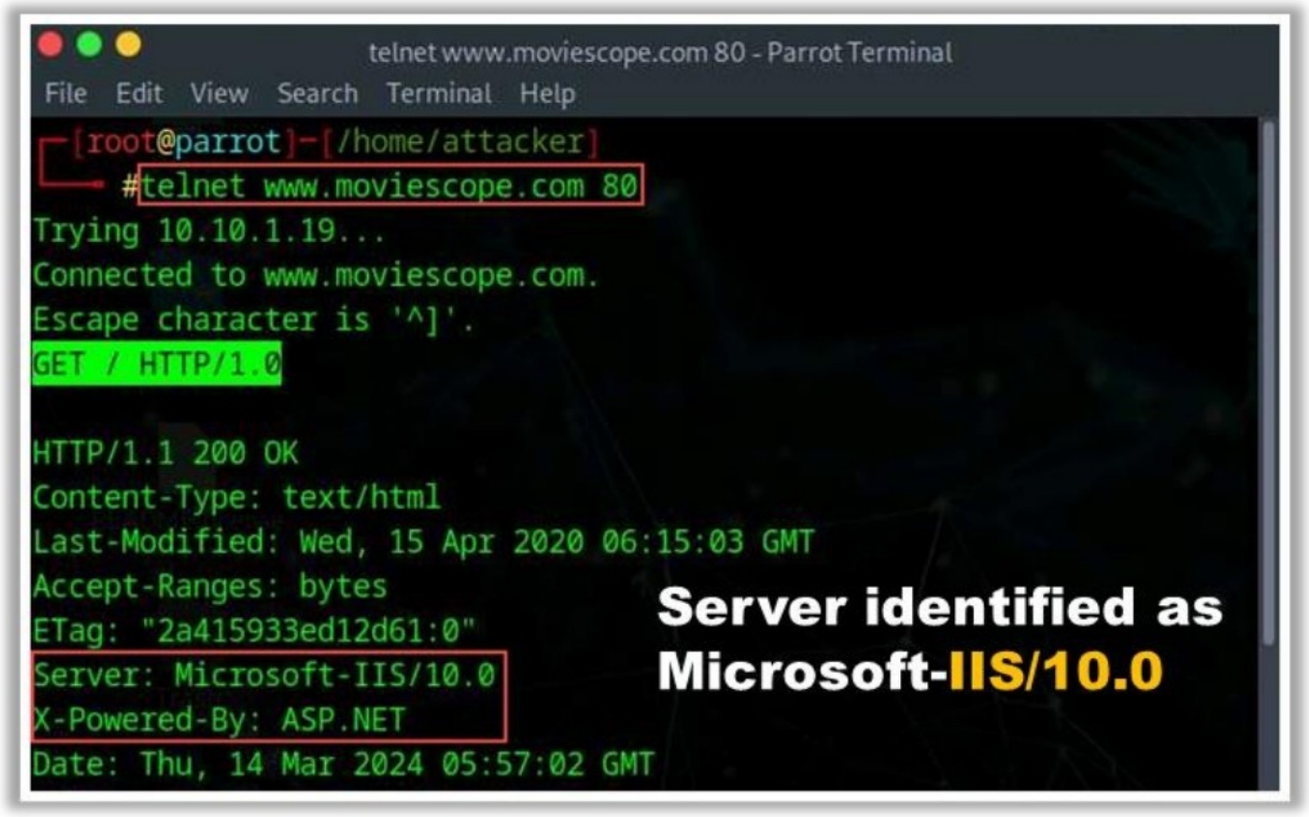


Figure 13.32: Telnet output

- **httprecon**

  Source: *https://www.computec.ch*

  httprecon is a tool for advanced web server fingerprinting. This tool performs banner-grabbing attacks, status code enumeration, and header ordering analysis on the target web server and provides accurate web server fingerprinting information.

  httprecon performs the following header analysis test cases on the target web server:

  - A legitimate GET request for an existing resource
  - An exceedingly long GET request (a Uniform Resource Identifier (URI) of >1024 bytes)
  - A common GET request for a non-existing resource
  - A common HEAD request for an existing resource
  - Enumeration with OPTIONS, which is allowed
  - The HTTP method DELETE, which is usually not permitted
  - The HTTP method TEST, which is not defined
  - The protocol version HTTP/9.8, which does not exist
  - A GET request including attack patterns (e.g., : ../ and %%)

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

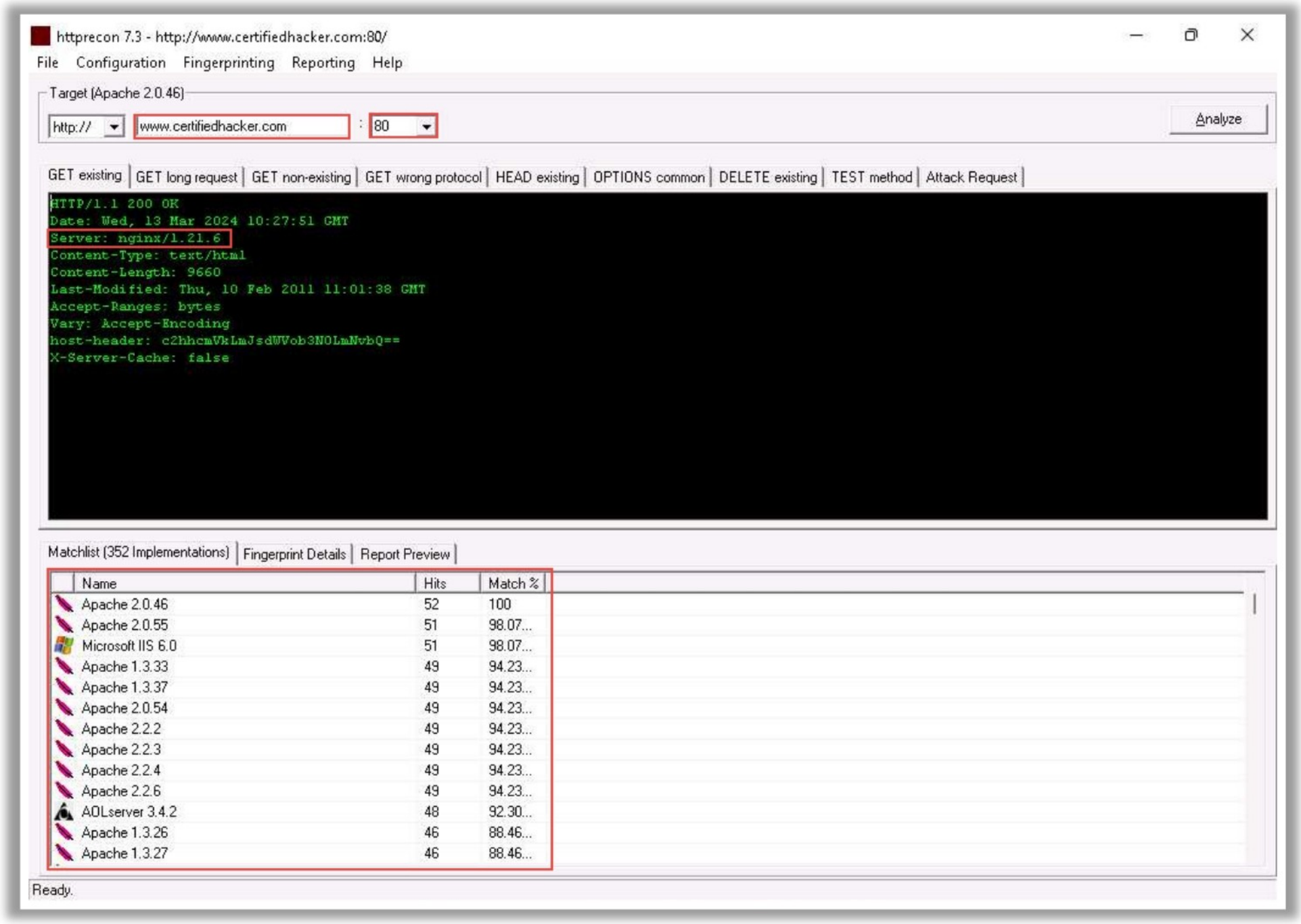


Figure 13.33: Screenshot of httprecon

- **Uniscan**

  Source: *https://sourceforge.net*

  Uniscan is a versatile server fingerprinting tool that not only performs simple commands such as ping, traceroute, and nslookup, but also conducts static, dynamic, and stress checks on web servers. In addition to scanning websites, Uniscan performs automated Bing and Google searches for specific IPs. It compiles all this data into a comprehensive report file.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

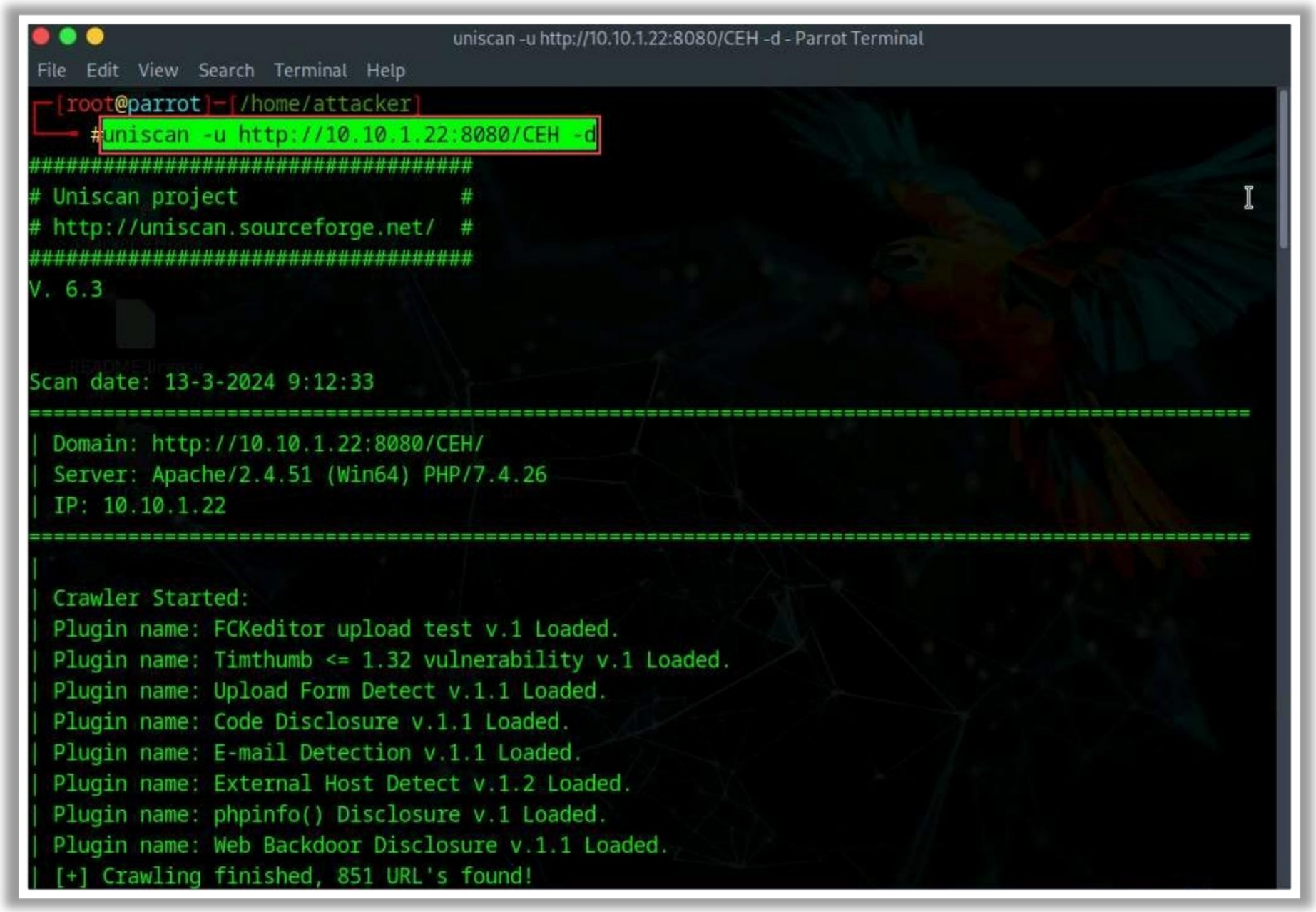
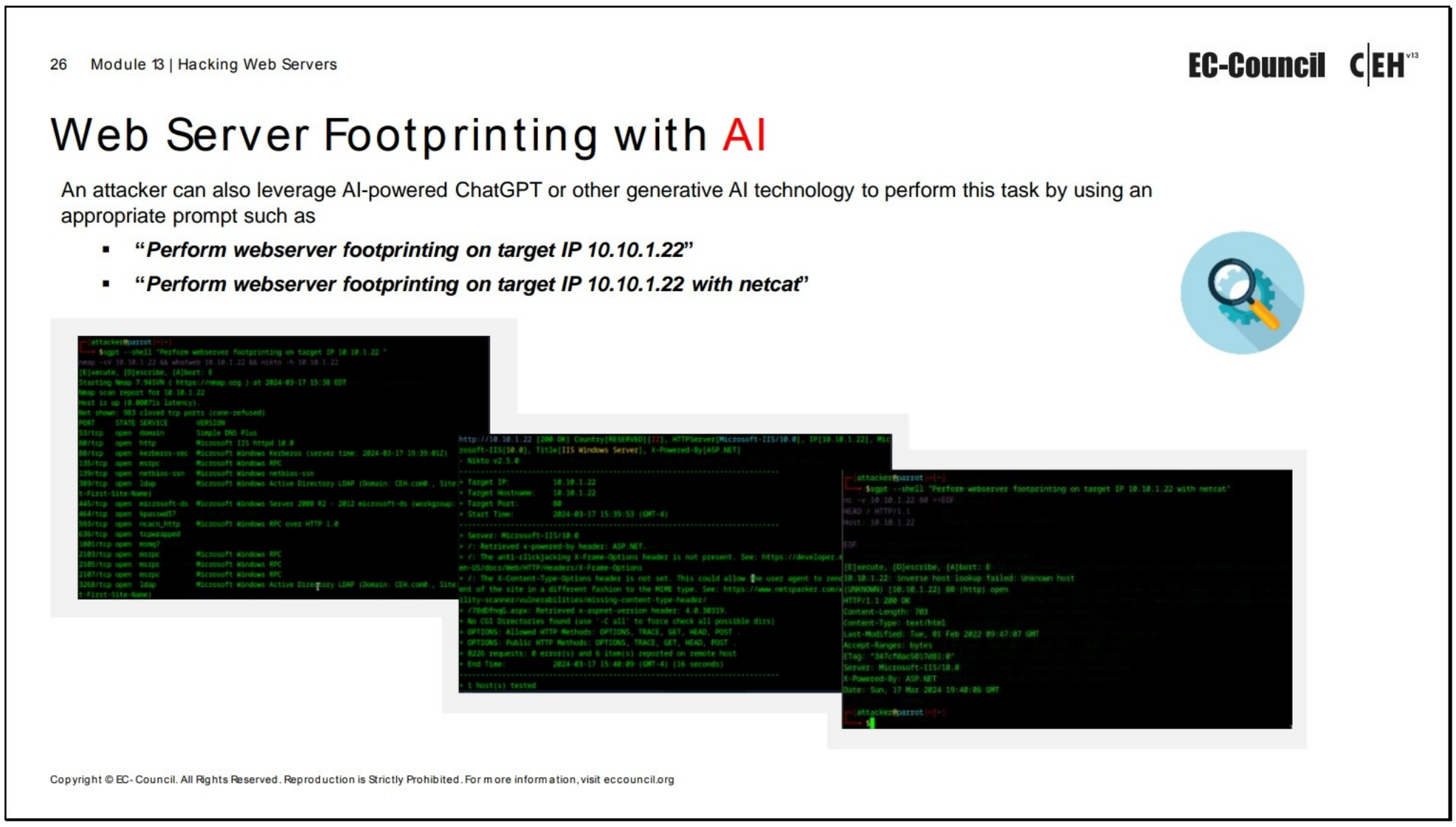


Figure 13.34: Screenshot of Uniscan

The following are some additional footprinting tools:

- Netcraft (*https://www.netcraft.com*)
- ID Serve (*https://www.grc.com*)
- Nmap (*https://nmap.org*)
- Ghost Eye (*https://github.com*)
- Skipfish (https://code.google.com)

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.



Web Server Footprinting with AI

Attackers can leverage AI-powered technologies to enhance and automate hacking. With the aid of AI, attackers can effortlessly perform web server footprinting on the target servers.

For example,

An attacker can use ChatGPT to perform this task by using an appropriate prompt such as:

- **"Perform webserver footprinting on target IP 10.10.1.22"**

```
┌──[attacker@parrot]─[~]
└─── $sgpt --shell "Perform webserver footprinting on target IP 10.10.1.22 "
nmap -sV 10.10.1.22 && whatweb 10.10.1.22 && nikto -h 10.10.1.22
[E]xecute, [D]escribe, [A]bort: E
Starting Nmap 7.94SVN ( https://nmap.org ) at 2024-03-17 15:38 EDT
Nmap scan report for 10.10.1.22
Host is up (0.00071s latency).
Not shown: 983 closed tcp ports (conn-refused)
PORT     STATE SERVICE       VERSION
53/tcp   open  domain        Simple DNS Plus
80/tcp   open  http          Microsoft IIS httpd 10.0
88/tcp   open  kerberos-sec  Microsoft Windows Kerberos (server time: 2024-03-17 19:39:01Z)
135/tcp  open  msrpc         Microsoft Windows RPC
139/tcp  open  netbios-ssn   Microsoft Windows netbios-ssn
389/tcp  open  ldap          Microsoft Windows Active Directory LDAP (Domain: CEH.com0., Site: Defaul
t-First-Site-Name)
445/tcp  open  microsoft-ds  Microsoft Windows Server 2008 R2 - 2012 microsoft-ds (workgroup: CEH)
464/tcp  open  kpasswd5?
593/tcp  open  ncacn_http    Microsoft Windows RPC over HTTP 1.0
636/tcp  open  tcpwrapped
1801/tcp open  msmq?
2103/tcp open  msrpc         Microsoft Windows RPC
2105/tcp open  msrpc         Microsoft Windows RPC
2107/tcp open  msrpc         Microsoft Windows RPC
3268/tcp open  ldap          Microsoft Windows Active Directory LDAP (Domain: CEH.com0., Site: Defaul
t-First-Site-Name)
```

Figure 13.35: Screenshot showing web server footprinting

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

```
http://10.10.1.22 [200 OK] Country[RESERVED][ZZ], HTTPServer[Microsoft-IIS/10.0], IP[10.10.1.22], Mic
rosoft-IIS[10.0], Title[IIS Windows Server], X-Powered-By[ASP.NET]
- Nikto v2.5.0
---------------------------------------------------------------------------
+ Target IP:          10.10.1.22
+ Target Hostname:    10.10.1.22
+ Target Port:        80
+ Start Time:         2024-03-17 15:39:53 (GMT-4)
---------------------------------------------------------------------------
+ Server: Microsoft-IIS/10.0
+ /: Retrieved x-powered-by header: ASP.NET.
+ /: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.org/
en-US/docs/Web/HTTP/Headers/X-Frame-Options
+ /: The X-Content-Type-Options header is not set. This could allow the user agent to render the cont
ent of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerab
ility-scanner/vulnerabilities/missing-content-type-header/
+ /78dDfnqG.aspx: Retrieved x-aspnet-version header: 4.0.30319.
+ No CGI Directories found (use '-C all' to force check all possible dirs)
+ OPTIONS: Allowed HTTP Methods: OPTIONS, TRACE, GET, HEAD, POST .
+ OPTIONS: Public HTTP Methods: OPTIONS, TRACE, GET, HEAD, POST .
+ 8226 requests: 0 error(s) and 6 item(s) reported on remote host
+ End Time:           2024-03-17 15:40:09 (GMT-4) (16 seconds)
---------------------------------------------------------------------------
+ 1 host(s) tested
```

Figure 13.36: Screenshot showing web server footprinting

The output of the prompt results in the following command.

`nmap -SV 10.10.1.22 && whatweb 10.10.1.22 && nikto -h 10.10.1.22`

This is a compound command consisting of three different network scanning and reconnaissance tools: Nmap, WhatWeb, and Nikto:

1. **Nmap:**
   - **`-sV`:** This option enables version detection, which attempts to determine the version of services running on open ports.
   - **`10.10.1.22`:** Specifies the target IP address to scan.

   Therefore, the Nmap command scans the target IP address "10.10.1.22" to detect open ports and determine the versions of the services running on those ports.
2. **WhatWeb:**
   - **`10.10.1.22`:** Specifies the target IP address to scan.

   WhatWeb is a web scanner that identifies websites built with. By providing the target IP address "10.10.1.22", WhatWeb will attempt to gather information about the web server and technologies used on the target website.
3. **Nikto:**
   - **`-h 10.10.1.22`:** Specifies the target host to scan.

   Nikto is a web server scanner that performs comprehensive tests on web servers for multiple items, including dangerous files/CGIs, outdated server software, and other potential security issues. By providing the target host IP address "10.10.1.22", Nikto will scan the web server on that IP address for vulnerabilities and misconfigurations.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Overall, this compound command combines three different tools to gather information about the target IP address from both the network and web server perspectives.

Web Server Footprinting using Netcat with AI

Attackers can leverage AI-powered technologies to enhance and automate hacking. With the aid of AI, attackers can effortlessly perform footprinting on the target Web server with the help of the Netcat tool.

For example,

An attacker can use ChatGPT to perform this task by using an appropriate prompt such as:

"Perform webserver footprinting on target IP 10.10.1.22 with netcat"

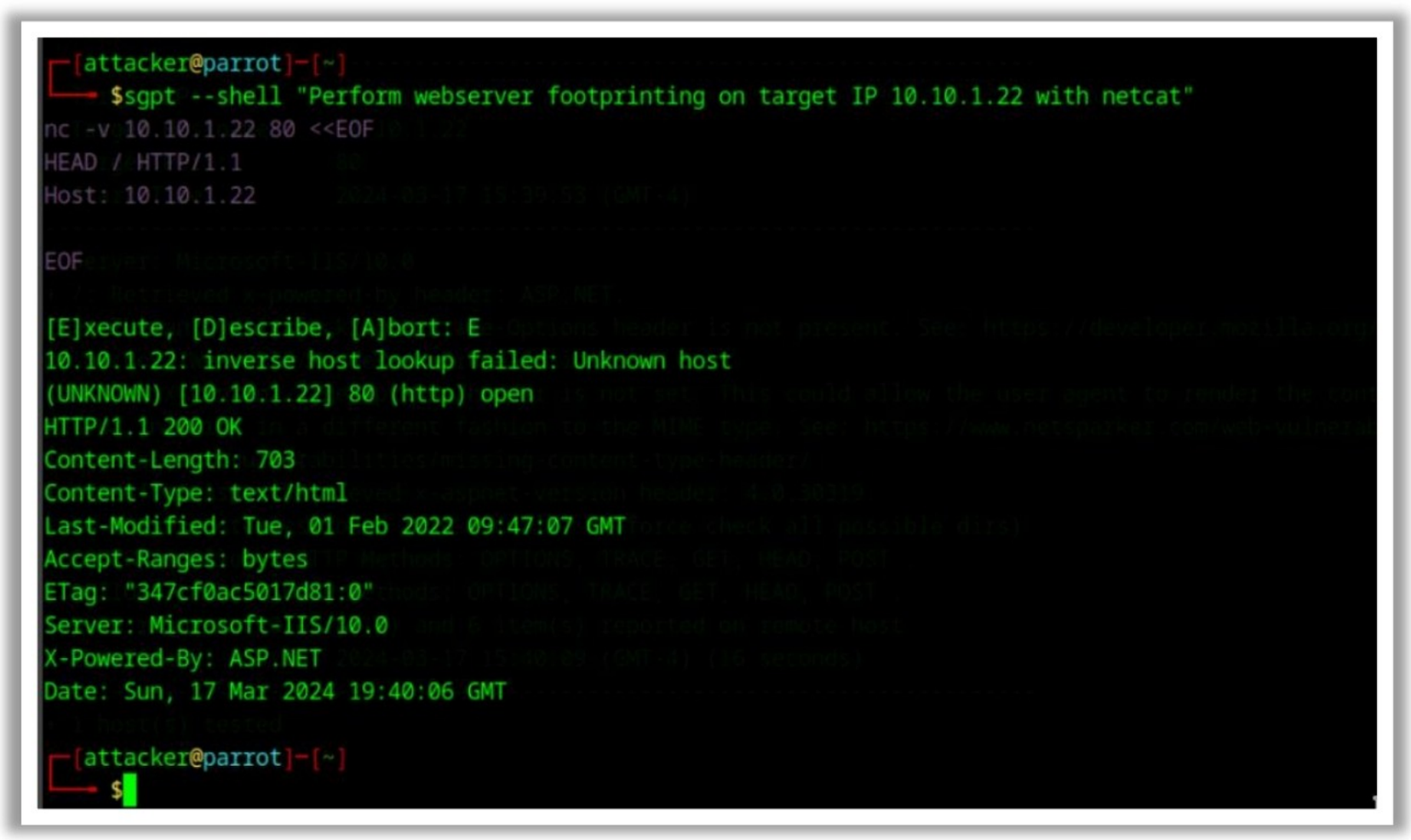


Figure 13.37: Webserver footprinting on target IP 10.10.1.22 with netcat

The command you provided is using `nc` (netcat) to establish a connection to the target IP address "10.10.1.22" on port 80, and then sending an HTTP request using the `HEAD` method.

```
nc -v 10.10.1.22 80 <<EOF
HEAD/HTTP/1.1
Host: 10.10.1.22
EOF
```

- **`nc -v 10.10.1.22 80`:** This initiates a connection to the target IP address "10.10.1.22" on port 80. The `-v` option makes `nc` operate in verbose mode, providing more information about the connection.
- **`<<EOF`:** This is a heredoc syntax in Bash, indicating the start of a block of text to be sent to the standard input of `nc. ' Everything between `<<EOF` and the next occurrence of `EOF` will be sent over the established connection.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

- **`HEAD/HTTP/1.1`:** This is the HTTP request line, indicating the HTTP method (`HEAD`), protocol version (`HTTP/1.1`), and the path of the resource being requested (which should typically follow the HTTP method, not precede it). This line contains syntactic errors. It should be `HEAD / HTTP/1.1` instead of `HEAD/HTTP/1.1`.
- **`Host: 10.10.1.22`:** This is a header indicating the hostname of the server to which the client is attempting to connect. In this case, it is the IP address "10.10.1.22".
- **`EOF`:** This signals the end of the heredoc block.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

IIS Information Gathering using Shodan

Attackers can use tools such as Shodan to gather information about IIS servers, enhancing their ability to perform targeted and efficient attacks

Shodan Search Filters for Information Gathering

- Use the following filter to identify the IIS servers with **SSL certificates** issued to "Company Inc.":

  `Ssl:"Company Inc." http.title:"IIS"`

- Use the following filter to locate IIS servers with SSL certificates where the **common name** (CN) is "**company.in**":

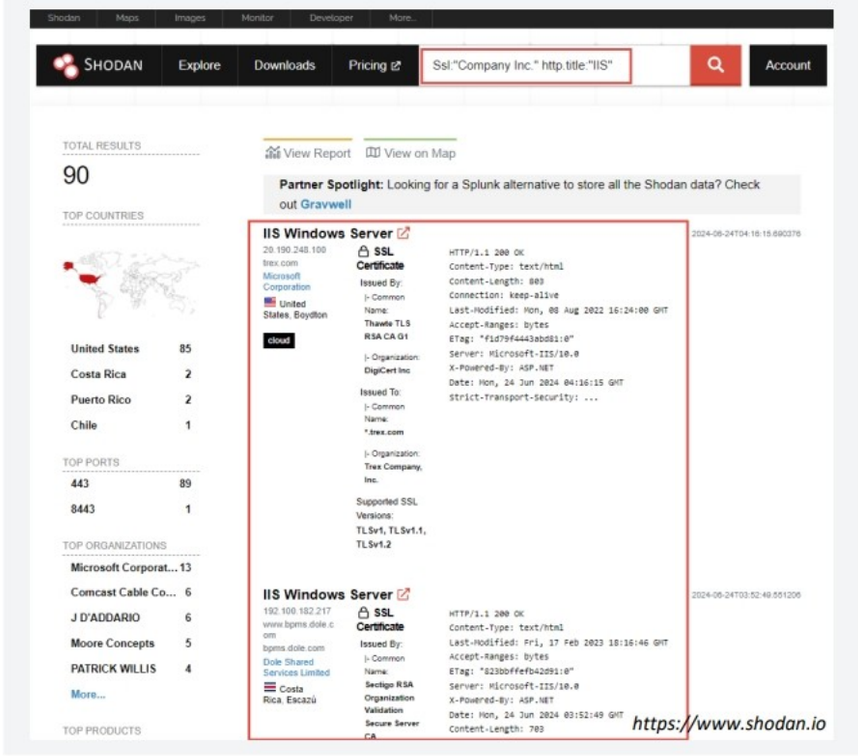
  `Ssl.cert.subject.CN:"company.in" http.title:"IIS"`

- Use the following filter to find **IIS servers in the US**:

  `http.title:"IIS Windows Server" country:"US"`

- Use the following filter to locate IIS7 servers running on **port 80**:

  `http.title:"IIS7" port:80`



Copyright © EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit eccouncil.org

IIS Information Gathering using Shodan

Gathering information on IIS servers can provide attackers with crucial details that assist in the planning and execution of further attacks. By identifying the version of IIS used, attackers can match known vulnerabilities to a specific version, making it easier to exploit them. In addition, information such as open ports, running services, and server configurations can reveal weak points in the security posture of the server. With a detailed knowledge of the IIS server environment, attackers can plan their attacks to exploit specific weaknesses. For example, if the gathered data show that a particular server uses an outdated version of IIS, attackers may deploy exploits targeting vulnerabilities specific to that version.

For this purpose, attackers can use tools such as Shodan, which can help them gather the necessary information about IIS servers, thereby significantly enhancing their ability to perform targeted and efficient attacks. Shodan search filters that can be used by attackers to gather information on IIS servers are as follows:

- Use the following filter to search for any IIS server and to provide a list of instances running IIS:

  `http.title:"IIS"`

- Use the following filter to identify IIS servers with SSL certificates issued to "`Company_name`" that can assist in finding servers associated with a specific organization:

  `Ssl:"Company Inc." http.title:"IIS"`

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

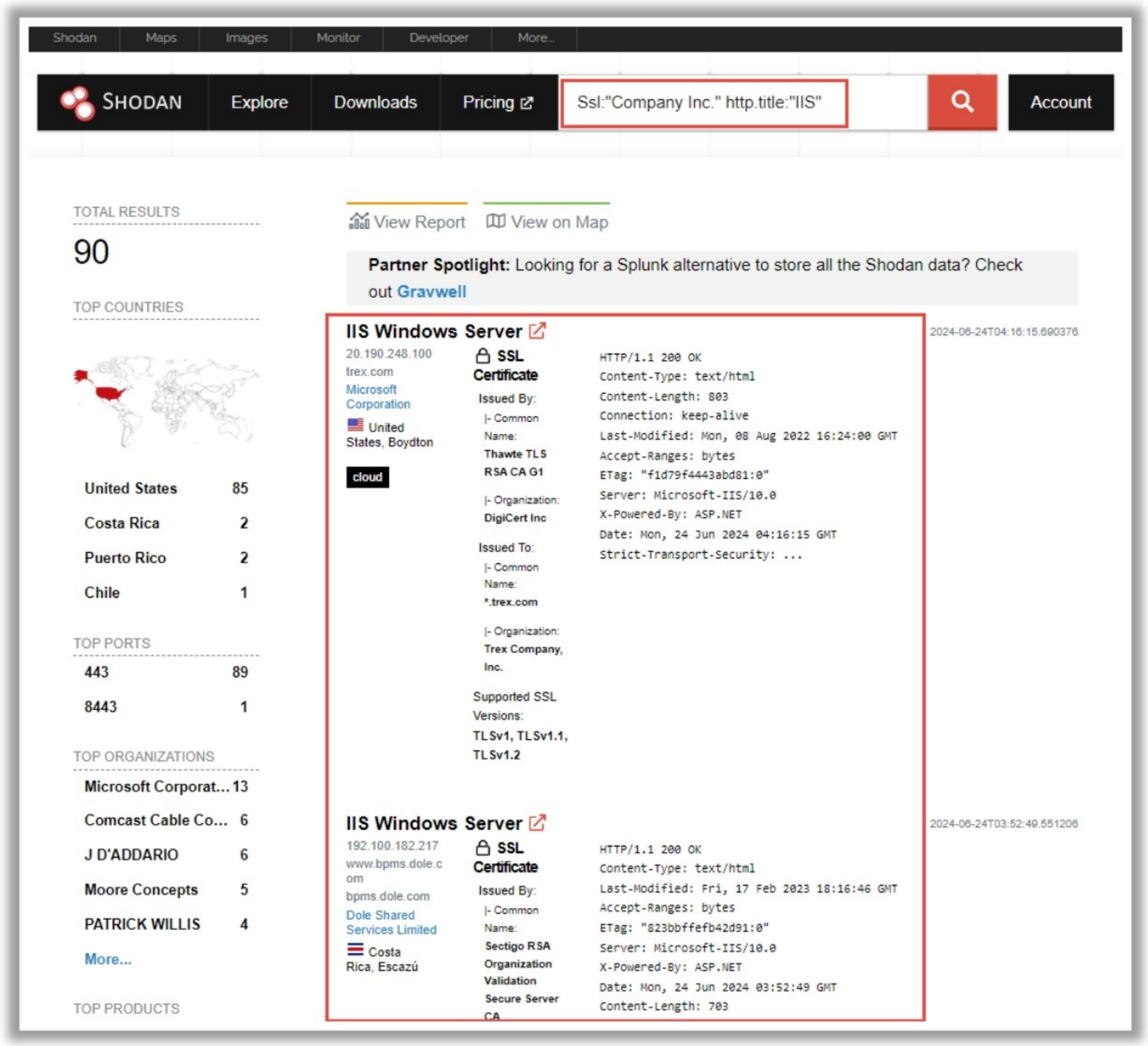


Figure 13.38: Screenshot of Shodan showing the servers associated with a specific organization

- Use the following filter to locate IIS servers with SSL certificates where the common name (CN) is "**company.in**":

  Ssl.cert.subject.CN:"company.in" http.title:"IIS"

  This can assist in identifying servers associated with a specific domain or subdomain.

- Use the following filter to identify IIS servers in the US that can aid in geographically targeted attacks:

  http.title:"IIS Windows Server" country:"US"

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

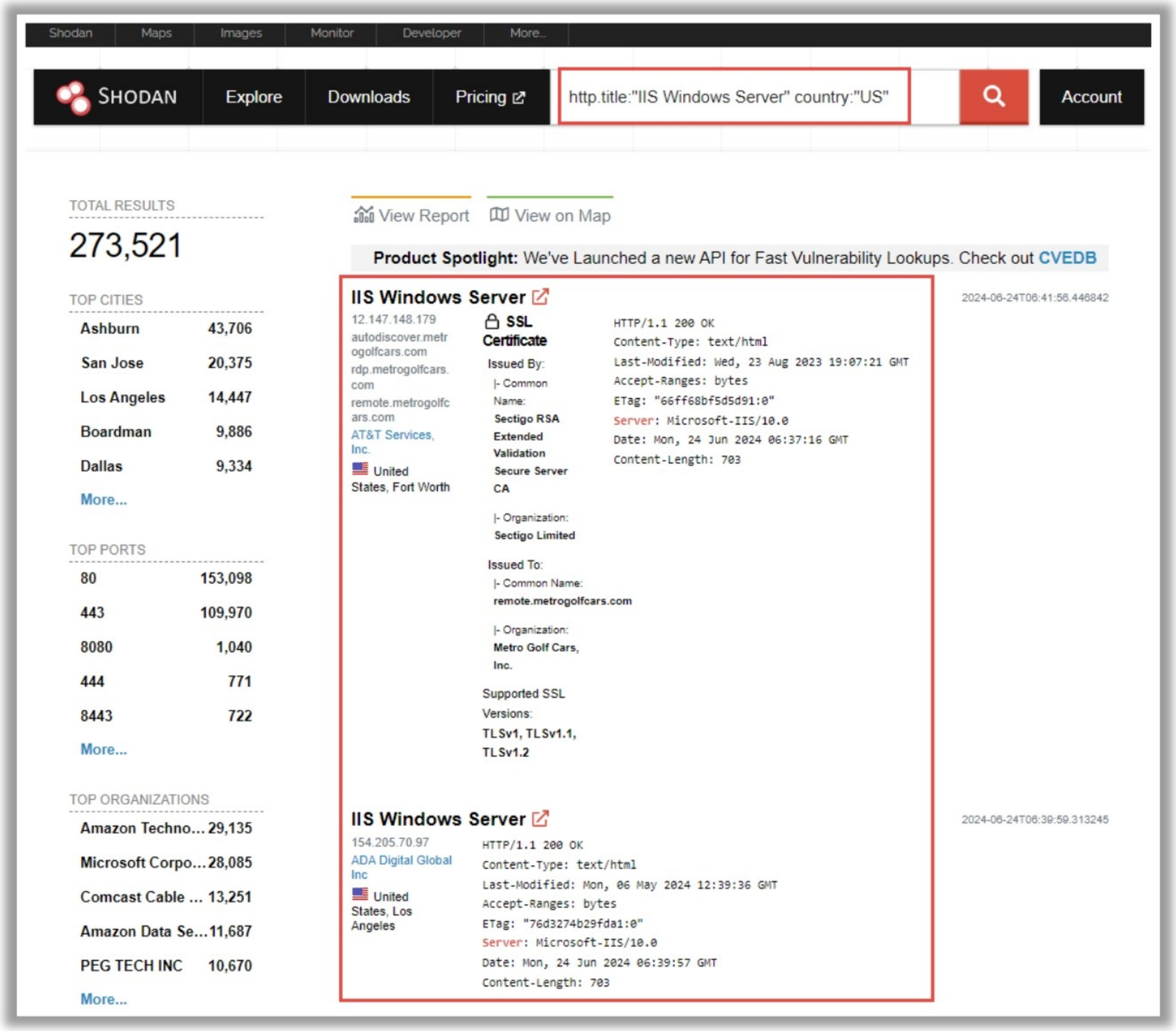


Figure 13.39: Screenshot of Shodan showing the IIS servers located in the US

- Use the following filter to locate IIS7 servers running on port 80:

```
http.title:"IIS7" port:80
```


Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

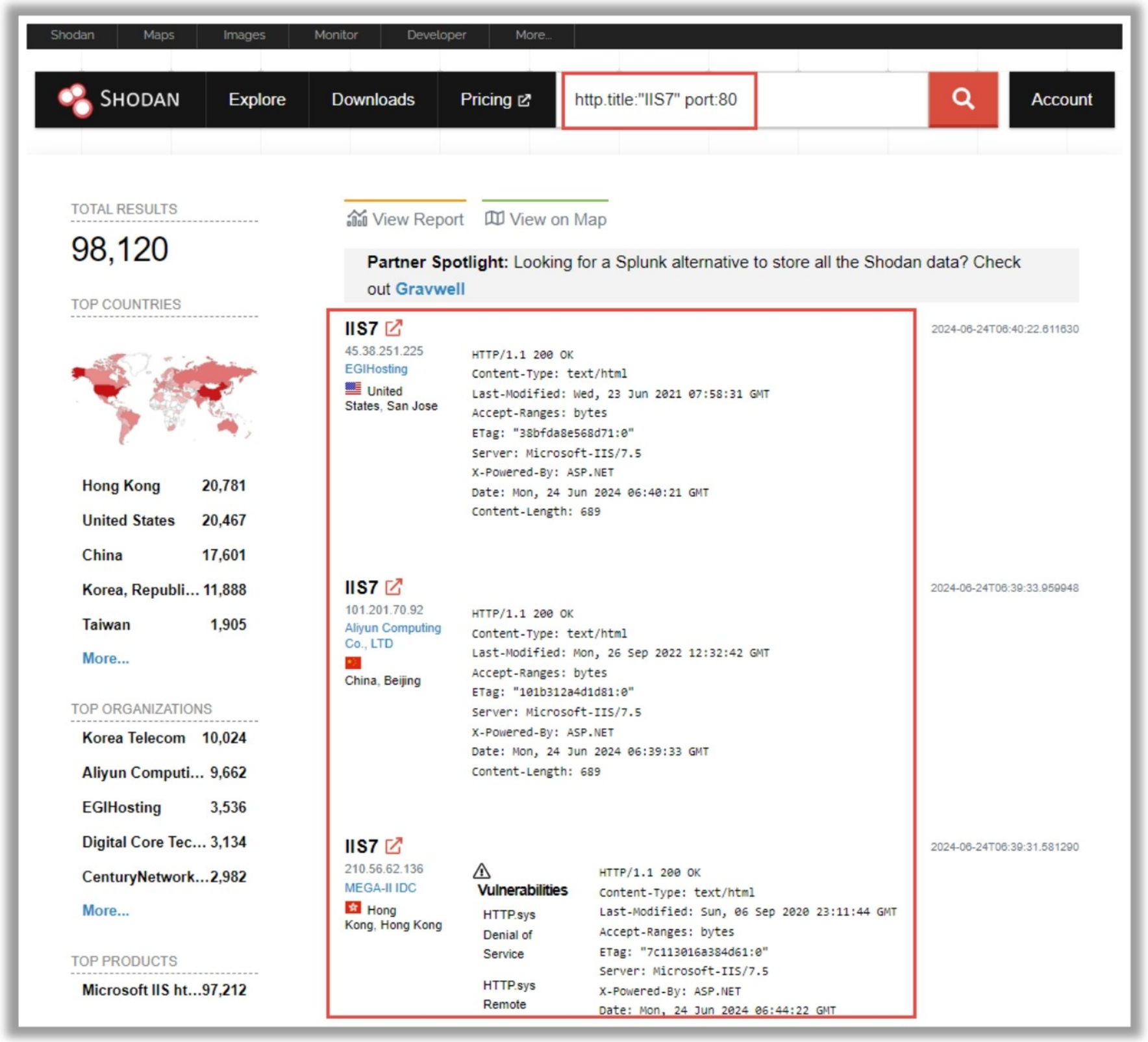


Figure 13.40: Screenshot of Shodan showing the IIS7 servers running on port 80

- Use the following filter to search for IIS7 servers within a specific IP range to assist in network-specific information gathering:

  `http.title:"IIS7" net:"<IP_address>/24"`

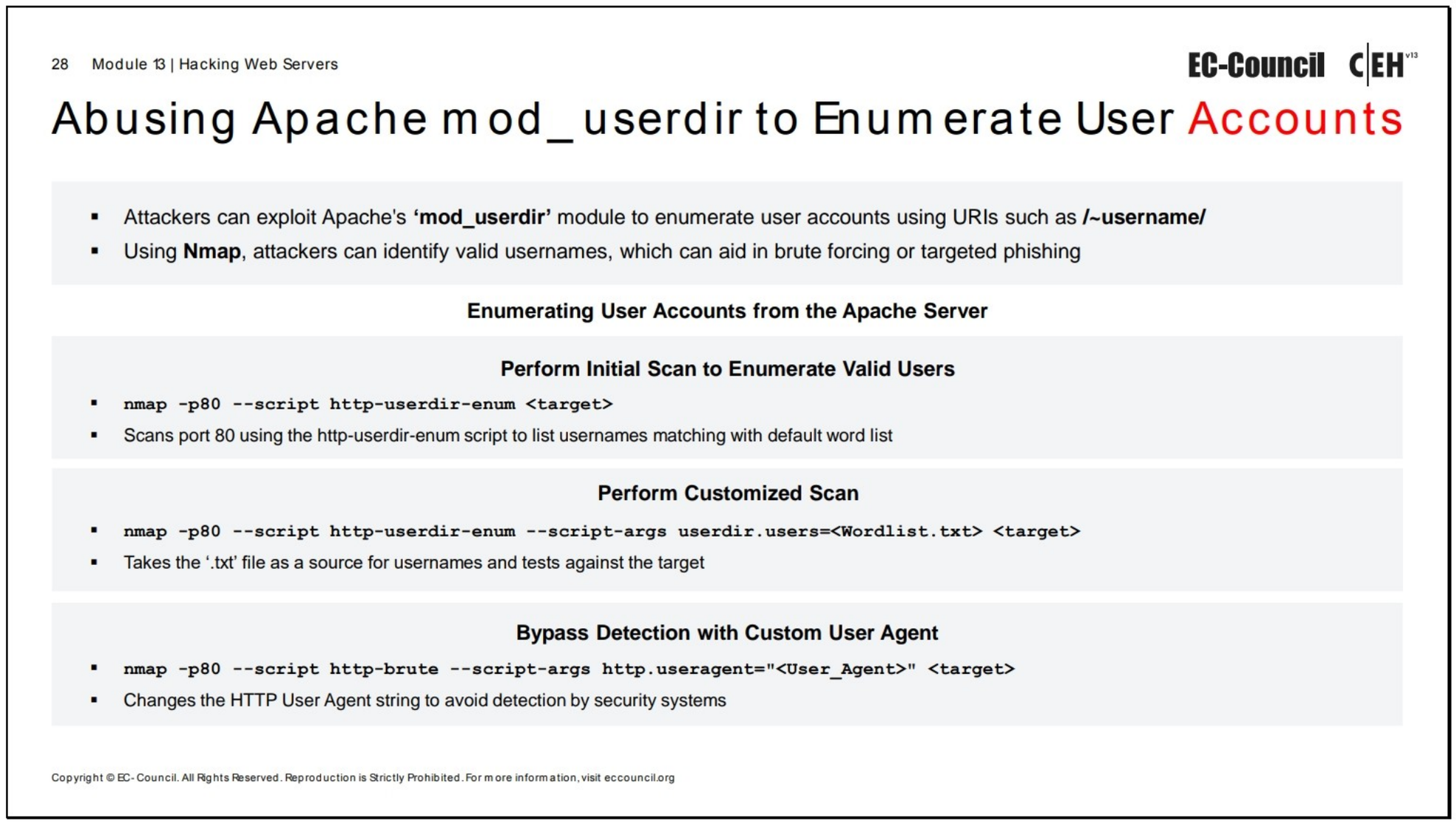
Additional Shodan search filters that can be used by attackers to gather information on IIS servers are as follows:

- **`http.title:"IIS7"`** – Identifies IIS servers running version 7, useful for finding specific version vulnerabilities.
- **`http.title:"IIS Windows Server"`** - Targets IIS servers on Windows, helpful for Windows-specific exploitation.
- **`http.title:"Internet Information Services"`** - Broad search for any IIS servers, useful for general information gathering.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Attackers can now review the search results to gather information about IIS servers, such as their IP addresses, open ports, running services, and version details. They can also click on individual results to obtain detailed information about the server, including HTTP headers, SSL certificates, and additional metadata. In addition, they can use Shodan's export features to save data in formats, such as CSV or JSON, for further analysis.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.



Abusing Apache mod_userdir to Enumerate User Accounts

Attackers can exploit Apache's '**mod_userdir**' module to enumerate user accounts on a web server. This module allows access to user directories using URIs formatted as '**/~username/**'. Using the Nmap tool, attackers can identify valid usernames to obtain valuable information that can be used to perform further attacks, such as brute-forcing or targeted phishing.

Enumerating User Accounts from the Apache Server

- **Perform Initial Scan to Enumerate Valid Users**

  Run the following command to enumerate valid users from the target web server with **mod_userdir** enabled:

  nmap -p80 --script http-userdir-enum <target>

  This command scans the target on port 80 using the '**http-userdir-enum**' script. If '**mod_userdir**' is enabled, the script uses the default word list '**usernames.lst**' located at '**/nselib/data/**' and lists any found usernames.

- **Perform Customized Scan**

  A customized list of potential usernames can be used to improve the accuracy and effectiveness of the attacks. Run the following command with the custom word list '**<Wordlist>.txt**':

  nmap -p80 --script http-userdir-enum --script-args userdir.users=<Wordlist>.txt <target>

  This command takes the '**.txt**' file as a source for the usernames and tests against the target.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

- **Bypass Detection with Custom User Agent**

  Some security systems may detect and block requests from Nmap because of its default user-agent string. To bypass such detection, a custom user agent should be specified. Run the following command with the specified HTTP user-agent string to avoid detection:

  ```
  nmap -p80 --script http-brute --script-args http.useragent="<User_Agent>" <target>
  ```

  This command changes the HTTP user-agent string used by Nmap to a specified string, making the traffic appear to originate from a standard web browser rather than a scanning tool.

Enumerating Web Server Information Using Nmap

Source: *https://nmap.org*

Nmap, along with the Nmap Scripting Engine (NSE), can extract a large amount of valuable information from the target web server. In addition to Nmap commands, NSE provides scripts that reveal various types of useful information about the target server to an attacker.

An attacker uses the following Nmap commands and NSE scripts to extract information.

- Discover virtual domains with hostmap:

  ```
  $nmap --script hostmap-bfk <host>
  ```

- Detect a vulnerable server that uses the TRACE method:

  ```
  nmap --script http-trace -p80 localhost
  ```

- Harvest email accounts with http-google-email:

  ```
  $nmap --script http-google-email <host>
  ```

- Enumerate users with http-userdir-enum:

  ```
  nmap -p80 --script http-userdir-enum localhost
  ```

- Detect HTTP TRACE:

  ```
  $nmap -p80 --script http-trace <host>
  ```

- Check if the web server is protected by a web application firewall (WAF) or IPS:

  ```
  $nmap -p80 --script http-waf-detect --script-args="http-waf-detect.uri=/testphp.vulnweb.com/artists.php,http-waf-detect.detectBodyChanges" www.modsecurity.org
  ```

- Fingerprint a WAF

  ```
  nmap --script=http-waf-fingerprint -p80,443 <host>
  ```

- Enumerate common web applications

  ```
  $nmap --script http-enum -p80 <host>
  ```

- Obtain robots.txt

  ```
  $nmap -p80 --script http-robots.txt <host>
  ```


Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

The following are some additional Nmap commands used to extract web server information:

- **nmap -sV –O –p target IP address**
- **nmap -sV --script http-enum target IP address**
- **nmap target IP address -p 80 --script = http-frontpage-login**
- **nmap --script http-passwd --script-args http-passwd.root =/ target IP address**

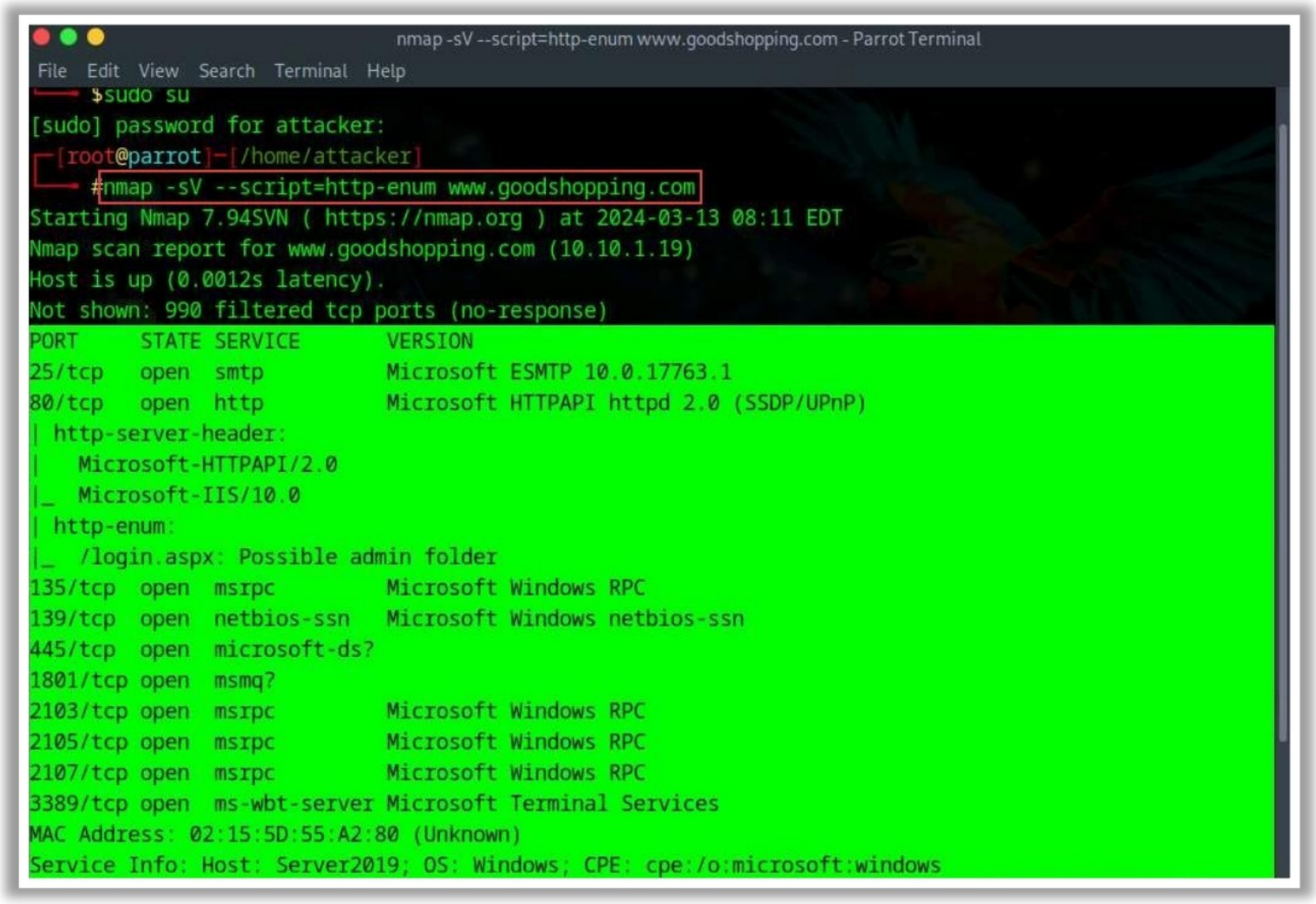


Figure 13.41: Screenshot of Nmap

Finding Default Credentials of Web Server

Administrators or security personnel use administrative interfaces to securely configure, manage, and monitor web application servers. Many web server administrative interfaces are publicly accessible and located in the root directory. Often, these administrative interface credentials are not properly configured and remain set to default. Attackers attempt to identify the running application interface of the target web server by performing port scanning. Once the running administrative interface is identified, the attacker uses the following techniques to identify the default login credentials:

- Consult the administrative interface documentation and identify the default passwords
- Use Metasploit's built-in database to scan the server
- Use online resources such as cirt.net (*https://cirt.net/passwords*) and FortyPoundHead.com (*https://www.fortypoundhead.com*) to identify the default passwords
- Attempt password-guessing and brute-forcing attacks

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

These default credentials can grant access to the administrative interface, compromising the web server and allowing the attacker to exploit the main web application.

- **cirt.net**

  Source: *https://cirt.net/passwords*

  cirt.net is a lookup database for default passwords, credentials, and ports.

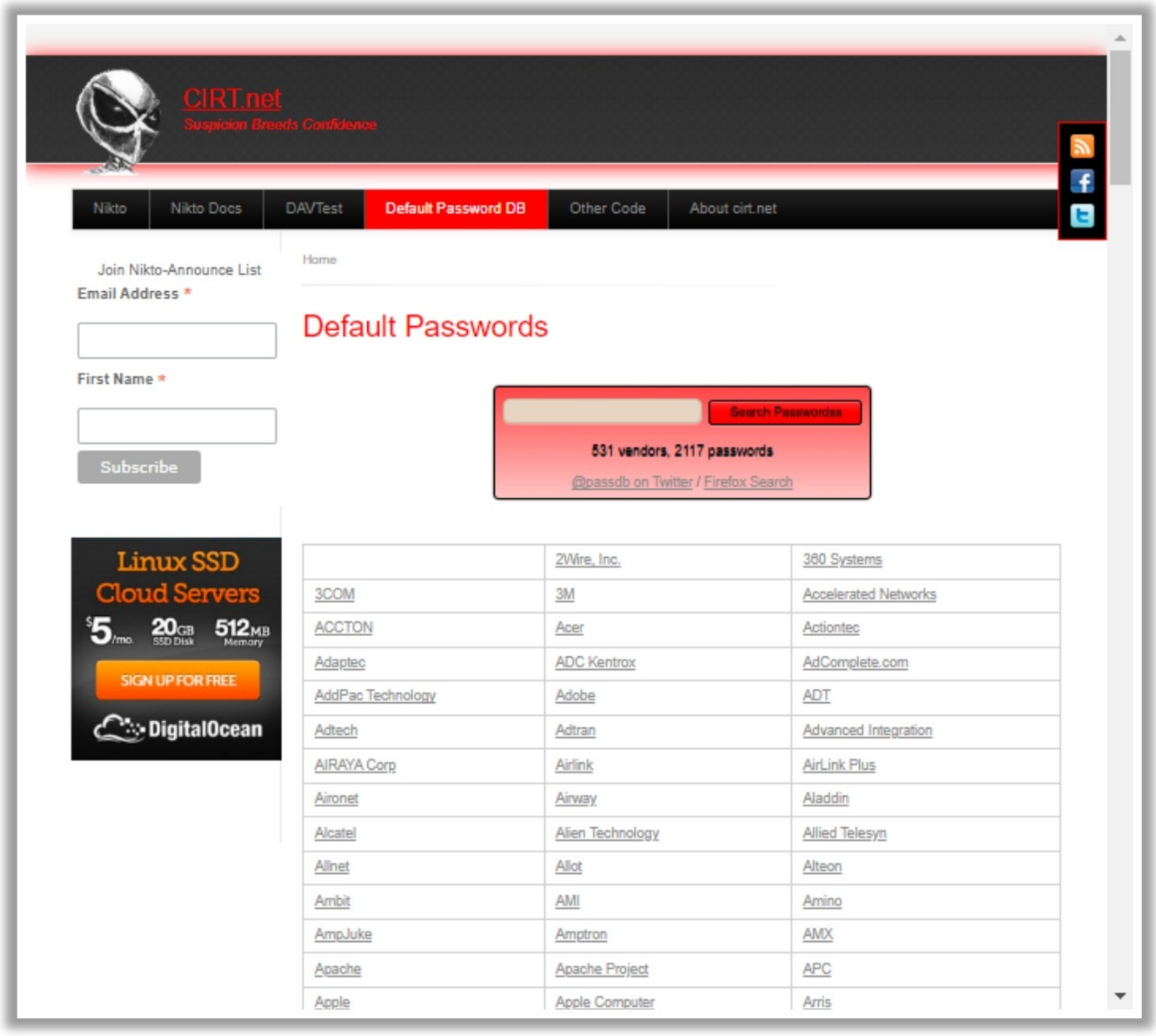


Figure 13.42: Screenshot displaying the default password DB page of cirt.net

The following are some additional websites for finding the default passwords of web server administrative interfaces:

- *https://www.fortypoundhead.com*
- *https://www.defaultpassword.com*
- *https://default-password.info*
- *https://www.routerpasswords.com*

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Finding Default Content of Web Server

Most servers of web applications have default contents and functionalities that allow attackers to launch attacks. The following are some common default contents and functionalities that an attacker attempts to identify in web servers.

- **Administrators debug and test functionality**

  Functionalities designed for administrators to debug, diagnose, and test web applications and web servers contain useful configuration information and the runtime state of both the server and its running applications. Hence, these functionalities are the main targets for attackers.

- **Sample functionality to demonstrate common tasks**

  Many servers contain various sample scripts and pages designed to demonstrate certain application server functions and application programming interfaces (APIs). Often, web servers fail to secure these scripts from attackers, and these sample scripts either contain vulnerabilities that can be exploited by attackers or implement functionalities that allow attackers to exploit.

- **Publicly accessible powerful functions**

  Some web servers include powerful functionalities that are intended for administrative personnel and restricted from public use. However, attackers attempt to exploit such powerful functions to compromise the server and gain access. For example, some application servers allow web archives to be deployed over the same HTTP port as that used by the application. An attacker may use common exploitation frameworks such as Metasploit to perform scanning to identify default passwords, upload backdoors, and gain command-shell access to the target server.

- **Server installation manuals**

  An attacker attempts to identify server manuals, which may contain useful information about configuration and server installation. Accessing this information allows the attacker to prepare an appropriate framework to exploit the installed web server.

Tools such as Nikto2 can be used to identify default contents.

- **Nikto2**

  Source: *https://cirt.net*

  Nikto is a vulnerability scanner used extensively to identify potential vulnerabilities in web applications and web servers.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

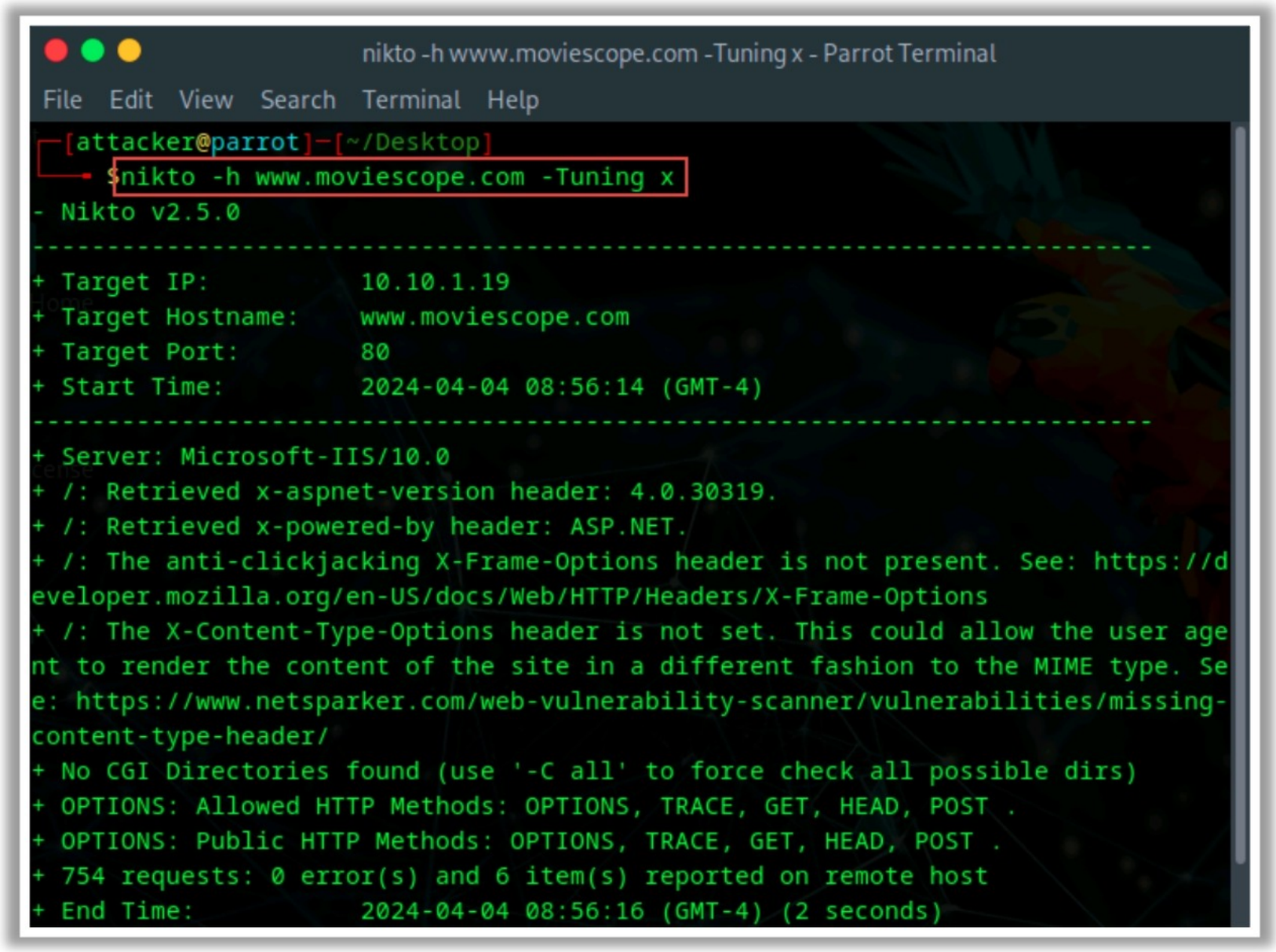


Figure 13.43: Screenshot of Nikto2

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Directory Brute Forcing

When a web server receives a request for the directory, it responds to the request in the following ways:

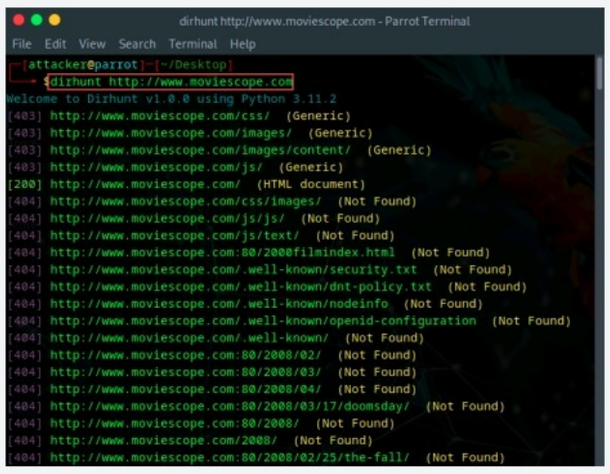
- Returns **default resource within the directory**
- Returns **error**
- Returns **listing of directory content**

Directory listings sometimes possess the following **vulnerabilities** that allow the attackers to **compromise the web server**:

- Improper **access controls**
- Unintentional **access to the web root** of servers

- After discovering the directory on the web server, **make a request** for the **same directory** and try to **access the directory listings**
- Try to **exploit vulnerable web server software** that gives **access to the directory listings**

Attackers use tools such as **Dirhunt** to search and analyze directories



https://github.com

Copyright © EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit eccouncil.org

Directory Brute Forcing

When a web server receives a request for a directory, rather than a file, the web server responds to the request in the following ways.

- **Return Default Resource within the directory**

  The server may return a default resource within the directory, such as index.html.

- **Return Error**

  The server may return an error, such as the HTTP status code 403, indicating that the request is not permitted.

- **Return listing of directory content**

  The server may return a listing showing the contents of the directory. A sample directory listing is shown in the screenshot.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Figure 13.44: Screenshot displaying a sample directory listing

Though directory listings do not have significant relevance from a security perspective, they occasionally possess the following vulnerabilities that allow attackers to compromise web applications:

- Improper access controls
- Unintentional access to the web root of servers

In general, after discovering a directory on a web server, an attacker makes a request for that directory and attempts to access the directory listing. Attackers also attempt to exploit vulnerable web server software that grants access to directory listings.

Attackers use tools such as Dirhunt and Sitechecker Website Directory Scanner to find directory listings of the target web server.

- **Dirhunt**

  Source: *https://github.com*

  Dirhunt is a web crawler optimized for searching and analyzing directories. This tool can find interesting results if the server has the "index of" mode enabled. Dirhunt is also useful if the directory listing is not enabled. It detects directories with false 404 errors, directories where an empty index file has been created to hide things, and so on.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

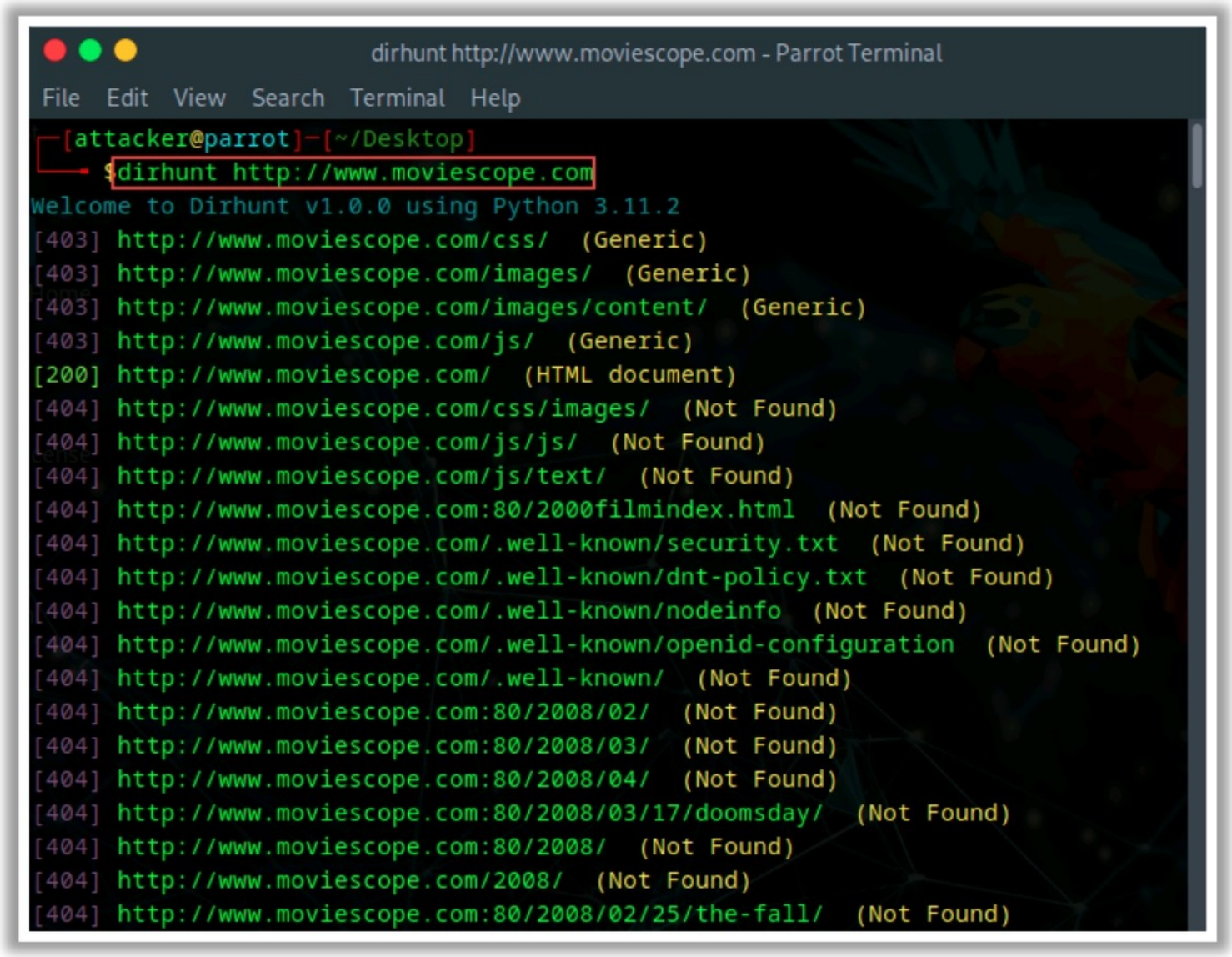


Figure 13.45: Screenshot of Dirhunt displaying directories and files

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

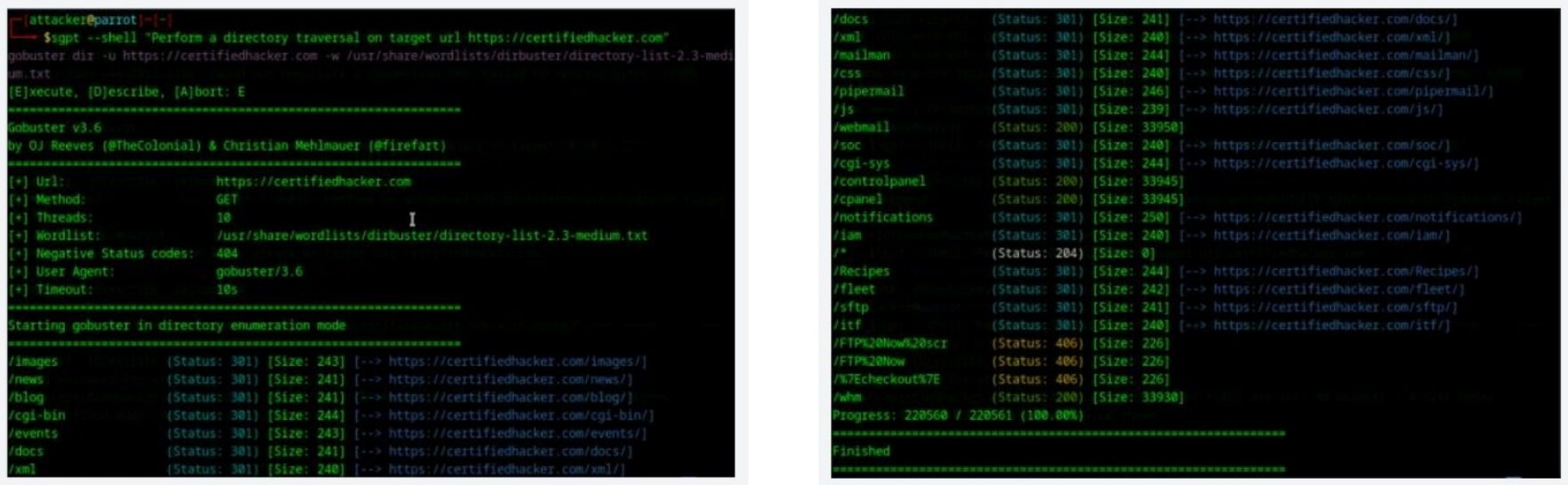
30 Module 13 | Hacking Web Servers

EC-Council C|EH v13

Directory Brute Forcing with AI

An attacker can also leverage AI-powered ChatGPT or other generative AI technology to perform this task by using an appropriate prompt such as

- ***"Perform a directory traversal on target url https://certifiedhacker.com"***



Copyright © EC- Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit eccouncil.org

Directory Brute Forcing with AI

Attackers can leverage AI-powered technologies to enhance and automate hacking. With the aid of AI, attackers can effortlessly perform directory-traversal attacks on the target domain.

For example,

An attacker can use ChatGPT to perform this task by using an appropriate prompt such as:

- **"Perform a directory traversal on target url https://certifiedhacker.com"**

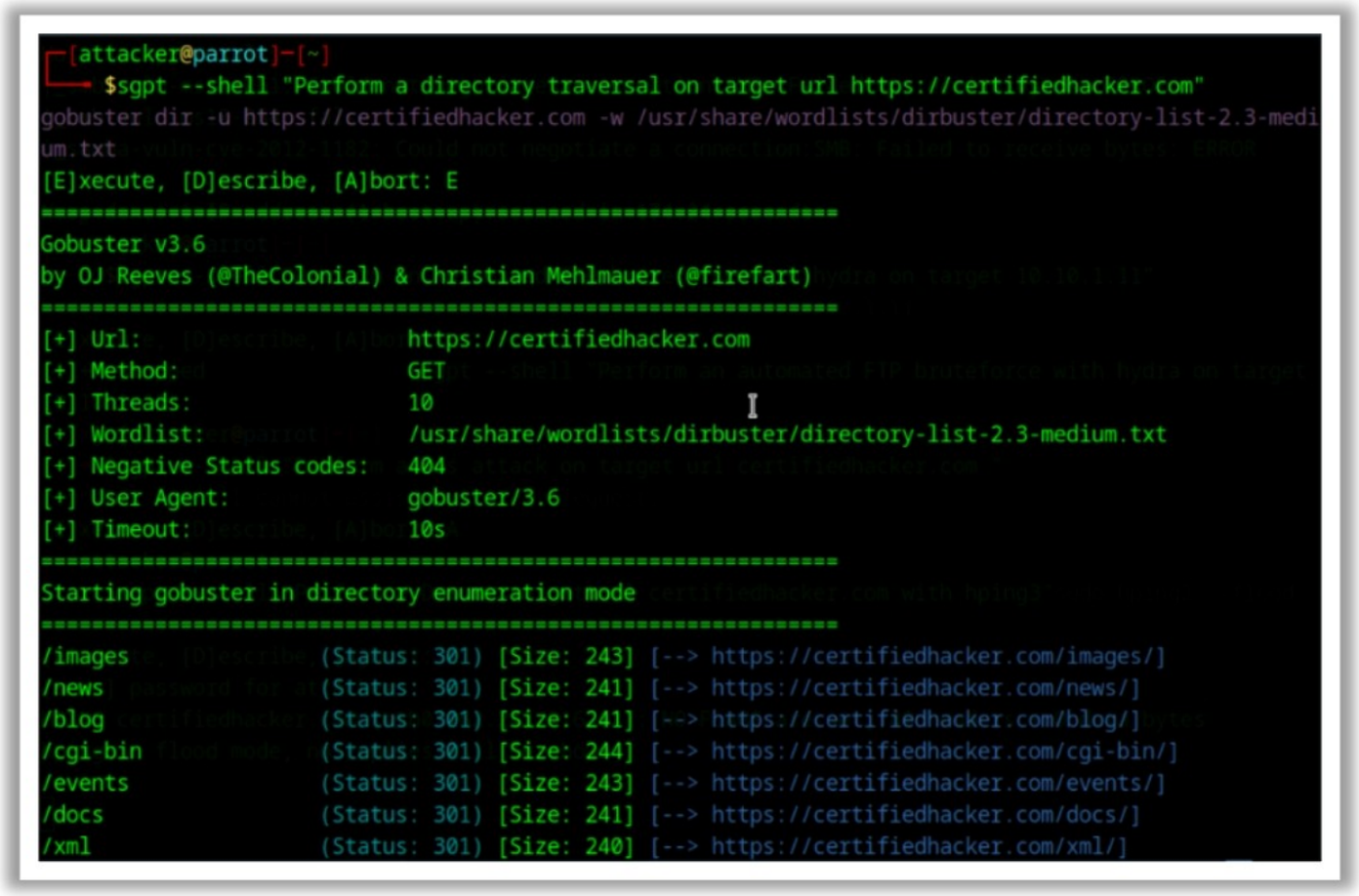


Figure 13.46: Directory traversal with ChatGPT

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

The output of prompt results in following command.

```
gobuster dir -u https://certifiedhacker.com -w
/usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
```

This command is attempting to discover directories on the website.

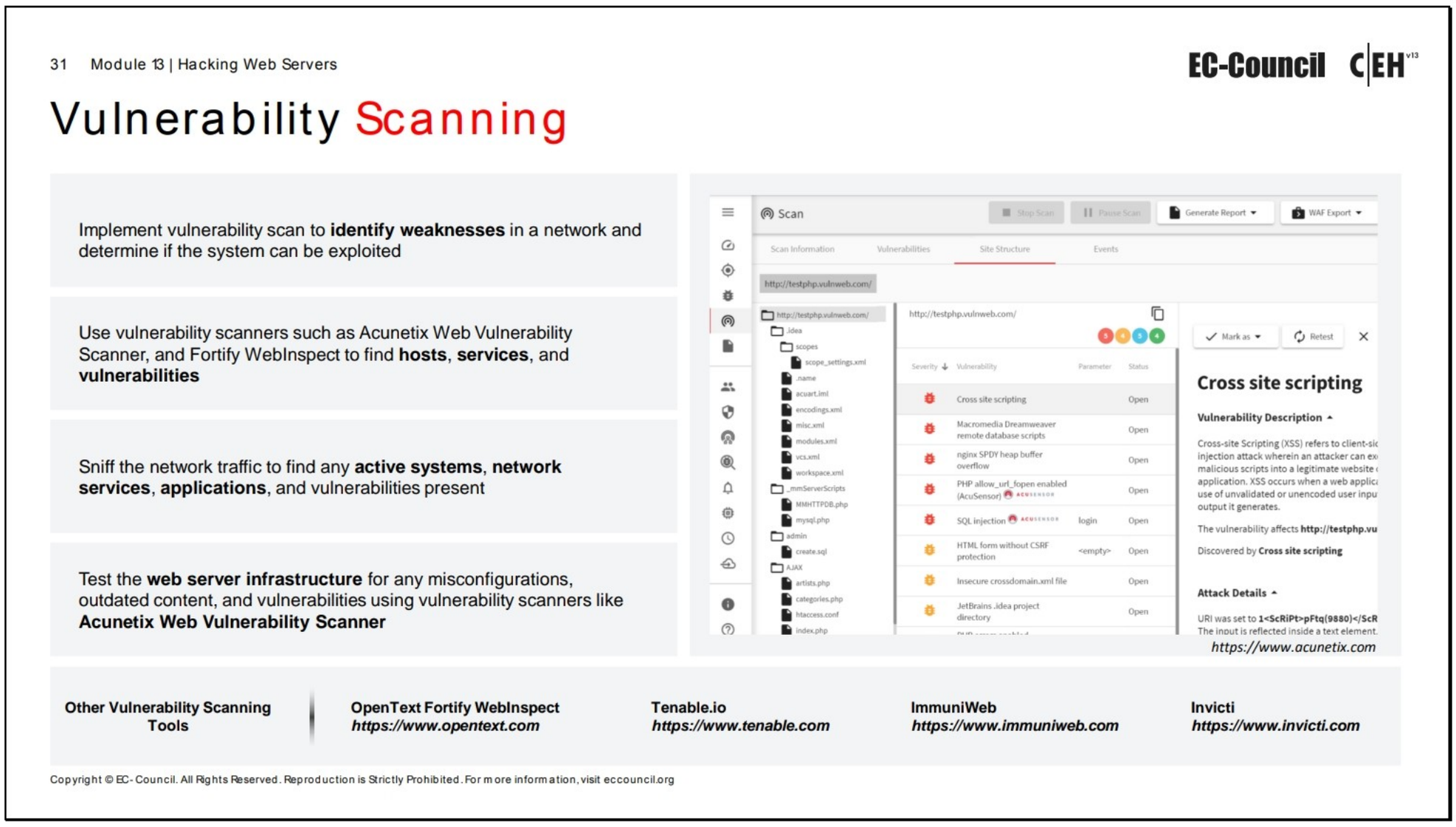
- **`gobuster dir`:** This is the `gobuster` tool command to perform directory/file brute-forcing.
- **`-u https://certifiedhacker.com`:** Specifies the target URL which is "https://certifiedhacker.com".
- **`-w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt`:** Specifies the wordlist to be used for directory and file brute-forcing.

```
/docs                 (Status: 301) [Size: 241] [--> https://certifiedhacker.com/docs/]
/xml                  (Status: 301) [Size: 240] [--> https://certifiedhacker.com/xml/]
/mailman              (Status: 301) [Size: 244] [--> https://certifiedhacker.com/mailman/]
/css                  (Status: 301) [Size: 240] [--> https://certifiedhacker.com/css/]
/pipermail            (Status: 301) [Size: 246] [--> https://certifiedhacker.com/pipermail/]
/js                   (Status: 301) [Size: 239] [--> https://certifiedhacker.com/js/]
/webmail              (Status: 200) [Size: 33950]
/soc                  (Status: 301) [Size: 240] [--> https://certifiedhacker.com/soc/]
/cgi-sys              (Status: 301) [Size: 244] [--> https://certifiedhacker.com/cgi-sys/]
/controlpanel         (Status: 200) [Size: 33945]
/cpanel               (Status: 200) [Size: 33945]
/notifications        (Status: 301) [Size: 250] [--> https://certifiedhacker.com/notifications/]
/iam                  (Status: 301) [Size: 240] [--> https://certifiedhacker.com/iam/]
/*                    (Status: 204) [Size: 0]
/Recipes              (Status: 301) [Size: 244] [--> https://certifiedhacker.com/Recipes/]
/fleet                (Status: 301) [Size: 242] [--> https://certifiedhacker.com/fleet/]
/sftp                 (Status: 301) [Size: 241] [--> https://certifiedhacker.com/sftp/]
/itf                  (Status: 301) [Size: 240] [--> https://certifiedhacker.com/itf/]
/FTP%20Now%20scr      (Status: 406) [Size: 226]
/FTP%20Now            (Status: 406) [Size: 226]
/%7Echeckout%7E       (Status: 406) [Size: 226]
/whm                  (Status: 200) [Size: 33930]
Progress: 220560 / 220561 (100.00%)
===============================================================
Finished
===============================================================
```

Figure 13.47: Screenshot showing output

This command systematically tests different directories and files on the target website using the wordlist provided in an attempt to find any that might be accessible.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.



Vulnerability Scanning

Vulnerability scanning is performed to identify vulnerabilities and misconfigurations in a target web server or network. Vulnerability scanning reveals possible weaknesses in a target server to exploit in a web server attack. In the vulnerability-scanning phase, attackers use sniffing techniques to obtain data on the network traffic to determine active systems, network services, and applications. Automated tools such as Acunetix Web Vulnerability Scanner are used to perform vulnerability scanning on a target server and find hosts, services, and vulnerabilities.

- **Acunetix Web Vulnerability Scanner**

  Source: *https://www.acunetix.com*

  Acunetix Web Vulnerability Scanner (WVS) scans websites and detects vulnerabilities. Acunetix WVS checks web applications for SQL injections, XSS, and so on. It includes advanced pen testing tools to ease manual security audit processes and creates professional security audit and regulatory compliance reports based on AcuSensor Technology. It supports the testing of web forms and password-protected areas, pages with CAPTCHA, single sign-on, and two-factor authentication mechanisms. It detects application languages, web server types, and smartphone-optimized sites. Acunetix crawls and analyzes different types of websites, including HTML5, Simple Object Access Protocol (SOAP), and Asynchronous JavaScript and Extensible Markup Language (AJAX). It supports the scanning of network services running on the server and the port scanning of the web server.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

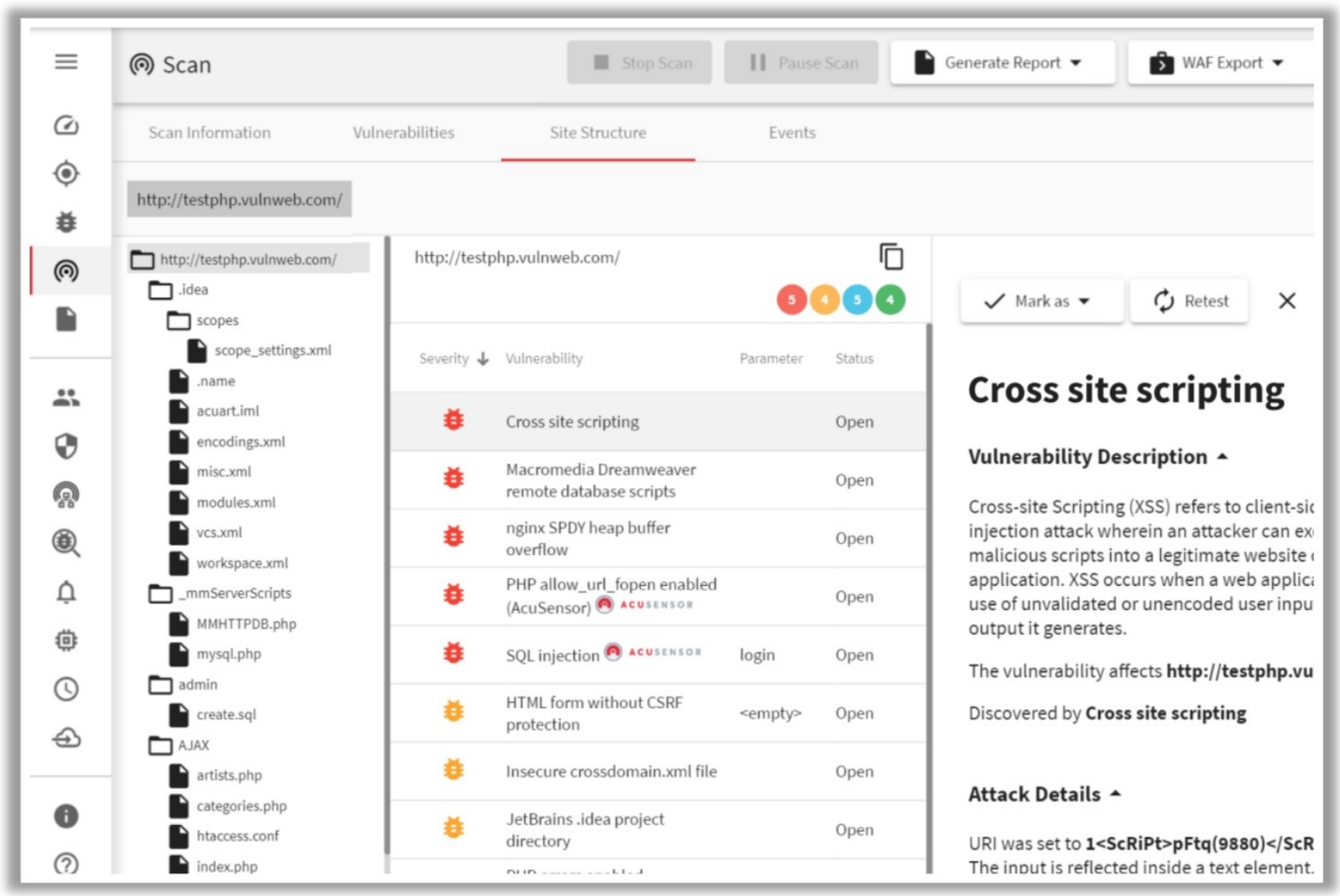


Figure 13.48: Screenshot of Acunetix Web Vulnerability Scanner

The following are some additional vulnerability scanning tools:

- OpenText Fortify WebInspect (*https://www.opentext.com*)
- Tenable.io (*https://www.tenable.com*)
- ImmuniWeb (*https://www.immuniweb.com*)
- Invicti (*https://www.invicti.com*)

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

EC-Council C|EH v13

Nginx Vulnerability Scanning using Nginxpwner

Nginxpwner is a Python-based tool designed to **identify common misconfigurations** and **vulnerabilities** in Nginx web servers that could be exploited

Scanning Nginx Web Server for Vulnerabilities

- Run the following command to create a temporary file to store a list of potential URL paths

  `nano /tmp/pathlist`

- Execute the nginxpwner script

  `python3 nginxpwner.py <target_URL> /tmp/pathlist`

- Analyze the output provided by Nginxpwner to identify potential vulnerabilities and misconfigurations in the target Nginx server

Copyright © EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit eccouncil.org

Nginx Vulnerability Scanning using Nginxpwner

Source: *https://github.com*

NginxPwner is a Python-based tool designed to identify common misconfigurations and vulnerabilities on Nginx web servers. NginxPwner automates the process of checking for security issues, such as misconfigured HTTP methods, improper file permissions, outdated software versions, and insecure default settings. Using this tool, attackers can quickly gather detailed information on the potential entry points and weaknesses in the Nginx setup, making it easier to launch targeted attacks.

Steps to Scan the Target Nginx Web Server for Vulnerabilities

- Run the following command to create a temporary file to store a list of potential URL paths acquired via crawling or other methods:

  `nano /tmp/pathlist`

  Insert the paths into this file, then save and exit using CTRL+X.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

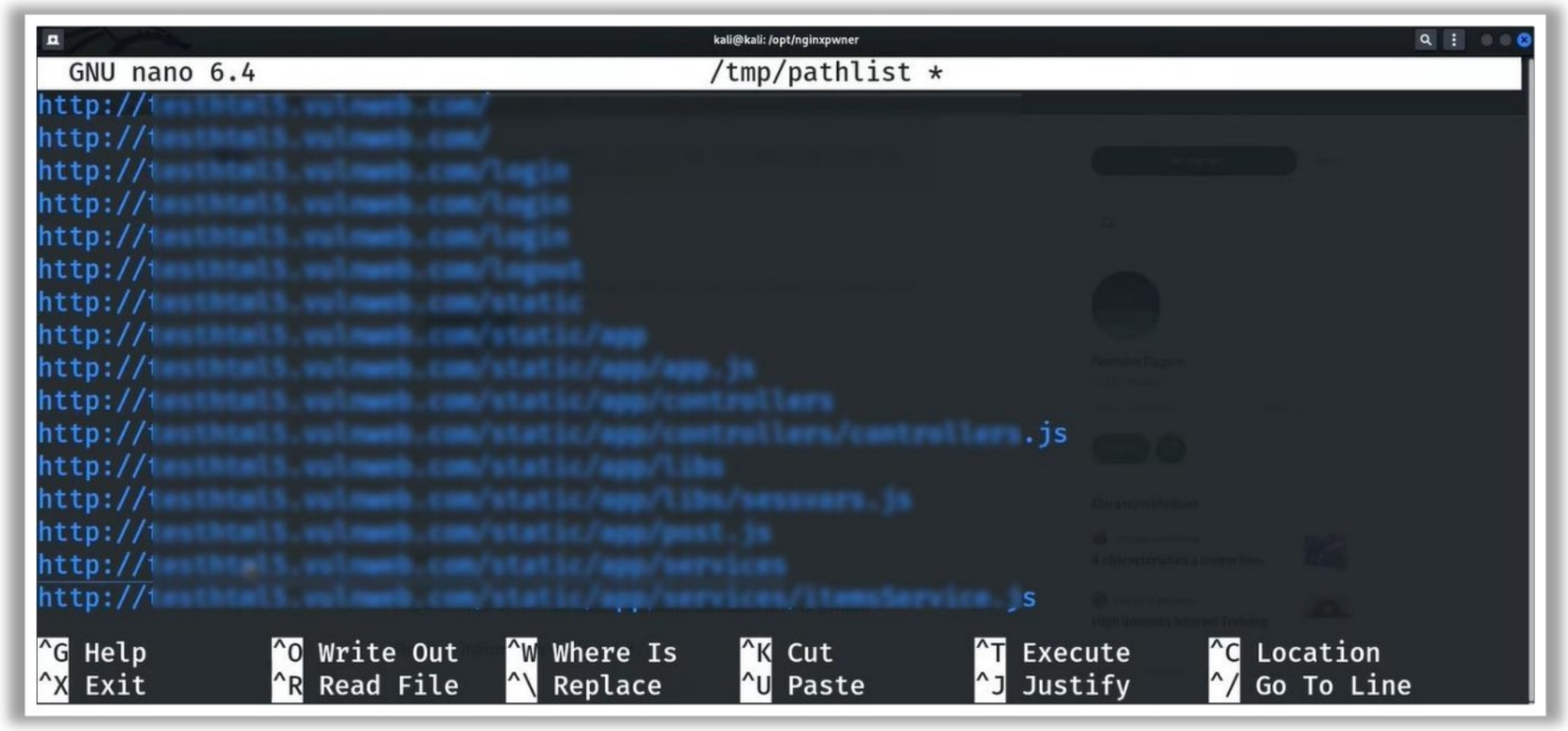


Figure 13.49: Screenshot of creating a path list for the Nginxpwner tool

- Execute the **nginxpwner** script, specifying the target URL and the path file:

  python3 nginxpwner.py <target_URL> /tmp/<pathlist>

  Replace **<target_URL>** and **/tmp/<pathlist>** with the actual target URL and path to your list file.

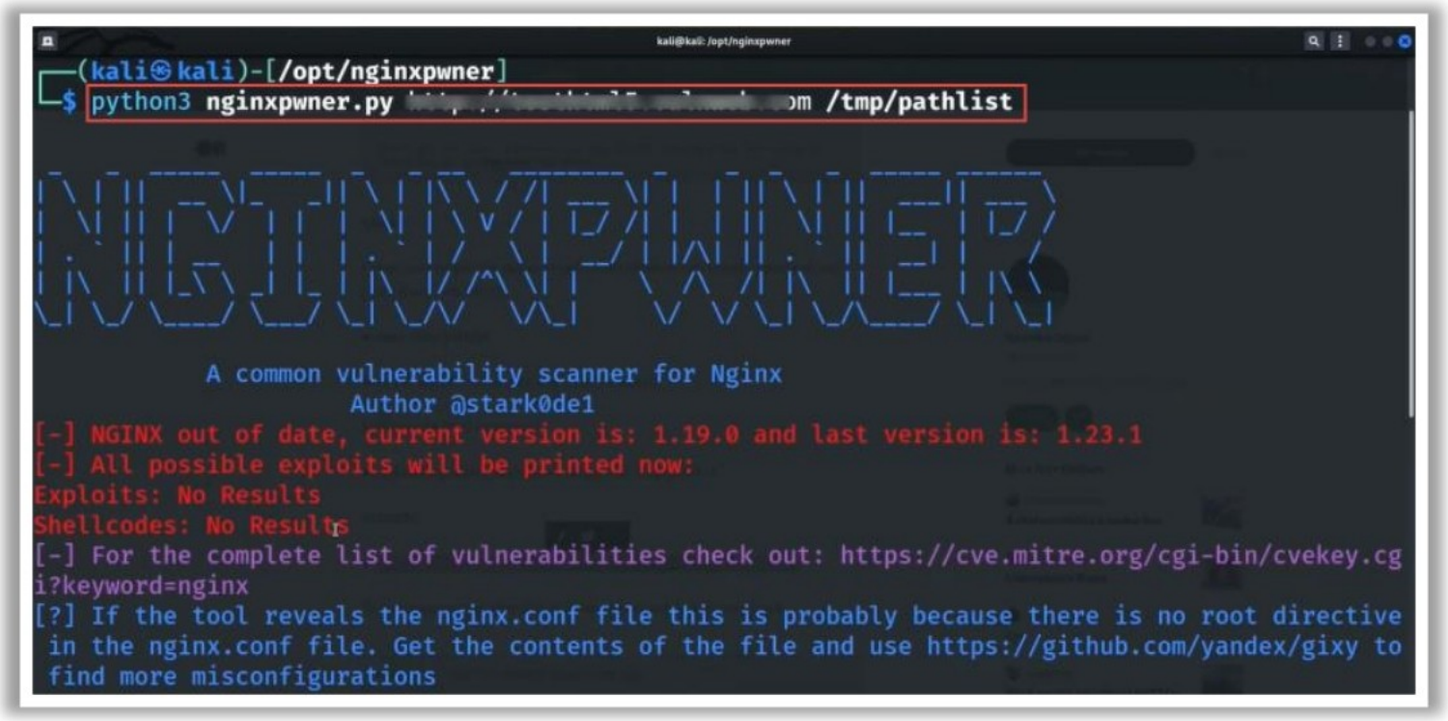
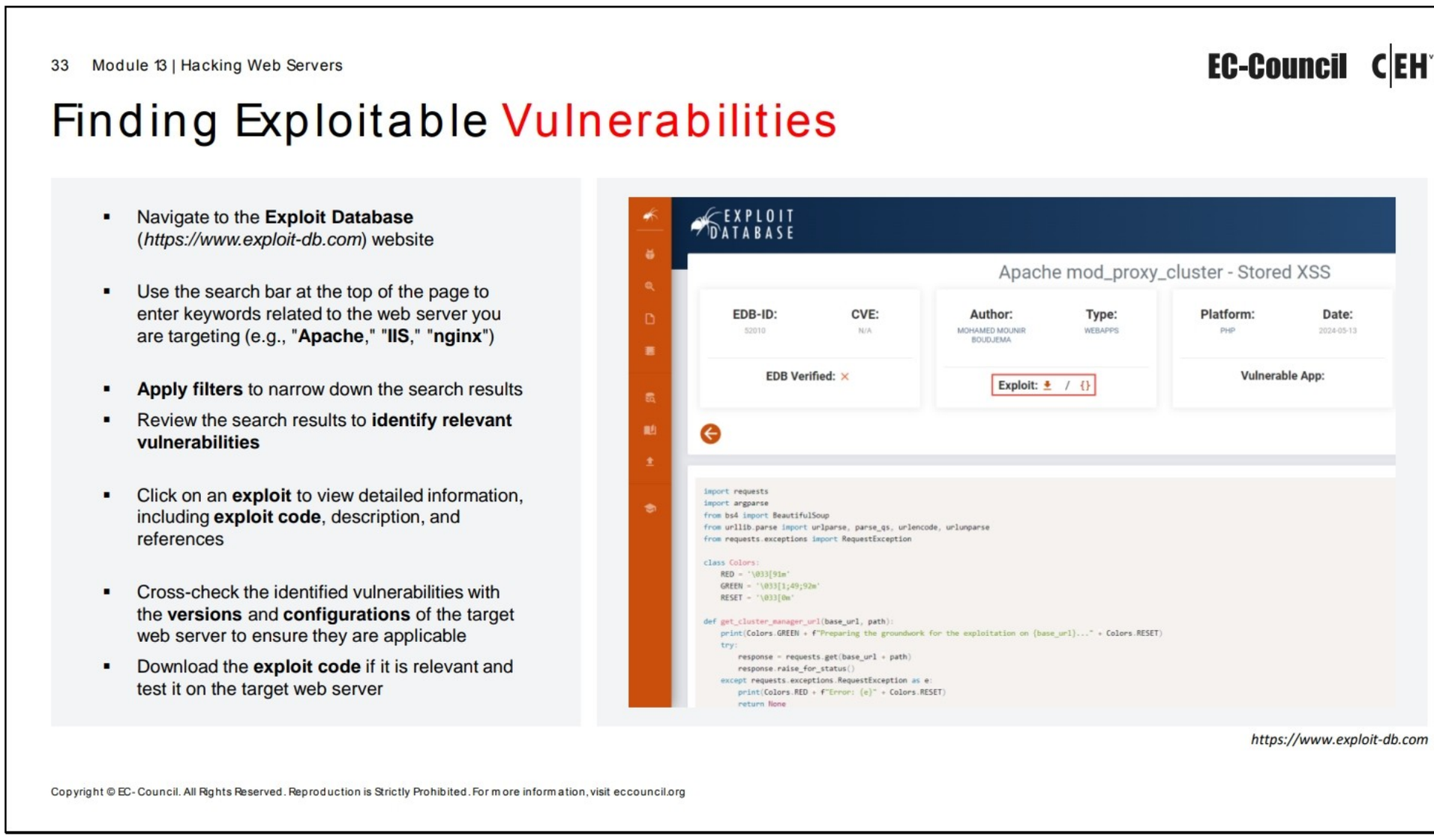


Figure 13.50: Screenshot of Nginxpwner tool showing the scanning result of target nginx web server

- Analyze the output provided by NginxPwner to identify potential vulnerabilities and misconfigurations in the target Nginx server.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.



Finding Exploitable Vulnerabilities

Flaws and programming errors in software design lead to security vulnerabilities. Attackers take advantage of these vulnerabilities to perform various attacks on the confidentiality, availability, or integrity of a system. Software vulnerabilities such as programming flaws in a program, service, or within the OS software or kernel can be exploited to execute malicious code.

Many public vulnerability repositories that are available online allow access to information about various software vulnerabilities. Attackers search on exploit sites such as Packet Storm (*https://packetstormsecurity.com*) and Exploit Database (*https://www.exploit-db.com*) for exploitable vulnerabilities of a web server based on its OS and software applications. Attackers use the information gathered in the previous stages to find the relevant vulnerabilities by using Exploit Database.

Exploiting these vulnerabilities allows attackers to execute a command or binary on a target machine to gain higher privileges than existing ones or to bypass security mechanisms. Attackers using these exploits can even access privileged user accounts and credentials.

Finding Exploitable Web Server Vulnerabilities Using Exploit Database

1. **Visit Exploit Database Website**

   Navigate to the Exploit Database (*https://www.exploit-db.com*) website.

2. **Use the Search Functionality**

   Use the search bar at the top of the page to enter keywords related to the web server you are targeting (e.g., "Apache," "IIS," "nginx").

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

3. **Filter Search Results**

   Apply filters to narrow down the search results. You can filter by:

   - Type: Choose "Webapps" for web server-related exploits.
   - Platform: Select the appropriate platform (e.g., Windows, Linux).
   - Date: Specify a date range to find recent vulnerabilities.

4. **Analyze the Results**

   Review the search results to identify the relevant vulnerabilities. Each result includes details such as the vulnerability description, affected software version, and type of exploit.

5. **Review Exploit Details**

   Click on an exploit to view detailed information, including:

   - Exploit Code: The actual code or script used to exploit the vulnerability.
   - Description: Detailed explanation of the vulnerability and how it can be exploited.
   - References: Links to additional resources or advisories.

6. **Verify Vulnerability**

   Cross-check the identified vulnerabilities with the versions and configurations of the target web server to ensure that they are applicable.

7. **Download and Test Exploits**

   Download the exploit code if it is relevant and tested in the target environment to verify its effectiveness.

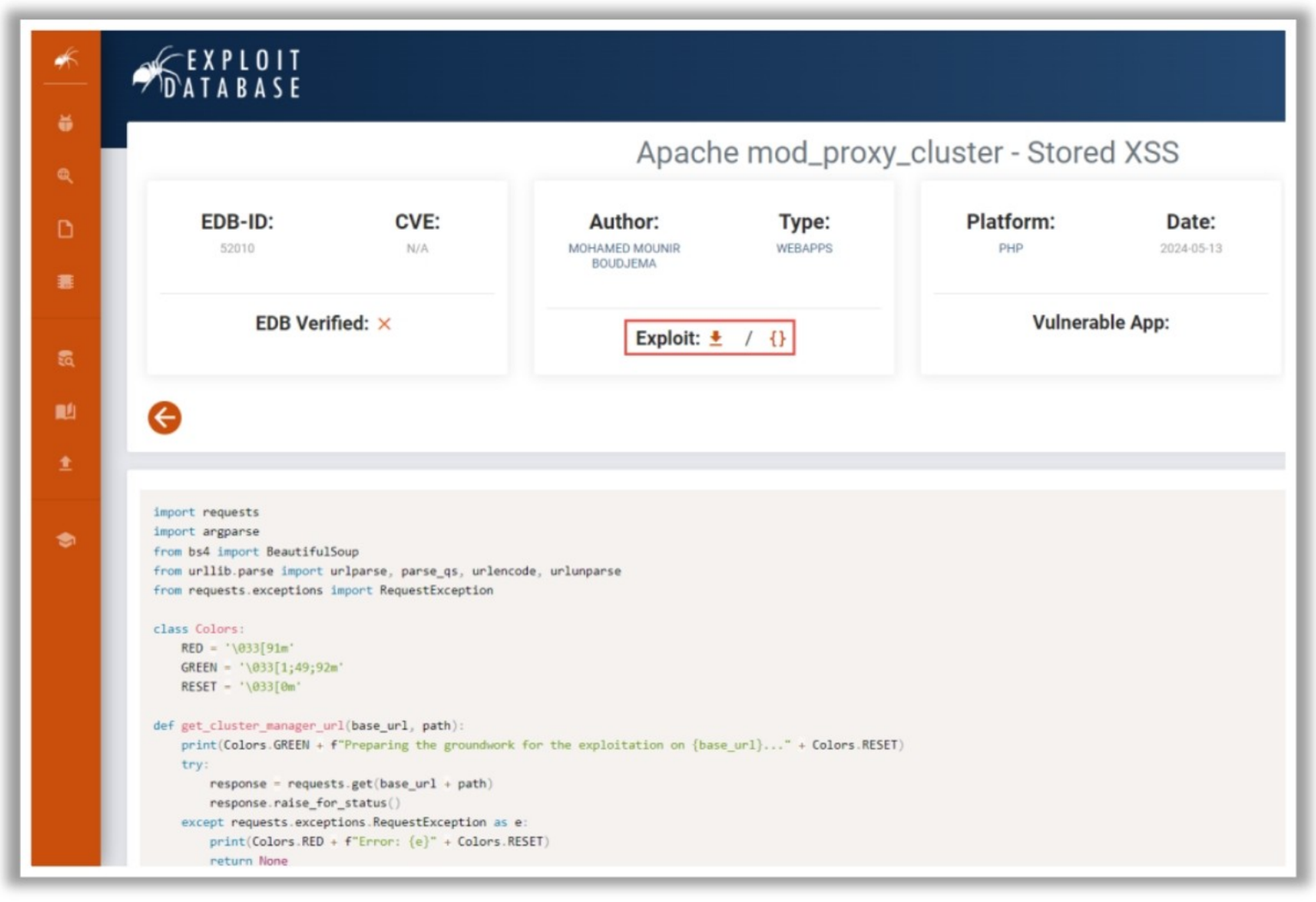


Figure 13.51: Screenshot of Google Hacking Database (GHDB)

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

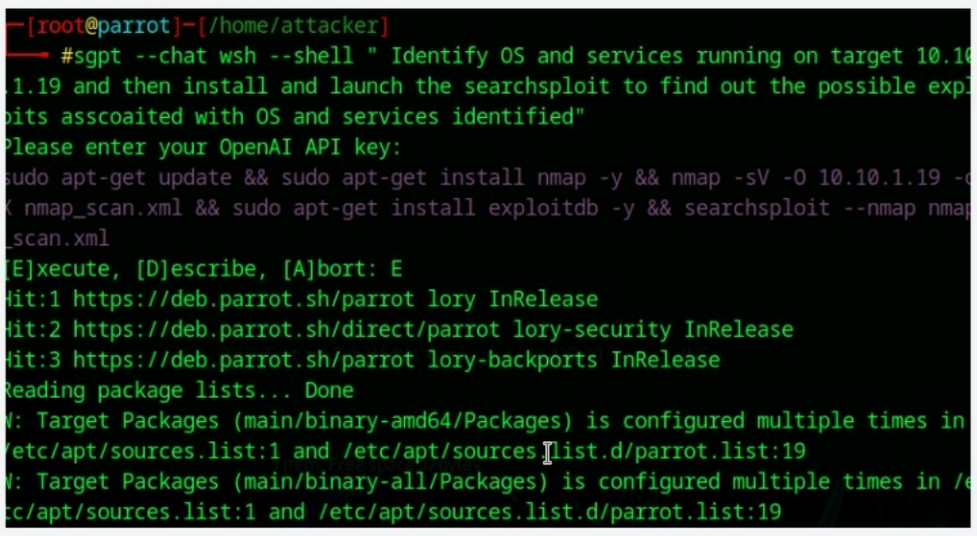
34 Module 13 | Hacking Web Servers

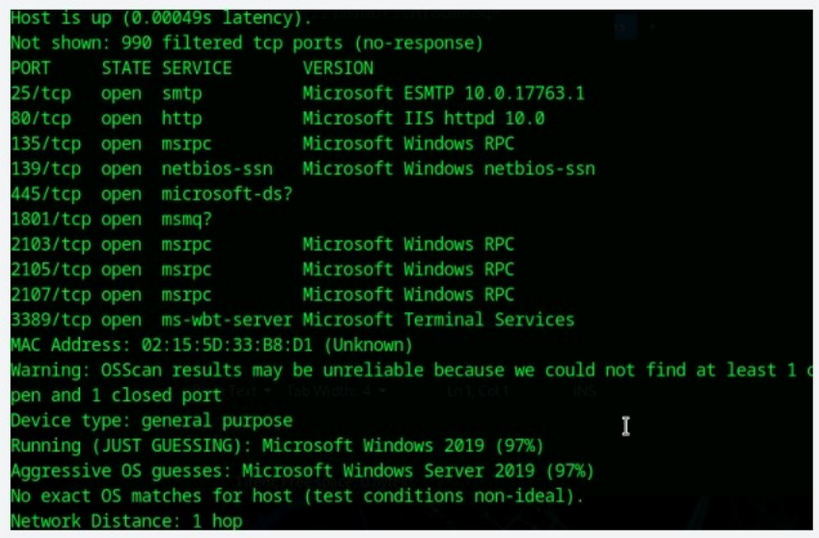
EC-Council C|EH v13

Finding Exploitable Vulnerabilities with AI

An attacker can also leverage AI-powered ChatGPT or other generative AI technology to perform this task by using an appropriate prompt such as

- "***Identify OS and services running on the target 10.10.1.19 and then install and launch the searchsploit to find out the possible exploits associated with OS and services identified***"



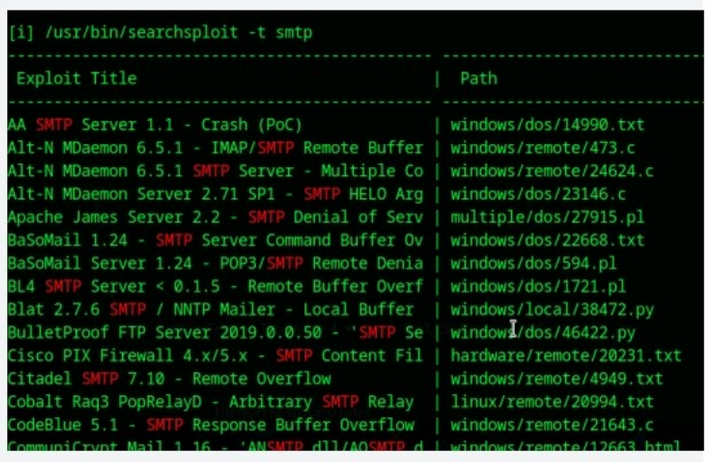


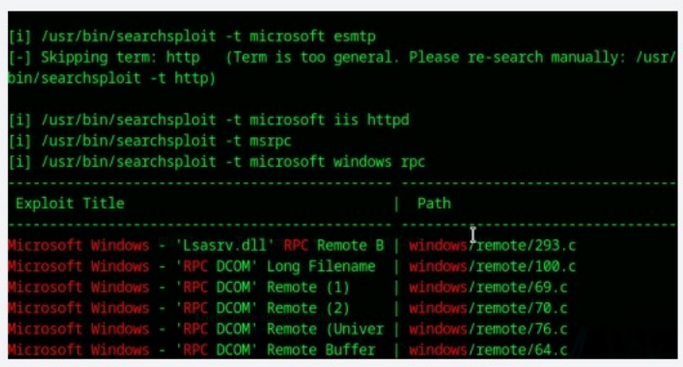
Copyright © EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit eccouncil.org

35 Module 13 | Hacking Web Servers

EC-Council C|EH v13

Finding Exploitable Vulnerabilities with AI (Cont'd)





Copyright © EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit eccouncil.org

Finding Exploitable Vulnerabilities with AI

Attackers can leverage AI-powered technologies to enhance and automate hacking. With the aid of AI, attackers can effortlessly identify potential vulnerabilities and search for exploits associated with them.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

For example,

An attacker can use ChatGPT to perform this task by using an appropriate prompt such as:

"Identify OS and services running on the target 10.10.1.19 and then install and launch the searchsploit to find out the possible exploits associated with OS and services identified"

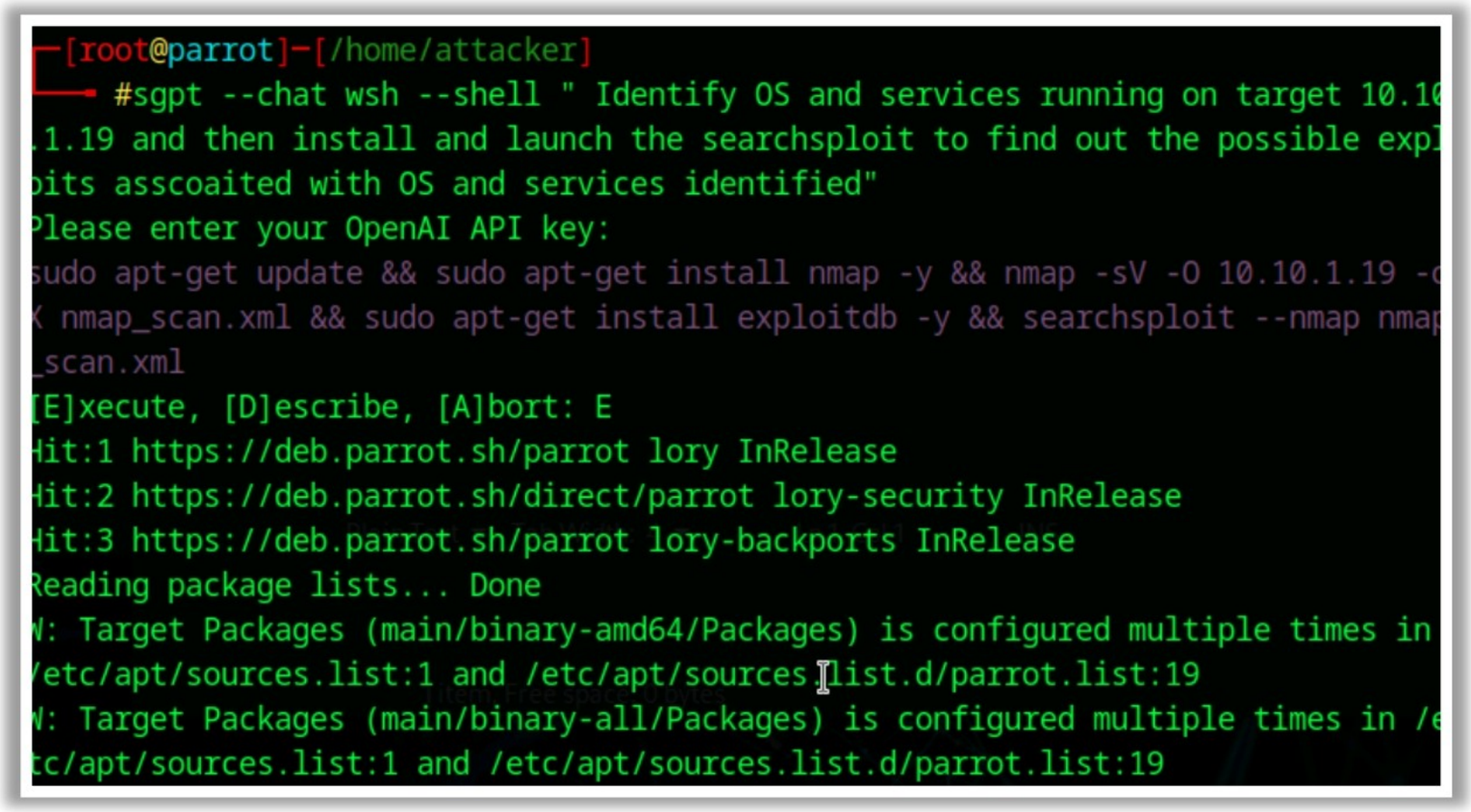


Figure 13. 52: Finding exploits for vulnerabilities with AI

The output of the prompt results in the following command:

`sudo apt-get update && sudo apt-get install nmap -y && nmap -SV-0 10.10.1.19 -oX nmap_scan.xml && sudo apt-get install exploitdb -y && searchsploit-nmap nmap_scan.xml`

- The command first updates the package repository and installs the `nmap` package to perform a scan on the target IP address **`10.10.1.19.`**
- The **`nmap`** command with options **`-SV-0`** is used to perform service-version detection without OS detection on the target IP address, and the results are saved in an XML file named **`nmap_scan.xml.`**
- Next, the script installs the **`exploitdb`** package, which provides the **`search-sploit`** utility for searching for possible exploits associated with the identified services.
- Finally, the **`search-sploit-nmap`** command is used to search for exploits associated with the OS and services identified during the scan.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

```
Host is up (0.00049s latency).
Not shown: 990 filtered tcp ports (no-response)
PORT     STATE SERVICE       VERSION
25/tcp   open  smtp          Microsoft ESMTP 10.0.17763.1
80/tcp   open  http          Microsoft IIS httpd 10.0
135/tcp  open  msrpc         Microsoft Windows RPC
139/tcp  open  netbios-ssn   Microsoft Windows netbios-ssn
445/tcp  open  microsoft-ds?
1801/tcp open  msmq?
2103/tcp open  msrpc         Microsoft Windows RPC
2105/tcp open  msrpc         Microsoft Windows RPC
2107/tcp open  msrpc         Microsoft Windows RPC
3389/tcp open  ms-wbt-server Microsoft Terminal Services
MAC Address: 02:15:5D:33:B8:D1 (Unknown)
Warning: OSScan results may be unreliable because we could not find at least 1 o
pen and 1 closed port
Device type: general purpose
Running (JUST GUESSING): Microsoft Windows 2019 (97%)
Aggressive OS guesses: Microsoft Windows Server 2019 (97%)
No exact OS matches for host (test conditions non-ideal).
Network Distance: 1 hop
```

Figure 13.53: Output of finding exploits for vulnerabilities with AI

```
[i] /usr/bin/searchsploit -t smtp
---------------------------------------------- ----------------------------
 Exploit Title                                |  Path
---------------------------------------------- ----------------------------
AA SMTP Server 1.1 - Crash (PoC)              | windows/dos/14990.txt
Alt-N MDaemon 6.5.1 - IMAP/SMTP Remote Buffer | windows/remote/473.c
Alt-N MDaemon 6.5.1 SMTP Server - Multiple Co | windows/remote/24624.c
Alt-N MDaemon Server 2.71 SP1 - SMTP HELO Arg | windows/dos/23146.c
Apache James Server 2.2 - SMTP Denial of Serv | multiple/dos/27915.pl
BaSoMail 1.24 - SMTP Server Command Buffer Ov | windows/dos/22668.txt
BaSoMail Server 1.24 - POP3/SMTP Remote Denia | windows/dos/594.pl
BL4 SMTP Server < 0.1.5 - Remote Buffer Overf | windows/dos/1721.pl
Blat 2.7.6 SMTP / NNTP Mailer - Local Buffer  | windows/local/38472.py
BulletProof FTP Server 2019.0.0.50 - 'SMTP Se | windows/dos/46422.py
Cisco PIX Firewall 4.x/5.x - SMTP Content Fil | hardware/remote/20231.txt
Citadel SMTP 7.10 - Remote Overflow           | windows/remote/4949.txt
Cobalt Raq3 PopRelayD - Arbitrary SMTP Relay  | linux/remote/20994.txt
CodeBlue 5.1 - SMTP Response Buffer Overflow  | windows/remote/21643.c
CommuniCrypt Mail 1.16 - 'ANSMTP.dll/AQSMTP.d | windows/remote/12663.html
```

Figure 13.54: Output of finding exploits for vulnerabilities with AI

```
[i] /usr/bin/searchsploit -t microsoft esmtp
[-] Skipping term: http   (Term is too general. Please re-search manually: /usr/
bin/searchsploit -t http)

[i] /usr/bin/searchsploit -t microsoft iis httpd
[i] /usr/bin/searchsploit -t msrpc
[i] /usr/bin/searchsploit -t microsoft windows rpc
---------------------------------------------- ----------------------------
 Exploit Title                                |  Path
---------------------------------------------- ----------------------------
Microsoft Windows - 'Lsasrv.dll' RPC Remote B | windows/remote/293.c
Microsoft Windows - 'RPC DCOM' Long Filename  | windows/remote/100.c
Microsoft Windows - 'RPC DCOM' Remote (1)     | windows/remote/69.c
Microsoft Windows - 'RPC DCOM' Remote (2)     | windows/remote/70.c
Microsoft Windows - 'RPC DCOM' Remote (Univer | windows/remote/76.c
Microsoft Windows - 'RPC DCOM' Remote Buffer  | windows/remote/64.c
```

Figure 13.55: Output of finding exploits for vulnerabilities with AI

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

This command automates the process of identifying potential vulnerabilities and searching for associated exploits on the target IP address **10.10.1.19**, enabling attackers to exploit any discovered vulnerabilities for malicious purposes.

Session Hijacking

Valid session IDs can be sniffed to gain unauthorized access to a web server and snoop its data. An attacker can hijack or steal valid session content using various techniques such as session token prediction, session replay, session fixation, sidejacking, and XSS. By using these techniques, the attacker attempts to capture valid session cookies and IDs in established sessions. The attacker uses tools such as Burp Suite, JHijack, and Ettercap to automate session hijacking.

- **Burp Suite**

  Source: *https://portswigger.net*

  Burp Suite is a web security testing tool that can hijack session IDs in established sessions. The Sequencer tool in Burp Suite tests the randomness of session tokens. With this tool, an attacker can predict the next possible session ID token and use that to take over a valid session.

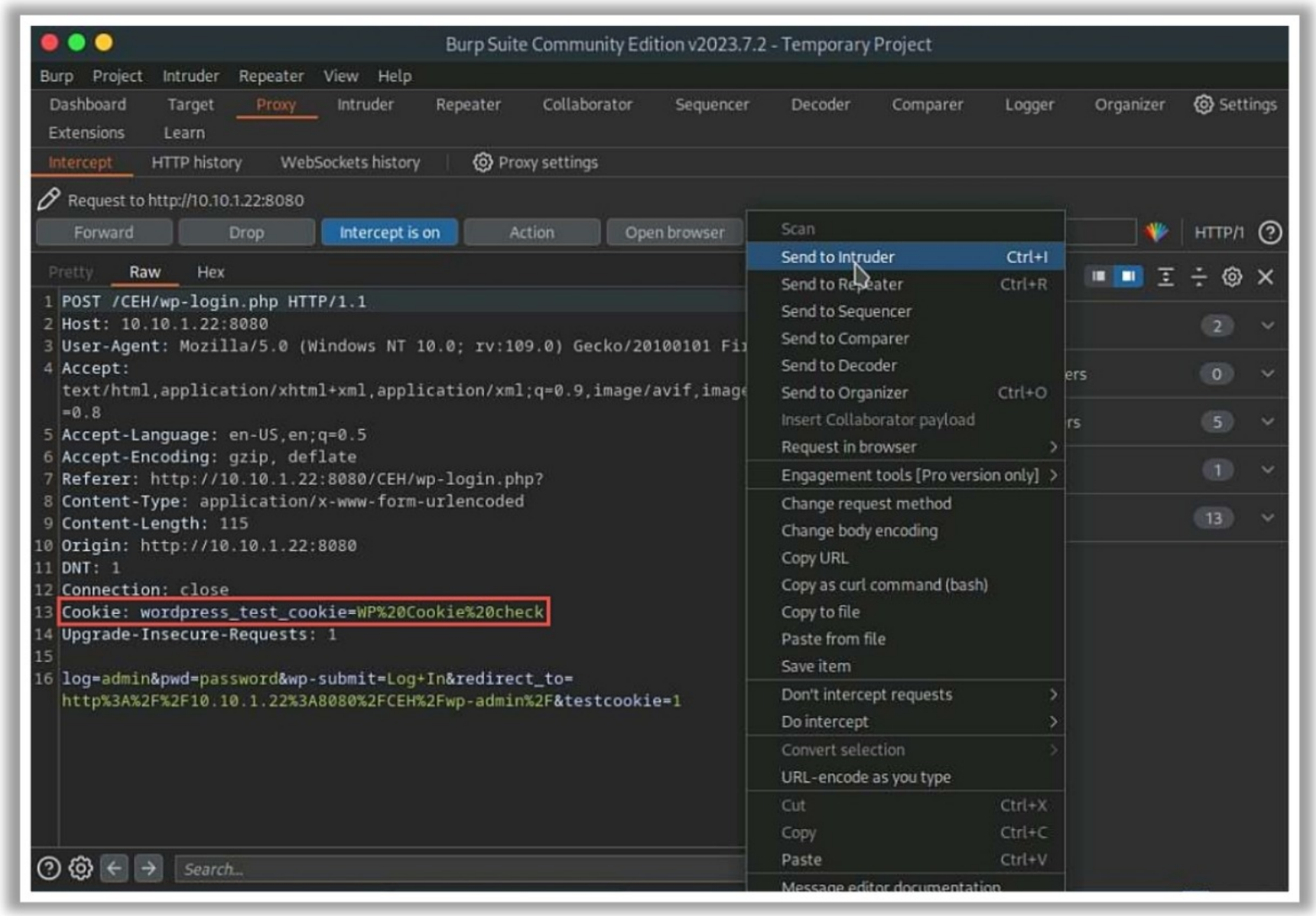


Figure 13.56: Screenshot of Burp Suite

The following are some additional session hijacking tools:

- JHijack (*https://sourceforge.net*)
- Ettercap (*https://www.ettercap-project.org*)

Note: For complete coverage of concepts and techniques related to session hijacking, refer to Module 11: Session Hijacking.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Web Server Password Hacking

In this phase of web server hacking, an attacker attempts to crack web server passwords. The attacker may employ all possible techniques of password cracking to extract passwords, including password guessing, dictionary attacks, brute-force attacks, hybrid attacks, precomputed hashes, rule-based attacks, distributed network attacks, and rainbow attacks. The attacker needs patience to crack passwords because some of these techniques are tedious and time-consuming. The attacker can also use automated tools such as Hashcat, THC Hydra, and Ncrack to crack web passwords and hashes.

- **Hashcat**

  Source: *https://hashcat.net*

  Hashcat is a cracker compatible with multiple OSs and platforms and can perform multi-hash (MD4, 5; SHA – 224, 256, 384, 512; RIPEMD-160; etc.), multi-device password cracking. The attack modes of this tool are straight, combination, brute force, hybrid dict + mask, and hybrid mask + dict.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

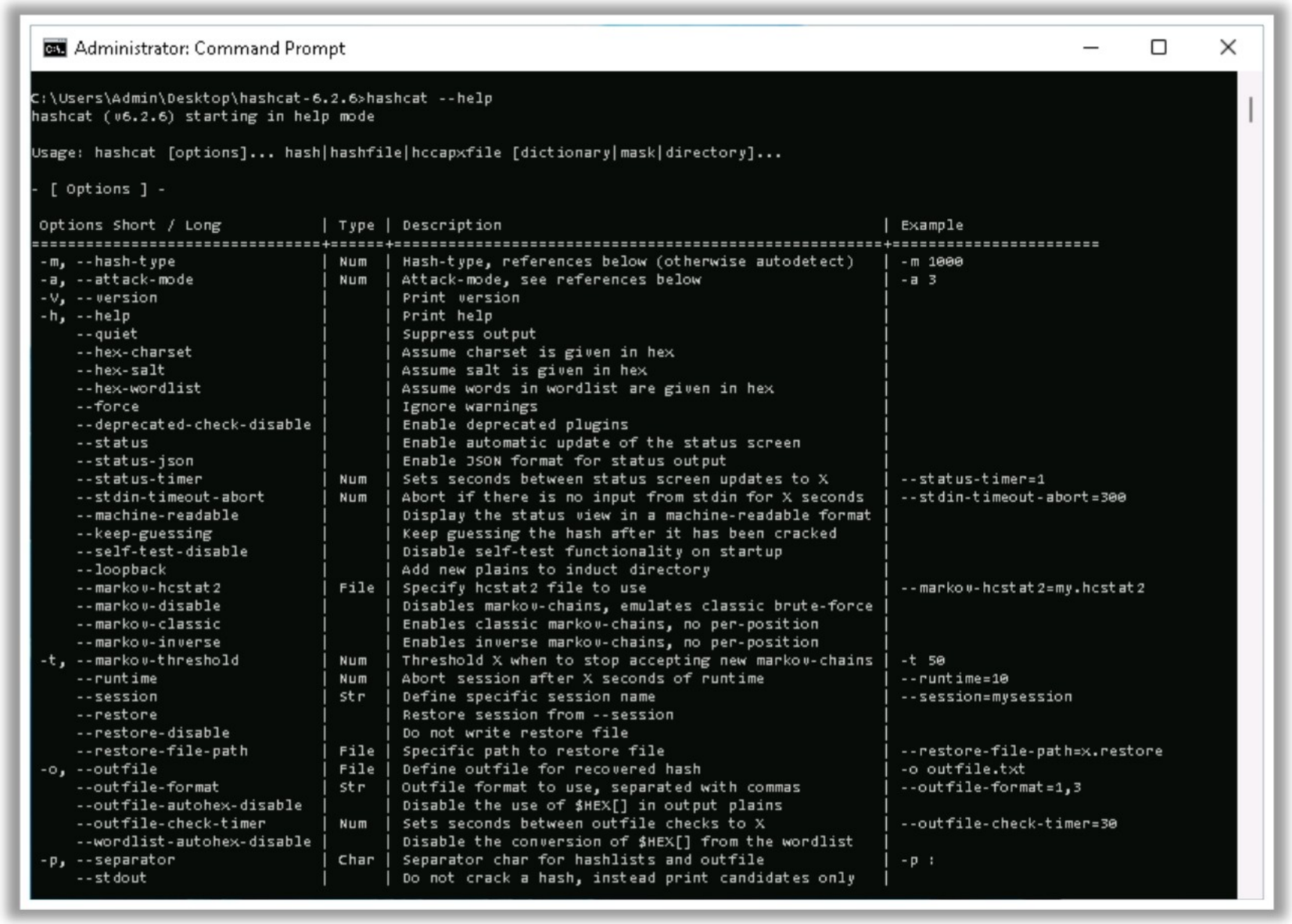


Figure 13.57: Screenshot of Hashcat password cracker

- **THC Hydra**

  Source: *https://github.com*

  THC Hydra is a parallelized login cracker that can attack numerous protocols. This tool is a proof-of-concept code that provides researchers and security consultants the possibility to demonstrate how easy it would be to gain unauthorized remote access to a system.

  Currently, this tool supports the following protocols: Asterisk; Apple Filing Protocol (AFP); Cisco Authentication, Authorization, and Accounting (AAA); Cisco auth; Cisco enable; Concurrent Versions System (CVS); Firebird; FTP; HTTP-FORM-GET; HTTP-FORM-POST; HTTP-GET; HTTP-HEAD; HTTP-POST; HTTP-PROXY; HTTPS-FORM-GET; HTTPS-FORM-POST; HTTPS-GET; HTTPS-HEAD; HTTPS-POST; HTTP-Proxy; ICQ; Internet Message Access Protocol (IMAP); Internet Relay Chat (IRC); Lightweight Directory Access Protocol (LDAP); Memcached; MongoDB; Microsoft SQL Server; MySQL; Network Control Protocol (NCP); Network News Transfer Protocol (NNTP); Oracle Listener; Oracle system identifier (SID); Oracle; PC-Anywhere; personal computer Network File System (PC-NFS); POP3; Postgres; Radmin; Remote Desktop Protocol (RDP); Rexec; Rlogin; Rsh; Real Time Streaming Protocol (RTSP); SAP R/3; Session Initiation Protocol (SIP); Server Message Block (SMB); Simple Mail Transfer Protocol (SMTP); SMTP Enum; Simple Network Management Protocol (SNMP) v1+v2+v3; SOCKS5; SSH (v1 and v2); SSH key; Subversion; TeamSpeak (TS2); Telnet; VMware-Auth; Virtual Network Computing (VNC); and Extensible Messaging and Presence Protocol (XMPP).

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

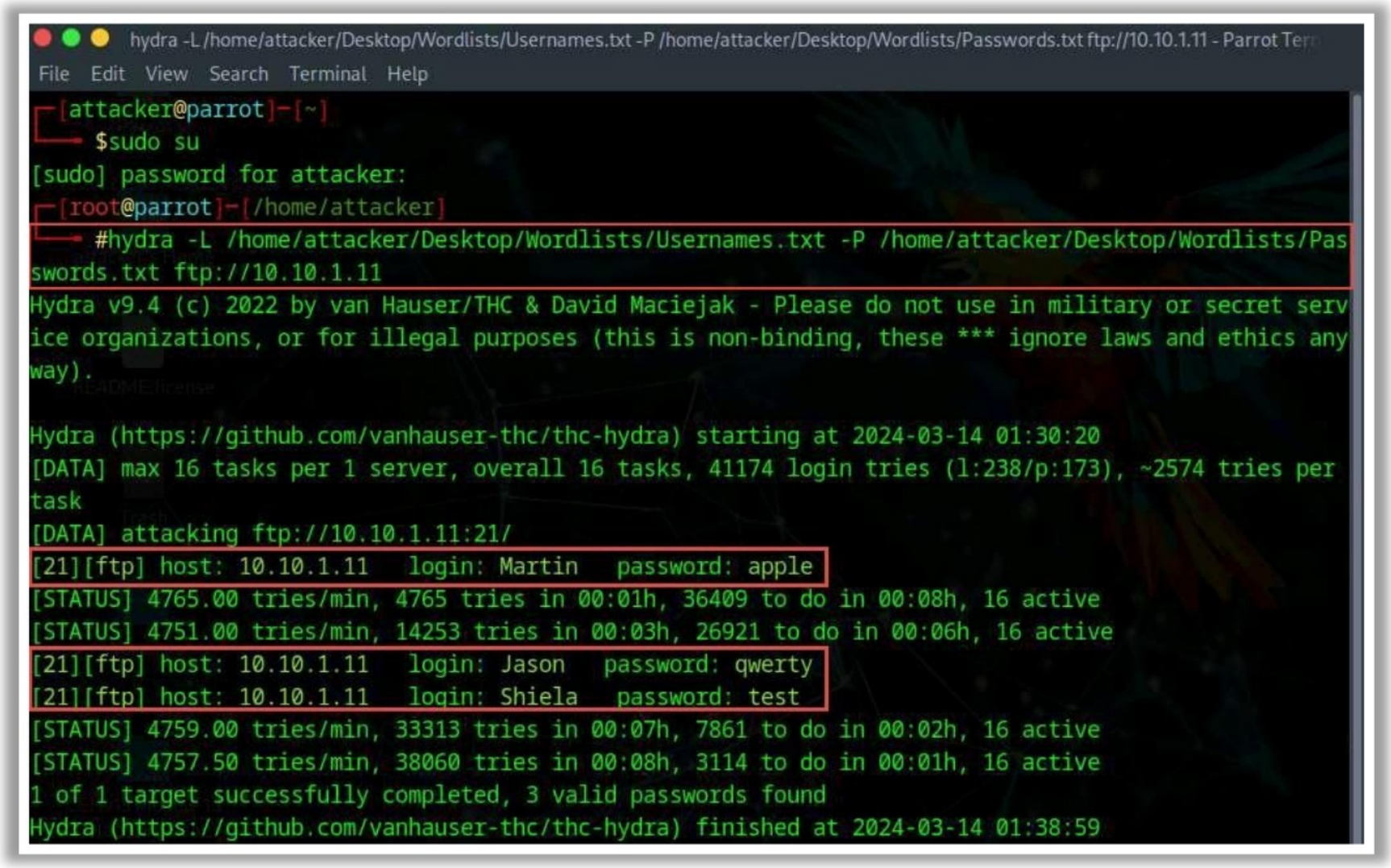


Figure 13.58: Screenshot of THC Hydra password cracker

The following are some additional password cracking tools:

- Ncrack (*https://nmap.org*)
- Rainbow crack (*https://project-rainbowcrack.com*)
- Wfuzz (*http://www.edge-security.com*)
- Wireshark (*https://www.wireshark.org*)

Using Application Server as a Proxy

Web servers are occasionally configured to perform functions such as forwarding or reverse HTTP proxy. Web servers with these functions enabled are employed by attackers to perform the following attacks:

- Attacking third-party systems on the Internet
- Connecting to arbitrary hosts on the organization's internal network
- Connecting back to other services running on the proxy host itself

Attackers use GET and CONNECT requests to use vulnerable web servers as proxies to connect to and obtain information from target systems through these web servers.

Figure 13.59: Illustration of the use of an application server as a proxy

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Path Traversal via Misconfigured NGINX Alias

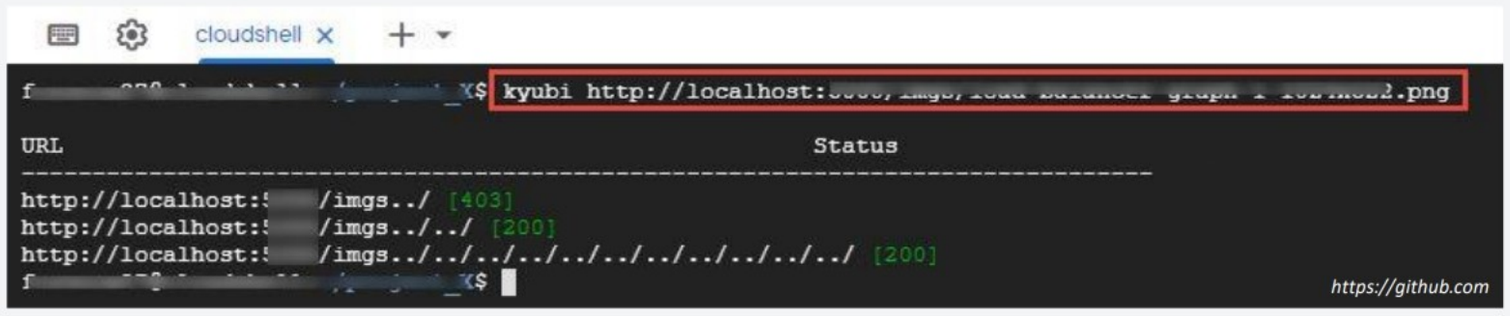
- An attacker can exploit a misconfiguration in the nginx.conf file of a targeted Nginx web server, specifically involving improper usage of the alias directive.

  Webroot misconfiguration in nginx.conf file:

  ```
  location /i {
      alias /data/w3/images/;
  }
  ```

  Lack of a trailing slash allows attackers to manipulate the URL to access directories and files outside the designated Webroot

Using Kyubi for Exploitation:



Copyright © EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit eccouncil.org

Path Traversal via Misconfigured NGINX Alias

An attacker can exploit a misconfiguration in the nginx.conf file of a targeted Nginx web server, specifically involving the improper usage of the alias directive. This vulnerability arises when an alias directive is used without a trailing slash, as demonstrated in the following configuration example:

Webroot Misconfiguration in nginx.conf File

```
location /i {
    alias /data/w3/images/;
}
```

In this scenario, the lack of a trailing slash allows attackers to manipulate the URL to access directories and files outside the designated Webroot. By appending paths such as "../", attackers can traverse the file system to restricted areas, exposing sensitive data or system files.

Exploiting This Vulnerability Using Kyubi

Source: *https://github.com*

Kyubi is a Python-based security tool designed to identify and exploit path-traversal vulnerabilities in Nginx web servers caused by misconfigured alias directives. Kyubi automates the process of testing URL paths for potential traversal problems.

Run the following command to scan for misconfigurations/vulnerabilities:

```
kyubi -v <target_URL>
```


Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

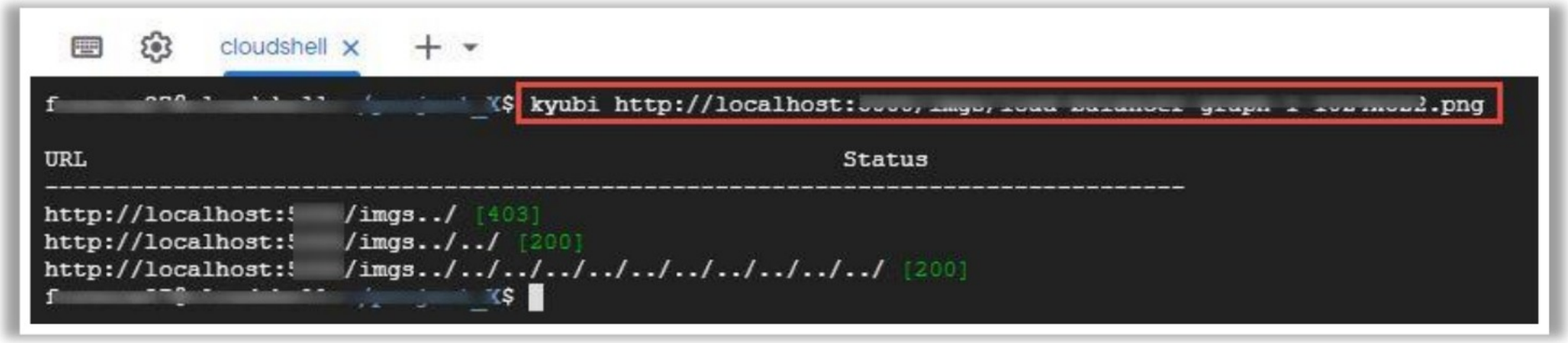


Figure 13.60: Screenshot of Kyubi detecting potential files or directories

Kyubi recursively brute forces the URL path to detect and list files or directories that are potentially exposed owing to misconfigurations.

Exploiting this misconfiguration allows attackers to access sensitive files outside the Webroot, including configuration files and credentials. This can lead to severe consequences such as data theft, website defacement, and even total web server compromise.

Web Server Attack Tools

- **Immunity's** CANVAS

  Source: *https://www.immunityinc.com*

  Immunity's CANVAS provides penetration testers and security professionals with hundreds of exploits, an automated exploitation system, and a comprehensive, reliable exploit development framework. It provides features such as client-side exploitation, privilege escalation, HTTP tunneled privilege escalation, remote kernel exploitation, advanced backdoor technology, and advanced web attack technology.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

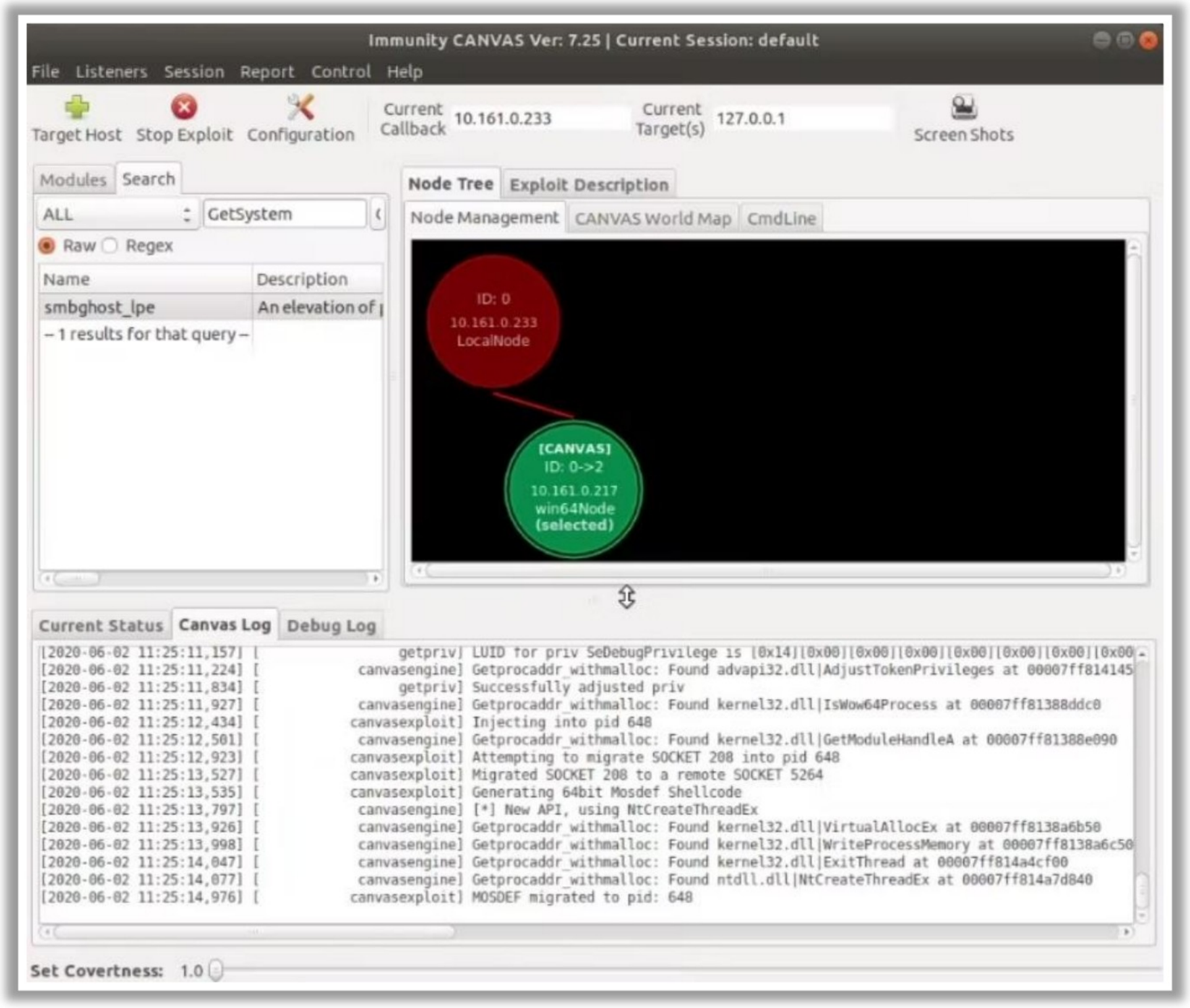
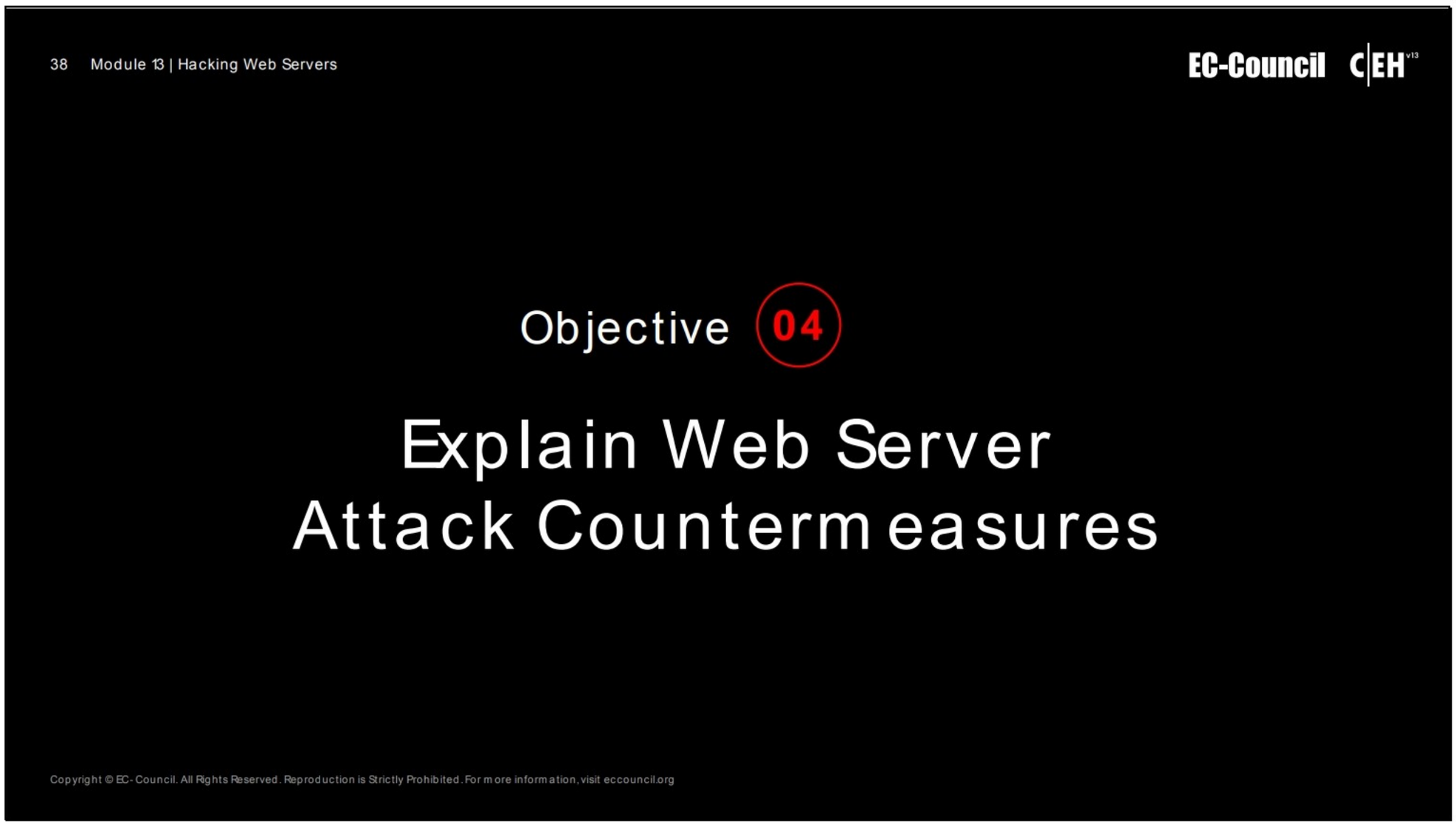


Figure 13.61: Screenshot of Immunity CANVAS

The following are some additional web server attack tools:

- OpenVAS (*https://www.openvas.org*)
- THC Hydra (*https://github.com*)
- HULK DoS (*https://github.com*)
- MPack (*https://sourceforge.net*)

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.



Web Server Attack Countermeasures

In previous sections, we discussed the benefits of a well-informed web server security posture, the danger posed by web server attacks, the methodology used in web server attacks, and the tools that assist an attacker in performing web server attacks. In this section, we discuss the tools and techniques used for securing web servers. This section also discusses various methods to detect web server attacks, countermeasures, and defense techniques.

Further, this section describes common security tools to secure a web server against possible attacks. These tools scan for vulnerabilities in a target server and web applications, send alerts in the case of hacking attempts, scan for malware in the web server, and perform other security assessment activities.

Place Web Servers in Separate Secure Server Security Segment on Network

An ideal web hosting network should be designed with three segments: an Internet segment; a secure server security segment, which is often called the demilitarized zone (DMZ); and an internal network. The first step in securing web servers is to place them separately in the DMZ, which is isolated from the public network and from the internal web-hosting network. Placing web servers in a separate segment adds security barriers between the web servers and the internal network as well as between the web servers and the outside public network. This separation allows the administrator to place firewalls and apply access control based on security rules for the internal network as well as for Internet traffic toward the DMZ. Such a web-hosting network can prevent attacks on the web server by outside attackers or malicious insiders.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Network segmentation divides a network into different segments, each having its own hub or switch. It allows network administrators to protect one segment from others by enforcing firewalls and security rules depending on the level of security desired. In a segmented network, an attacker who compromises one segment of the network will not be able to compromise the security of other segments of the network. Let us example a sample web-hosting network that is segmented by the administrator in such a manner that the web server is placed in a DMZ.

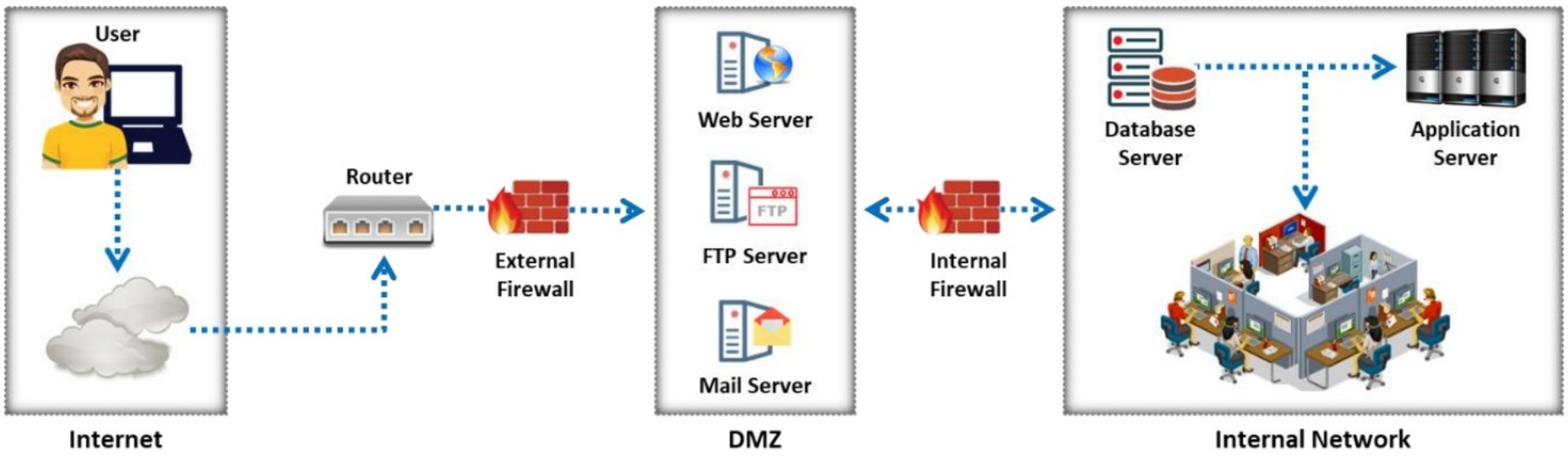
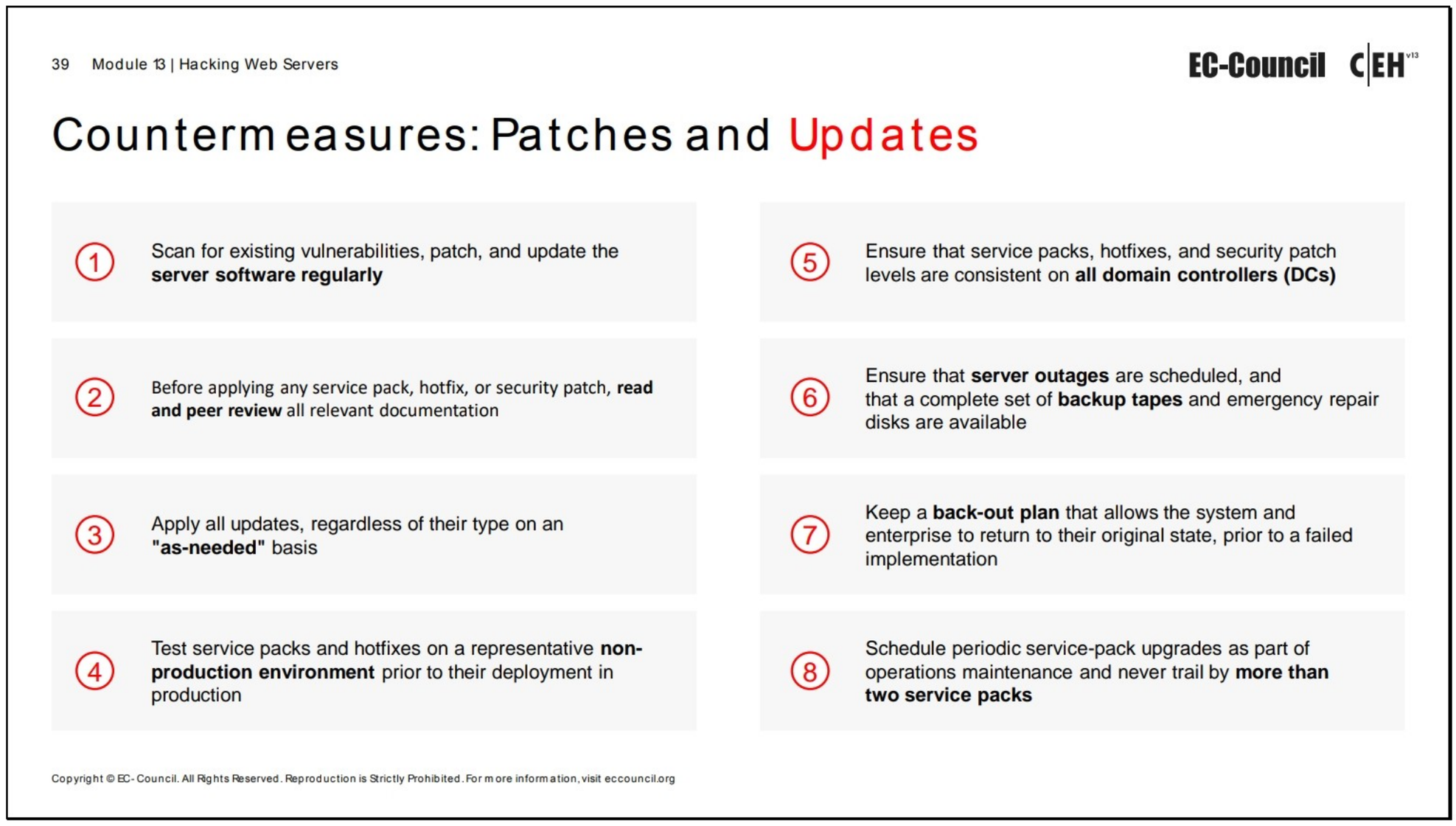


Figure 13.62: Illustration of three different segments in a web-hosting network

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.



Countermeasures: Patches and Updates

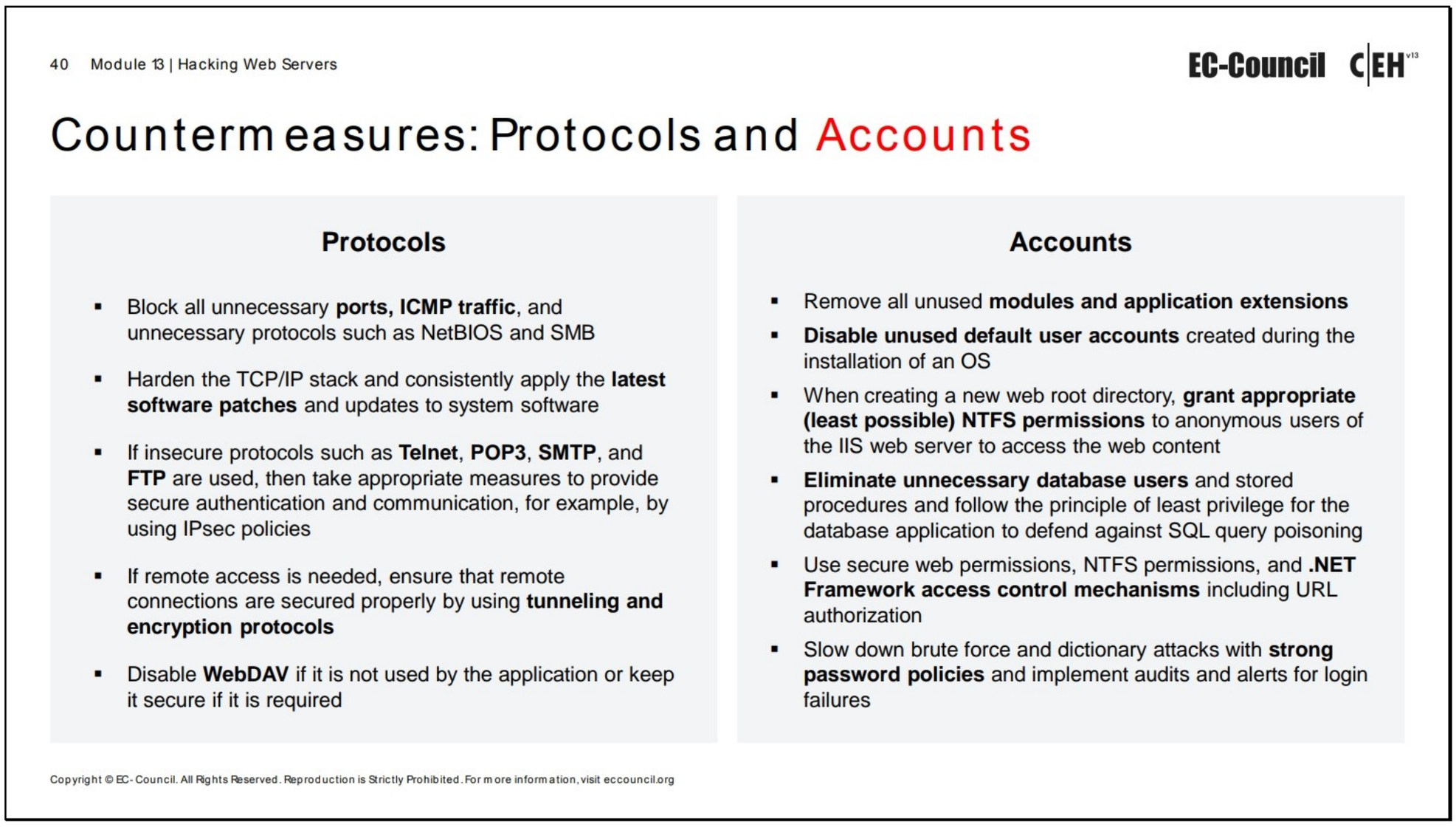
The following are various countermeasures for secure update and patch management of web servers:

- Scan for existing vulnerabilities; patch and update the server software regularly.
- Before applying any hotfix, or security patch, read and peer review all relevant documentation.
- Apply all updates, regardless of their type, on an “as-needed” basis.
- Test service packs and hotfixes on a representative non-production environment prior to their deployment in production.
- Ensure that hotfixes, and security patch levels are consistent on all domain controllers (DCs).
- Ensure that server outages are scheduled and that a complete set of backup tapes and emergency repair disks are available.
- Keep a back-out plan that allows the system and enterprise to return to their original state, prior to a failed implementation.
- Disable all unused script extension mappings.
- Avoid using default configurations dispatched with web servers.
- Use virtual patches in the organization because they provide additional identification/logging capabilities.
- Establish a disaster recovery plan to handle patch management failures.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

- Conduct an extensive risk assessment to determine which segments of the network are most vulnerable or at high risk that need to be patched first.
- Make a detailed inventory of all the endpoints, services, and dependencies.
- While deploying a patch to the full system, ensure that it is performed in testing environment first.
- Deploy an alerting system for patches.
- Use a patch management application or system such as SolarWinds Patch Manager to automate the procedure.
- Regularly conduct monitoring and reporting to ensure your patch management processes and updates are performing effectively.
- Reduce your exposure to third-party risks by limiting the number of software versions you employ.
- All patch and update operations should be validated and documented for accessibility, analysis, and confirmation.
- Make a standardized patch management and security update methodology as part of the SDLC.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.



Countermeasures: Protocols and Accounts

Countermeasures: Protocols

The following are various countermeasures for using secure protocols on web servers:

- Block all unnecessary ports, ICMP traffic, and unnecessary protocols.
- Harden the TCP/IP stack and consistently apply the latest software patches and updates to system software.
- If insecure protocols such as Telnet, SMTP, and FTP are used, then take appropriate measures to provide secure authentication and communication, for example, by using IPsec policies.
- If remote access is needed, ensure that remote connections are secured properly by using tunneling and encryption protocols.
- Use secure protocols such as Transport Layer Security (TLS)/SSL for communicating with the web server.
- Ensure that unidentified FTP servers operate in an innocuous part of the directory tree that is different from the web server's tree.
- Ensure that the HTTP service banner is properly configured to cover the details of the host device like OS version and type.
- Isolate the supporting servers such as LDAP servers from the local subnet to filter out the traffic through a firewall before entering the local network.
- Ensure that all the file transfer applications through the web server are done through FTPS for better data encryption and protection.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

- Redirect all HTTP traffic to HTTPS to ensure data is encrypted in transit.
- Use HSTS headers to force browsers to use secure connections, preventing downgrade attacks.
- Automate the renewal process for SSL/TLS certificates to avoid the use of expired certificates.
- Implement rate-limiting to mitigate DDoS attacks that target the SSL/TLS handshake process.

Countermeasures: Accounts

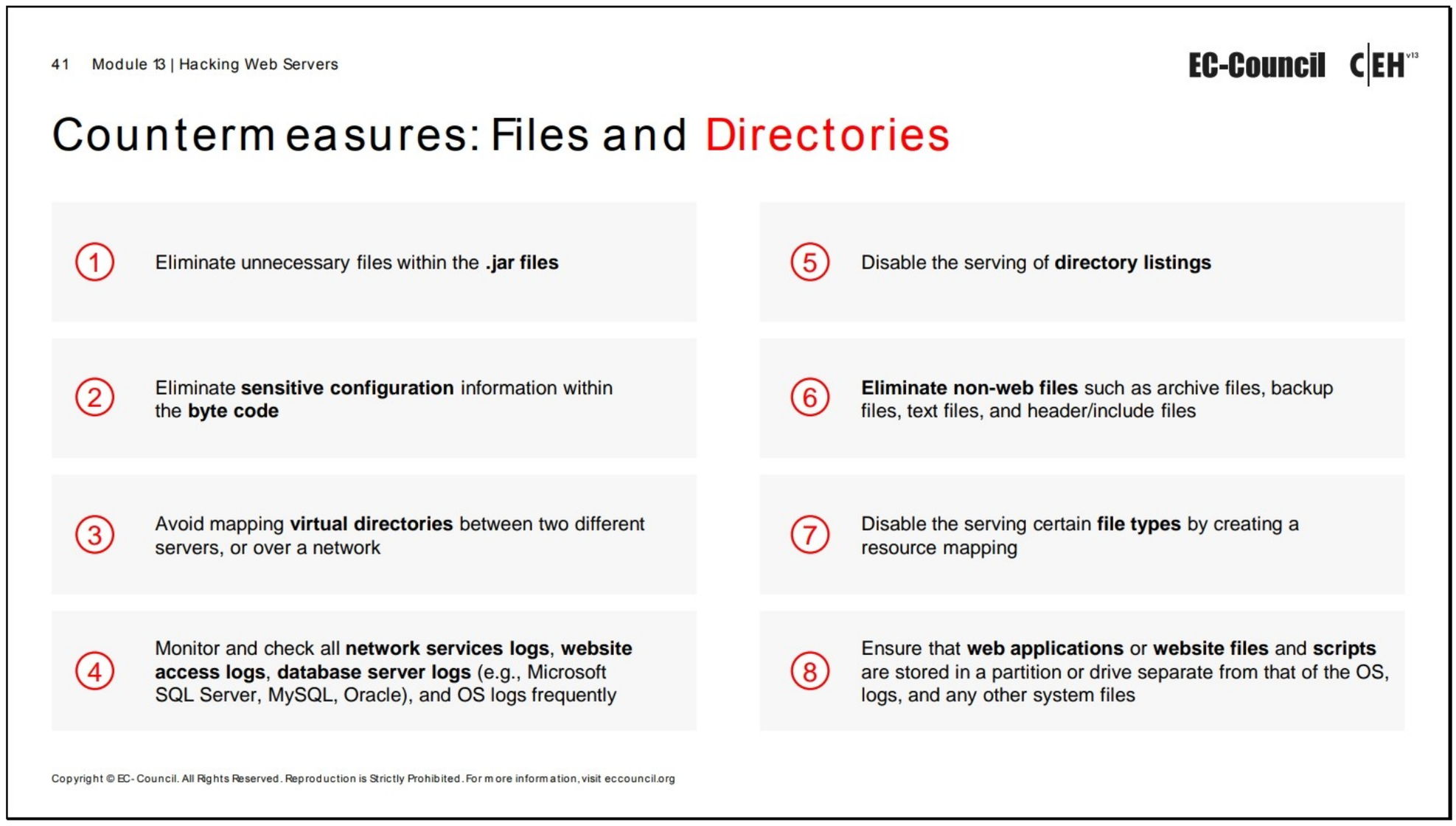
The following countermeasures can be adopted to secure user accounts on a web server:

- Remove all unused modules and application extensions.
- Disable unused default user accounts created during the installation of an OS.
- When creating a new web root directory, grant the appropriate (least possible) NTFS permissions to anonymous users of the IIS web server to access the web content.
- Eliminate unnecessary database users and stored procedures and follow the principle of least privilege for the database application to defend against SQL query poisoning.
- Use secure web permissions, NTFS permissions, and .NET Framework access control mechanisms, including URL authorization.
- Slow down brute-force and dictionary attacks with strong password policies and implement audits and alerts for login failures.
- Run processes using least privileged accounts as well as least privileged services and user accounts.
- Limit the administrator or root-level access to the minimum number of users and maintain a record of the same.
- Maintain logs of all user activity in an encrypted form on the web server or in a separate machine on the intranet.
- Disable all noninteractive accounts that should exist but do not require an interactive login.
- Use secure VPN networks such as OpenVPN while accessing multi-server platforms or accessing data from cross-server network models, which helps use one account for multiple server access.
- Use password managers such as KeePass to maintain a proper password policy for multiple user accounts.
- Enable the Separation of Duties (SoD) feature on the server config settings.
- Force users to periodically change passwords for their accounts by creating a password expiry policy.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

- Enable the user account locking feature by setting a limit on the number of failed login attempts.
- Implement 2FA or MFA as an additional layer of security for user accounts.
- Use CAPTCHA challenges on login and registration pages to prevent automated bot attacks.
- Use security questions with unpredictable answers as an additional authentication factor or for account recovery.
- Use strong, one-way hashing algorithms such as bcrypt, scrypt, or Argon2 to securely store passwords.
- Design secure account recovery processes that verify a user's identity without exposing the account to takeover risks.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.



Countermeasures: Files and Directories

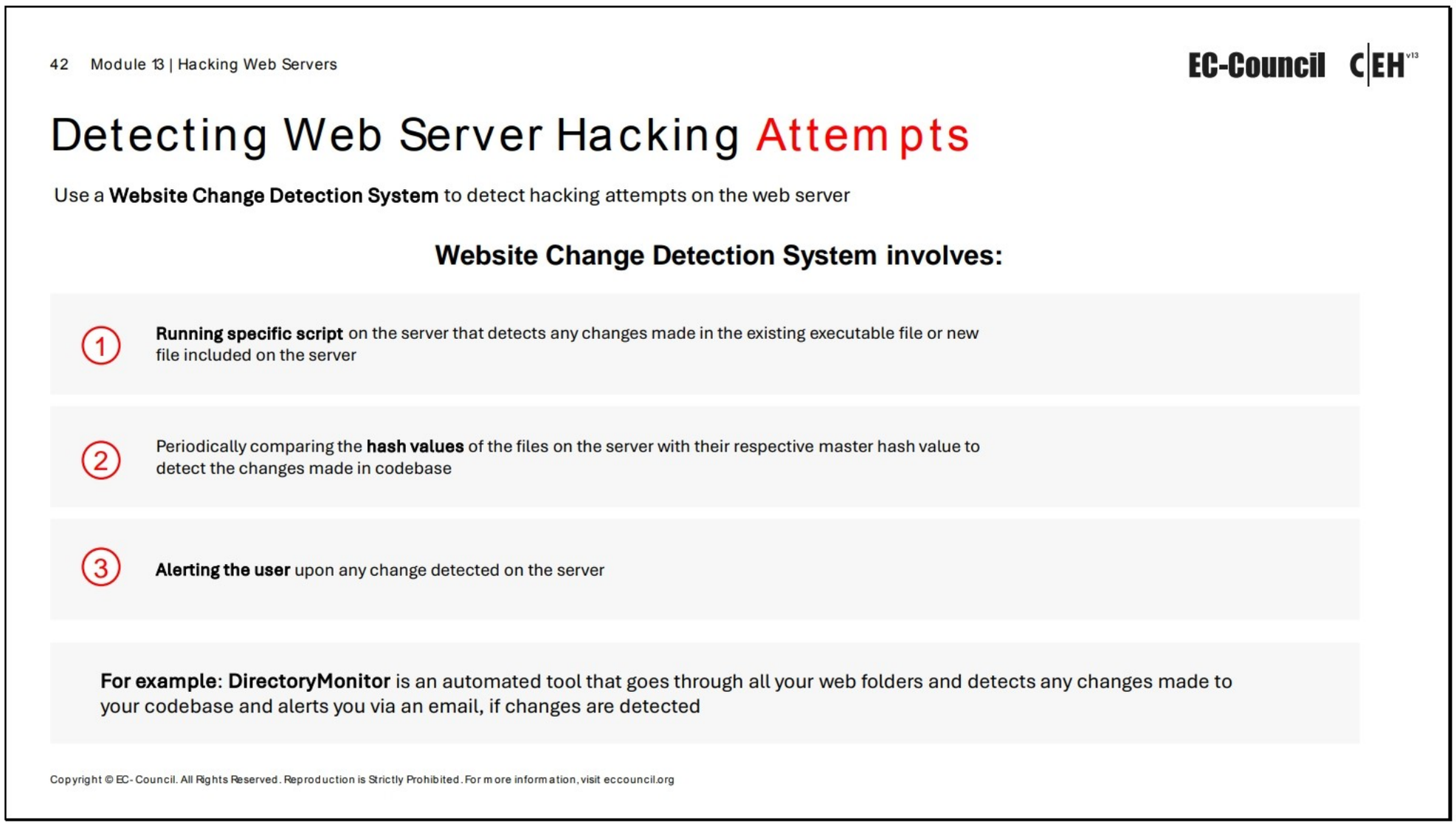
The following countermeasures can be adopted for securing files and directories on a web server:

- Eliminate unnecessary files within .jar files.
- Eliminate sensitive configuration information within the byte code.
- Avoid mapping virtual directories between two different servers or over a network.
- Monitor and check all network services logs, website access logs, database server logs (e.g., Microsoft SQL Server, MySQL, and Oracle), and OS logs frequently.
- Disable the serving of directory listings.
- Eliminate non-web files such as archive files, backup files, text files, and header/include files.
- Disable the serving of certain file types by creating a resource map.
- Ensure that web applications or website files and scripts are stored in a partition or drive separate from that of the OS, logs, and any other system files.
- Run the web server within a sandbox directory for preventing access to system files.
- Avoid all non-web file types from being referenced in a URL.
- Run the web server processes with the least required privileges and give access only to the necessary directories.
- Exclude meta characters while processing user inputs to ensure proper filtering of inputs.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

- Employ file integrity checkers to verify web content and intrusion detection.
- If an application allows file uploads, the uploaded files are scanned for malware and stored outside the web root.
- Use WAF to protect against common web-based attacks such as SQL injection, which can lead to unauthorized file access.
- Use SFTP instead of FTP to encrypt file transfers.
- Ensure that the configuration files (e.g., .htaccess, web.config) are secure and not accessible from the Web.
- Implement version control for web application files to track changes and revert to previous versions if necessary.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.



Detecting Web Server Hacking Attempts

An attacker who gains access to a web server by compromising security through known vulnerabilities present in the web server may attempt to plant backdoors (scripts). These backdoors allow the attacker to gain access, launch phishing attacks, or send spam emails. The victim remains unaware of the web server attack until the server is blacklisted on spam mails or until the attacker redirects the visitors of a target site hosted on the web server to some other site. Thus, a web server attack is difficult to detect unless such malicious events occur. By the time these events occur, it may be too late to react because the attacker would have already succeeded. Therefore, a mechanism to detect a web server hacking attempt in its early stages is required to prevent harm to the web server.

When an attacker installs a backdoor on a web server, the size of files infected with the backdoor automatically increases. A website change detection system (WDS) is a script that runs on the server to detect changes made to any executable file or the presence of any new file on the web server, such as HTML, JavaScript (JS), PHP, Active Server Pages (ASP), Perl, and Python files. It works by periodically comparing the hash values of the files on the server with their respective master hash values to detect any changes to the codebase. If it detects any change on the server, it alerts the user to take necessary action. Thus, WDS helps in detecting web server hacking attempts in the early stages of an attack. For example, DirectoryMonitor is an automated tool that goes through entire web folders, detects any changes made to the codebase, and alerts the user through an email.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

How to Defend against Web Server Attacks

Ports

- Regularly audit the ports on the server to ensure that an **insecure** or unnecessary service is not active on your web server
- Limit inbound traffic to **port 80 for HTTP** and **port 443 for HTTPS** (SSL)
- Encrypt or restrict **intranet traffic**

Server Certificates

- Ensure that **certificate data ranges** are valid and that the certificates are used for their intended purpose
- Ensure that no certificate has been revoked and the **certificate's public key** is valid all the way to a trusted root authority

Machine.config

- Ensure that protected resources are mapped to **HttpForbiddenHandler** and unused **HttpModules** are removed
- Ensure that **tracing is disabled** <trace enable="false"/> and **debug compiles** are turned off

Code Access Security

- Implement **secure coding** practices
- Restrict **code access security policy** settings
- **Configure IIS** to reject URLs with "../" and install new patches and updates

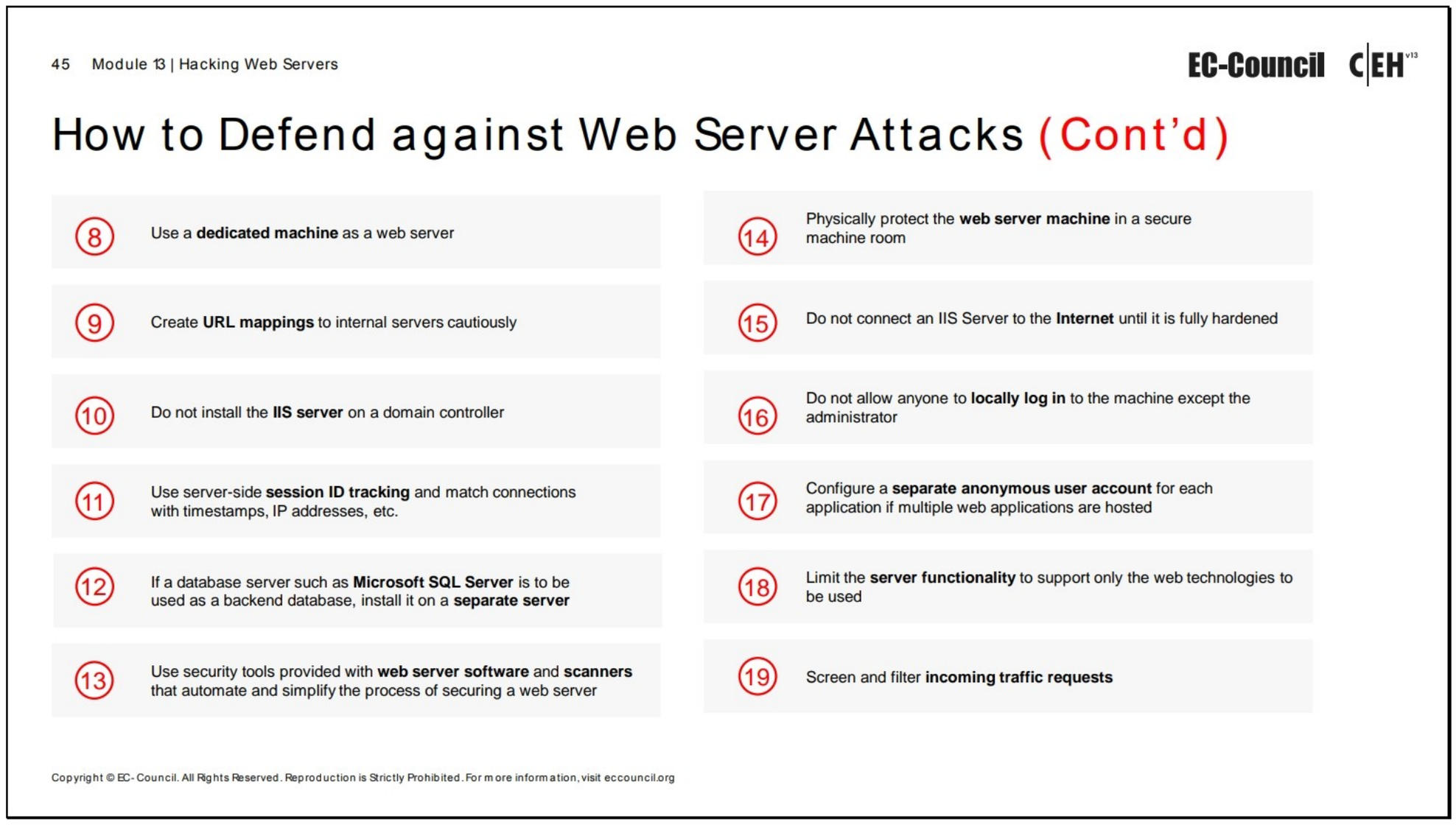
Copyright © EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit eccouncil.org

How to Defend against Web Server Attacks (Cont'd)

1. Apply **restricted ACLs** and block remote registry administration
   - Secure the **SAM** (Stand-alone servers only)
2. Ensure that security-related settings are **configured appropriately** and that access to the metabase file is restricted with hardened **NTFS permissions**
3. **Remove** unnecessary ISAPI filters from the web server
4. Remove all unnecessary file shares, including the **default administration shares**, if they are not required
   - Secure the shares with restricted **NTFS permissions**
5. Relocate sites and virtual directories to **non-system partitions** and use IIS web permissions to restrict access
6. Remove all unnecessary **IIS script mappings** for optional file extensions to avoid exploitation of any bugs in the ISAPI extensions that handle these types of files
7. Enable a **minimum level of auditing** on the web server and use NTFS permissions to protect log files

Copyright © EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit eccouncil.org

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.



How to Defend against Web Server Attacks

Defenses against web server attacks include the following.

- **Ports**

  Monitor all ports on the web server regularly to prevent unnecessary traffic toward the target web server. If traffic is not monitored, the target web server will be vulnerable to malware attacks. Do not allow public access to port 80 for HTTP or to port 443 for HTTPS; traffic to these ports should be limited. If port 80 is kept open, the server will be vulnerable to DoS attacks, which consume server resources. Intranet traffic should either be encrypted or restricted to secure the web server.

  Attackers attempt to hide their identity by spoofing the IP address of a legitimate user. By processing the security log file, either using the "deny this IP address" rule in the firewall ruleset file or by creating a "routed blackhole" command, the target system can defend against web server attacks.

- **Server Certificates**

  Server certificates guarantee security and are signed by a trusted authority. However, an attacker may compromise certified servers using forged certificates to intercept secure communications by performing MITM attacks. There are various techniques to avoid such MITM attacks. The following are some of them.

  - Use the direct validation of certificates.
  - Use a novel protocol that does not depend on third parties for certificate validation.
  - Allow domains to directly and securely examine their certificates by using previously established user authentication credentials.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

- Use a robust cryptographic construction that enhances server identity validation and resolves the limitations of third-party solutions.
- Ensure that the certificate data ranges are valid and that certificates are used for their intended purpose.
- Ensure that the certificate has not been revoked and that the certificate's public key is valid all the way to a trusted root authority.

- **Machine.config**

  The machine.config file provides a mechanism of securing information by changing machine-level settings. It affects all other applications. The machine.config file includes machine settings for the .Net framework, which affect the security. The following can be performed with the machine.config file:

  - Ensure that protected resources are mapped to HttpForbiddenHandler and that unused HttpModules are removed
  - Ensure that tracing is disabled <trace enable="false"/> and debug compiles are turned off
  - Verify that ASP.NET errors are not reverted to the client
  - Verify session state settings

- **Code Access Security**

  The following measures can be adopted to ensure code access security.

  - Implement secure coding practices to avoid source-code disclosure and input validation attacks.
  - Restrict code access security policy settings to ensure that there are no permissions to execute code downloaded from the Internet or intranet.
  - Configure IIS to reject URLs with "../" to prevent path traversal, lockdown system commands and utilities with restrictive access control lists (ACLs), and install new patches and updates.
  - If targets do not implement code access security in their web servers, then there is a possibility of execution of malicious code.

The following are some other measures to defend against web server attacks:

- Apply restricted ACLs and block remote registry administration.
- Secure the SAM (stand-alone servers only).
- Ensure that security-related settings are configured appropriately and that access to the metabase file is restricted with hardened NTFS permissions.
- Remove unnecessary Internet Server Application Programming Interface (ISAPI) filters from the web server.

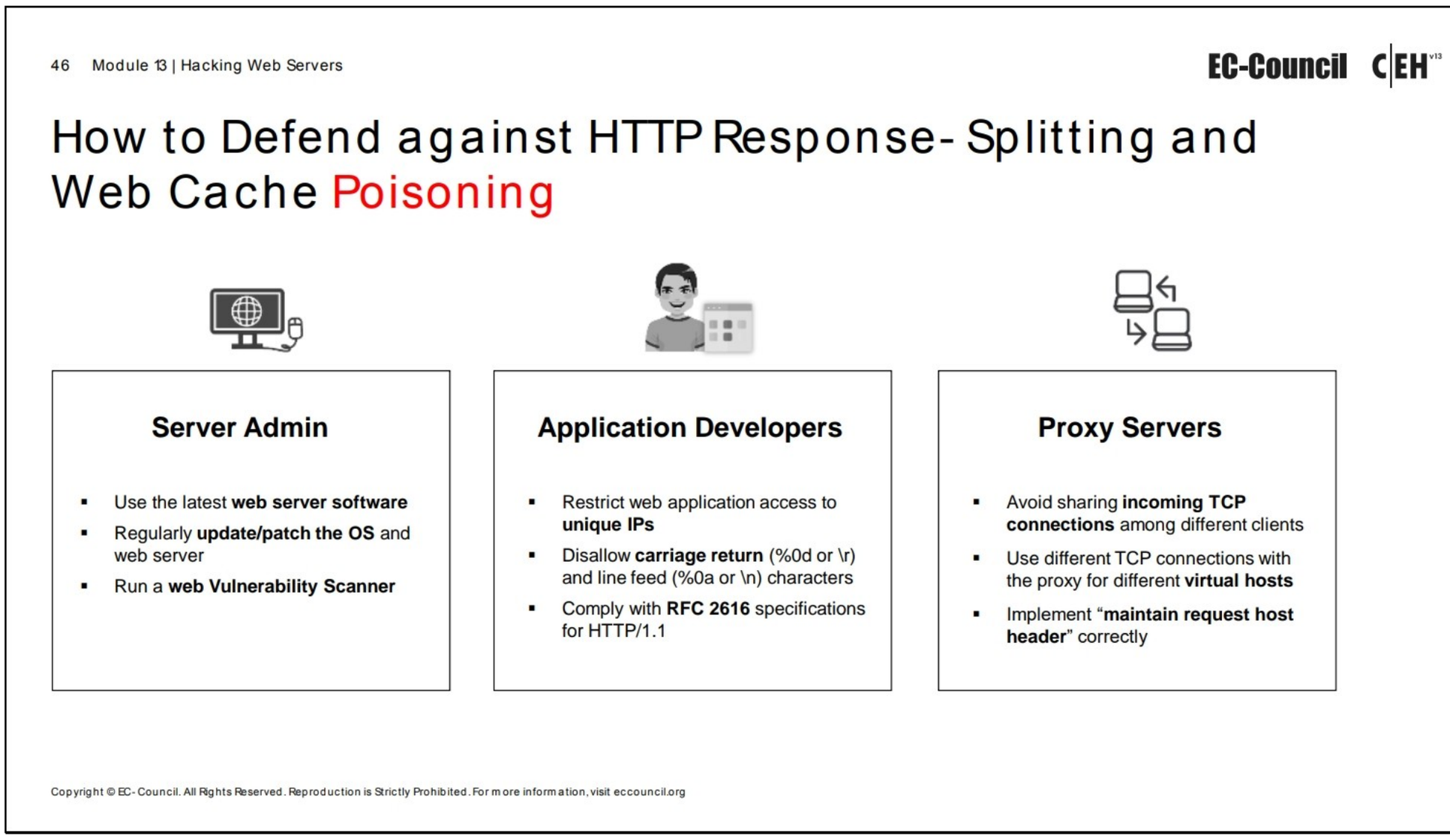
Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

- Remove all unnecessary file shares, including the default administration shares, if they are not required.
- Secure the shares with restricted NTFS permissions.
- Relocate sites and virtual directories to non-system partitions and use IIS web permissions to restrict access.
- Remove all unnecessary IIS script mappings for optional file extensions to avoid exploitation of any bugs in the ISAPI extensions that handle these types of files.
- Enable a minimum level of auditing on the web server and use NTFS permissions to protect log files.
- Use a dedicated machine as a web server.
- Create URL mappings to internal servers cautiously.
- Do not install the IIS server on a domain controller.
- Use server-side session ID tracking and match connections with timestamps, IP addresses, etc.
- If a database server such as Microsoft SQL Server is to be used as a backend database, install it on a separate server.
- Use security tools provided with web server software and scanners that automate and simplify the process of securing a web server.
- Physically protect the web server machine in a secure machine room.
- Do not connect an IIS Server to the Internet until it is fully hardened.
- Do not allow anyone to locally log in to the machine except the administrator.
- Configure a separate anonymous user account for each application if multiple web applications are hosted.
- Limit the server functionality to support only the web technologies to be used.
- Screen and filter incoming traffic requests.
- Implement firewalls to control incoming and outgoing network traffic based on security rules.
- Store website files and scripts on a separate partition or drive.
- Use an effective anti-bot mitigation service such as DataDome to detect botnets in real time.
- Use network segmentation, VPNs, and secure protocols (such as HTTPS) to limit unauthorized access and ensure encrypted communication.
- Implement role-based access control (RBAC) and the principle of least privilege to minimize the risk of unauthorized access.
- Deploy IDPS to monitor network traffic and detect unusual or malicious activity.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

- Implement centralized log monitoring to track server and application activities. Analyze logs for signs of suspicious behavior.
- Set up alerts for security events and establish an incident response plan to address security incidents promptly.
- Restrict directory listings and enforce proper file permissions to prevent unauthorized access to sensitive files.
- Turn off unused features, such as server-side scripting or directory browsing, to reduce potential attack vectors.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.



How to Defend against HTTP Response-Splitting and Web Cache Poisoning

While setting cookies, remove carriage returns (CRs) and linefeeds (LFs) before inserting data into an HTTP response header. The best practice is to use third-party products to test for the existence of security holes and defend against CRLF injection. Ensure that data application engines are up to date.

The User Datagram Protocol (UDP) source port randomization technique defends servers against blind response forgery. Limit the number of simultaneous recursive queries and increase the times-to-live (TTLs) of legitimate records.

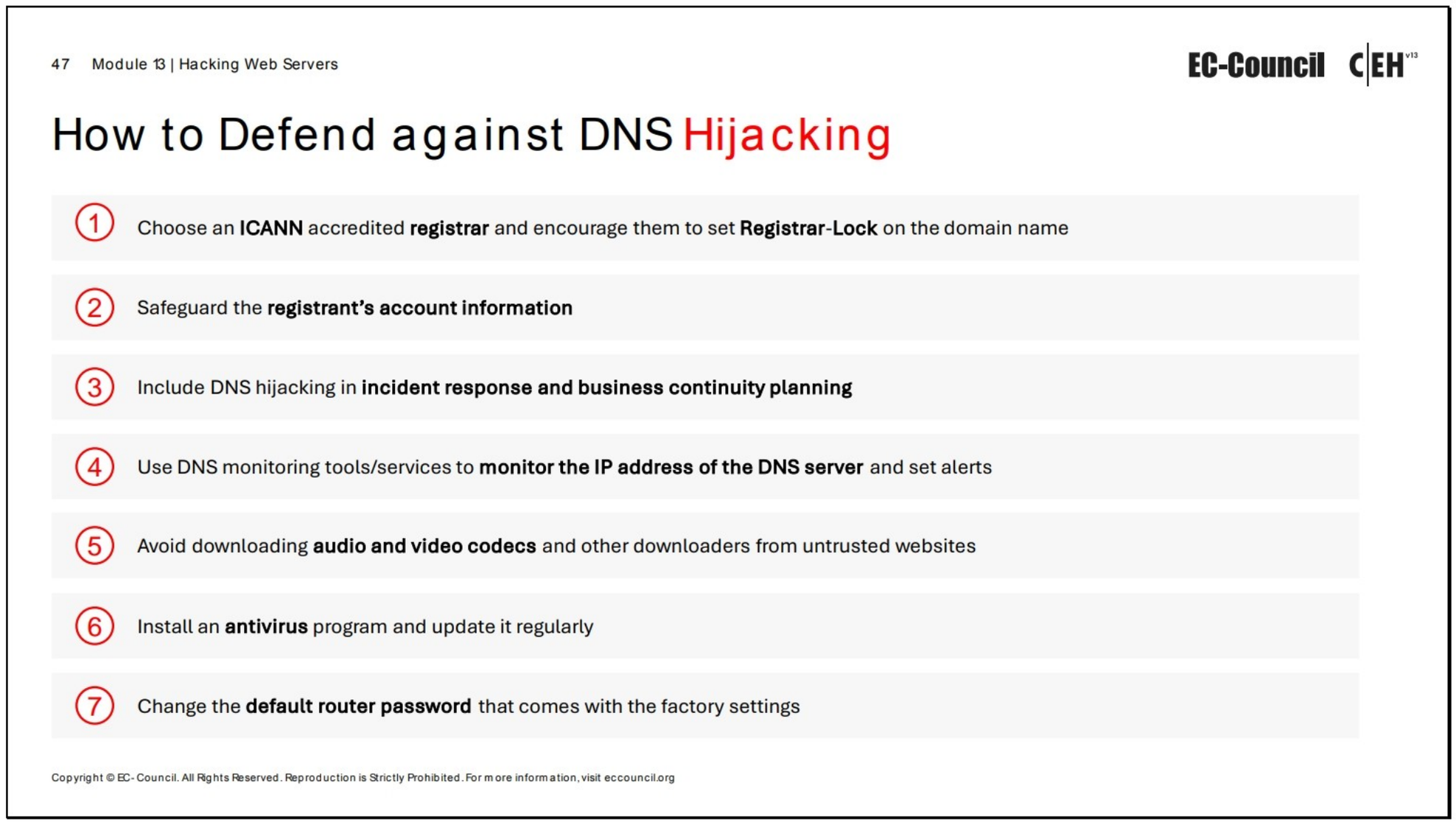
The following are some methods to defend against HTTP response-splitting attacks and web cache poisoning:

- **Server Admin**
  - Use the latest web server software
  - Regularly update/patch the OS and web server
  - Run a web vulnerability scanner
- **Application Developers**
  - Restrict the web application's access to unique IPs
  - Disallow CR (%0d or \r) and LF (%0a or \n) characters
  - Comply with RFC 2616 specifications for HTTP/1.1
  - Parse all user inputs or other forms of encoding before using them in HTTP headers

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

- **Proxy Servers**
  - Avoid sharing incoming TCP connections among different clients
  - Use different TCP connections with the proxy for different virtual hosts
  - Implement "maintain request host header" correctly

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.



How to Defend against DNS Hijacking

The following techniques can be used to defend against DNS hijacking:

- Choose a registrar accredited by the Internet Corporation for Assigned Names and Numbers (ICANN) and encourage them to set REGISTRAR-LOCK on the domain name.
- Safeguard the registrant's account information.
- Include DNS hijacking in incident response and business continuity planning.
- Use DNS monitoring tools/services to monitor the IP address of the DNS server and set alerts.
- Avoid downloading audio and video codecs and other downloaders from untrusted websites.
- Install an antivirus program and update it regularly.
- Change the default router password.
- Restrict zone transfers and use script blockers in the browser.
- **Domain Name System Security Extensions (DNSSEC)**: It adds an extra layer to DNS that prevents it from being hacked.
- **Strong password policies and user management**: The use of strong passwords further enhances security.
- **Better service-level agreements (SLAs) from DNS service providers**: When signing up for DNS servers with DNS service providers, learn who to contact when an issue occurs, how to receive good-quality reception and support, and whether the DNS server's infrastructure is hardened against attacks.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

- **Configuring a master–slave DNS within your network**: Use a master–slave DNS and configure the master without Internet access. Maintain two slave servers so that even if an attacker hacks a slave, it will update only when it receives an update from the master.
- **Constant monitoring of DNS servers**: The constant monitoring of DNS servers ensures that a domain name returns the correct IP address.
- **Ensure router safety**: Change the default username and password of the router. Keep the firmware up-to-date for ensuring safety from new vulnerabilities.
- **Use VPN service**: Establish virtual private network (VPN)-encrypted tunnels for secure private communication over the Internet. This feature protects messages from eavesdropping and unauthorized access.
- Use firewall protection services to safeguard the original DNS resolvers and filter out the rogue DNS resolver traffic.
- Maintain proper protection systems such as MFA and hardware security to ensure controlled access to the DNS server.
- Install script blocker extensions in the browser.
- Use only secured and reputed VPN networks instead of free VPN services, which can track your activities and record them for future use.
- Use ACLs to restrict who can query DNS servers, thereby reducing the risk of malicious queries leading to hijacking.
- Enable DNS over HTTPS (DoH) or DNS over TLS (DoT) to encrypt DNS queries, preventing attackers from intercepting or redirecting them.
- Use geolocation verification to detect and alert unusual access patterns to DNS management interfaces.
- Implement strict access controls for DNS server management using multifactor authentication (MFA) and role-based access control (RBAC).
- Restrict access to DNS servers based on a predefined list of trusted IP addresses.
- Use DNS filtering services or secure DNS providers (such as Cloudflare and Google Public DNS) that offer built-in security against malicious domains.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Web Application Security Scanners

- **Syhunt Hybrid**

  Source: *https://www.syhunt.com*

  The Syhunt Hybrid scanner automates web application security testing and guards the organization's web infrastructure against web application security threats. Syhunt Dynamic crawls websites and detects XSS, directory transversal problems, fault injection, SQL injection, attempts to execute commands, and several other attacks. Syhunt Hybrid creates signatures to detect application vulnerabilities and prevents logout. It analyzes JavaScript (JS), logs suspicious responses, and tests errors for review.

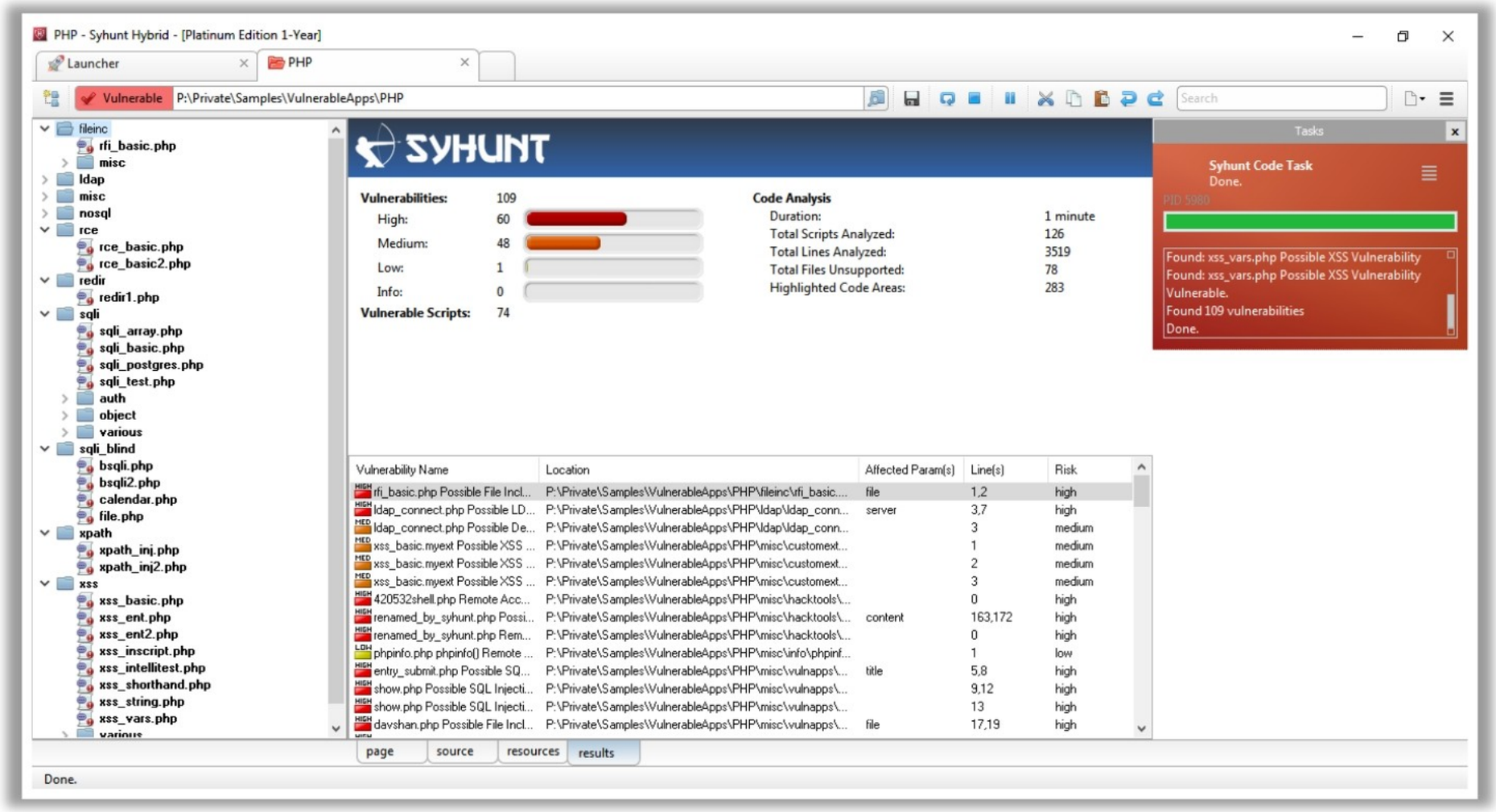


Figure 13.63: Screenshot of Syhunt Hybrid web application security scanner

- **N-Stalker X**

  Source: *https://www.nstalker.com*

  N-Stalker is a web application security scanner that searches for vulnerabilities to attacks such as clickjacking, SQL injection, and XSS. It allows spider crawling throughout the application and the creation of web macros for form authentication. It also provides proxy capabilities for "drive-thru" attacks and identifies components through reverse proxies that distribute different platforms in the same application URL.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

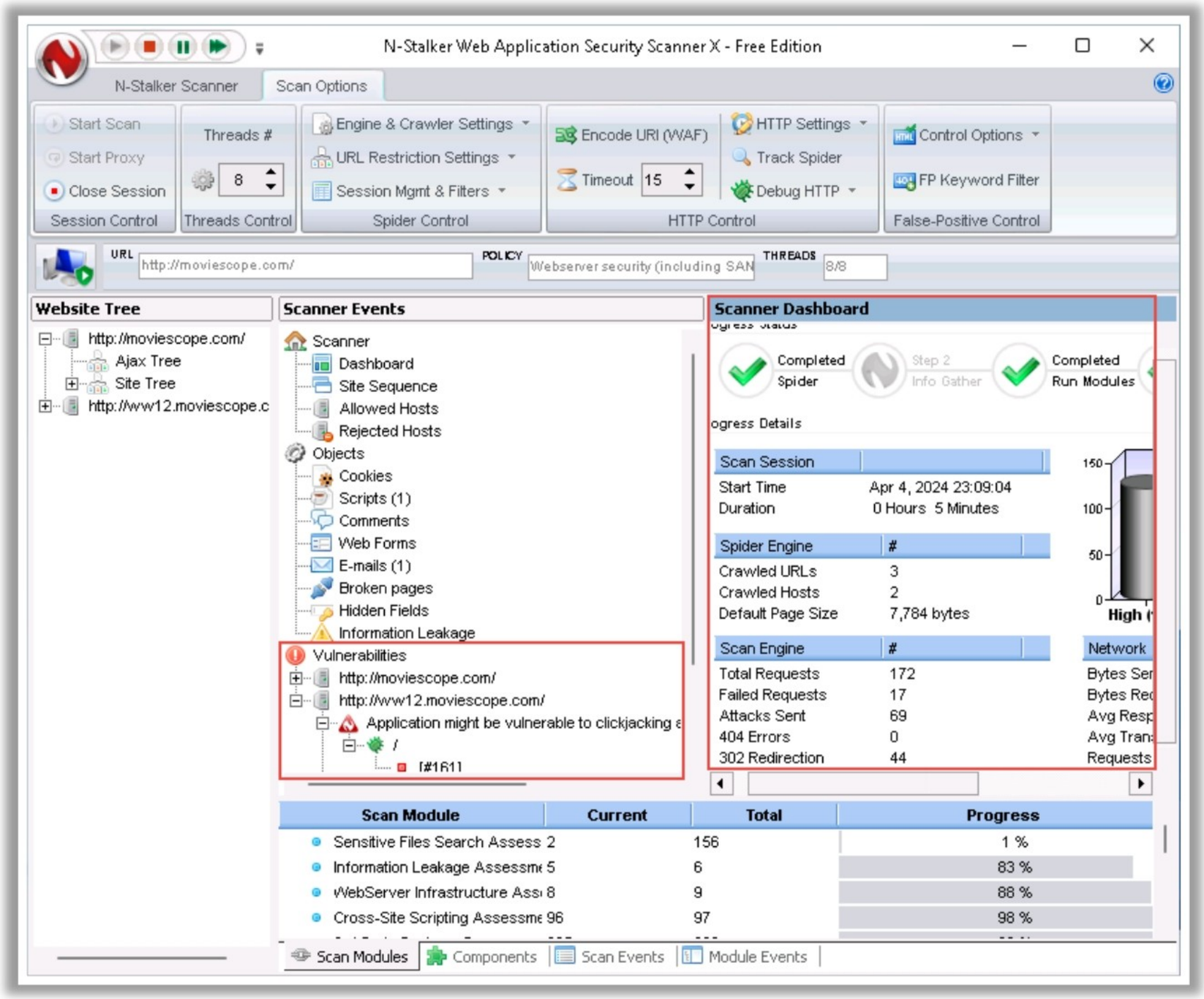


Figure 13.64: Screenshot of N-Stalker X

The following are some additional web application security scanners:

- Invicti (*https://www.invicti.com*)
- Burp Suite (*https://www.portswigger.net*)
- Wapiti (*https://wapiti-scanner.github.io*)
- WebScarab (*https://owasp.org*)
- WPSec (*https://wpsec.com*)
- Tinfoil Web Scanner (*https://www.tinfoilsecurity.com*)
- Skipfish (*https://code.google.com*)
- Detectify (*https://detectify.com*)
- OpenText™ Fortify™ On Demand (*https://www.opentext.com*)
- OWASP Zed Attack Proxy (ZAP) (*https://www.zaproxy.org*)
- SonarQube (*https://www.sonarqube.org*)
- Arachni (*https://ecsypno.com*)

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Web Server Security Scanners

- **Qualys Community Edition**

  Source: *https://www.qualys.com*

  Qualys Community Edition discovers IT assets, manages vulnerabilities, scans web applications, and maintains cloud assets inventory. It offers vulnerability management to identify dangerous bugs and remediate them immediately. Qualys can also assess vulnerabilities on all internal IT infrastructure as well as external-facing assets to ensure a secure state.

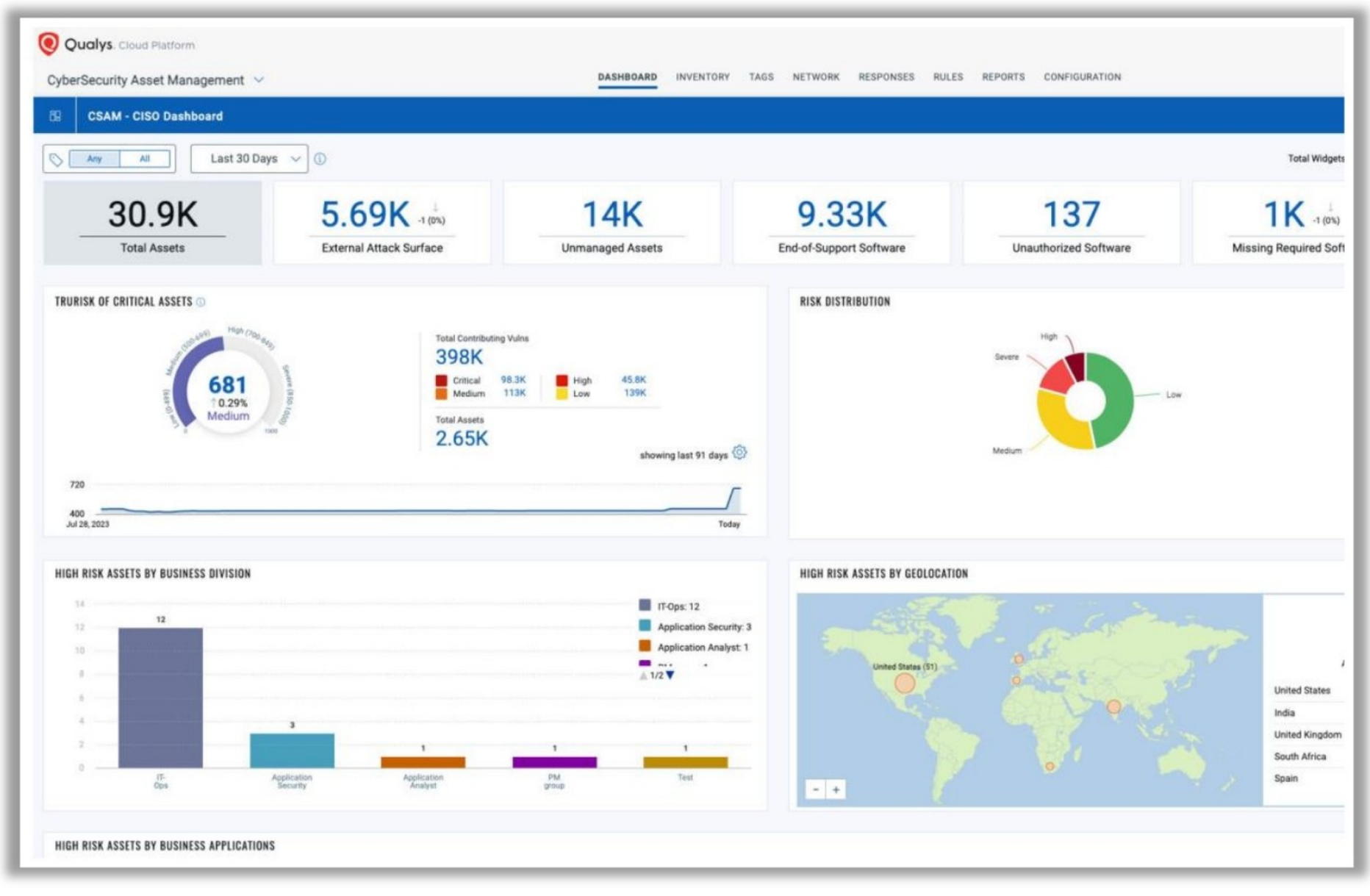


Figure 13.65: Screenshot of Qualys Community Edition

The following are some additional web server security scanners:

- Observatory (*https://observatory.mozilla.org*)
- WordPress Security Scan (*https://hackertarget.com*)
- Web Vulnerability Scanner (*https://pentest-tools.com*)
- Nikto (*https://cirt.net*)
- ImmuniWeb (*https://www.immuniweb.com*)

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Web Server Malware Infection Monitoring Tools

- **QualysGuard Malware Detection**

  Source: *https://www.qualys.com*

  QualysGuard Malware Detection allows organizations to proactively scan their websites for malware and provides automated alerts and in-depth reporting to enable prompt identification and resolution. It enables organizations to protect their customers from malware infections and safeguard their brand reputation.

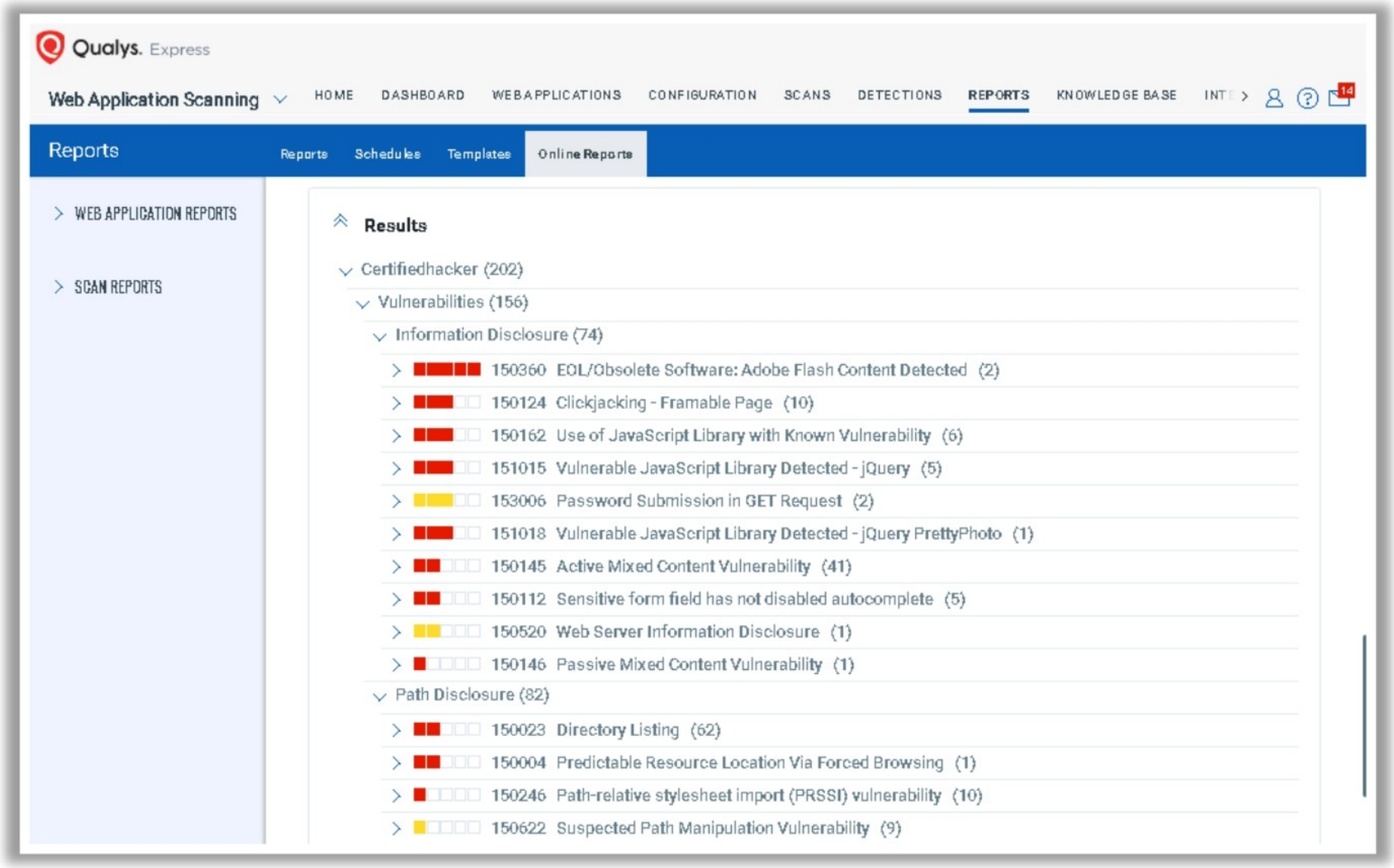
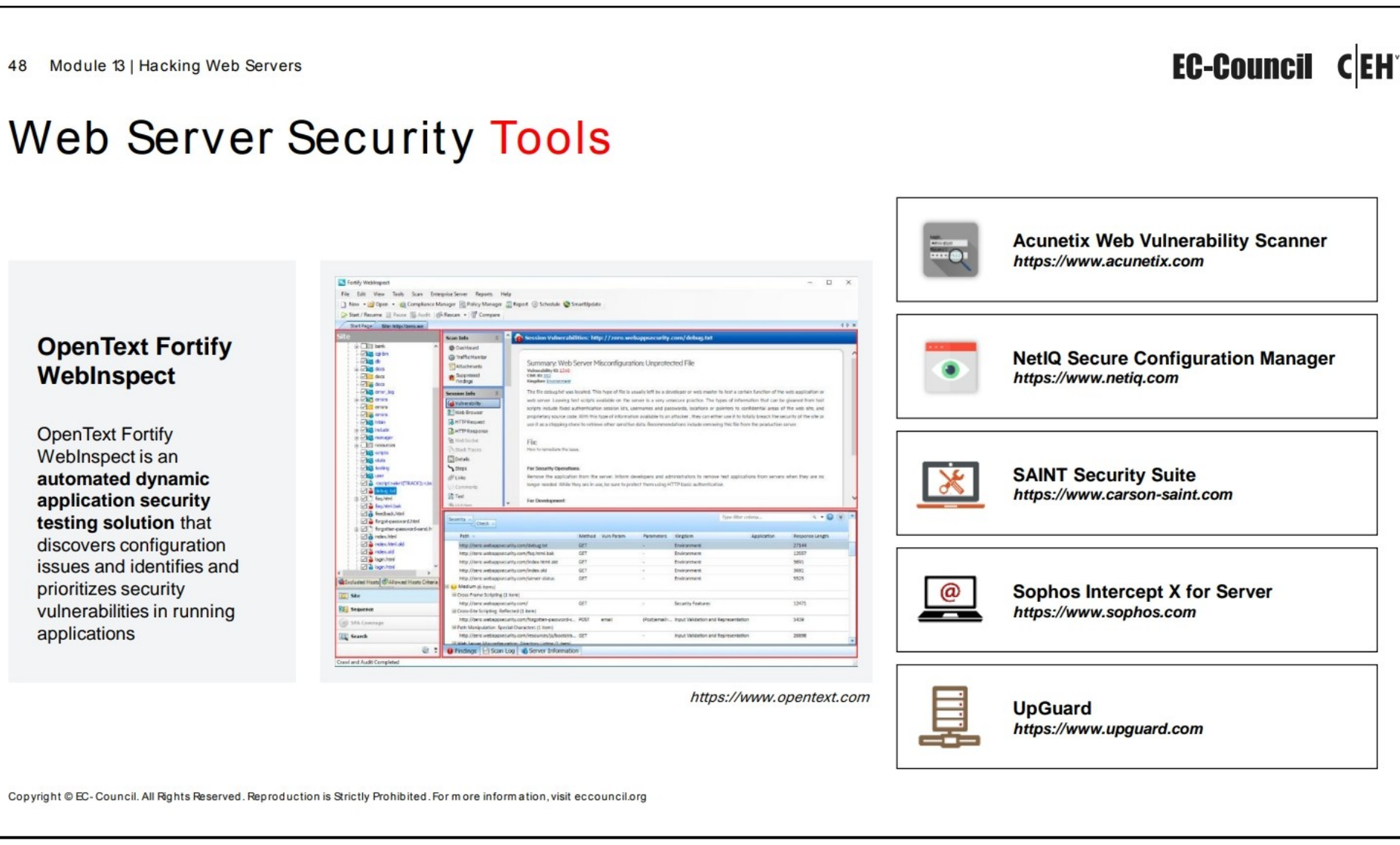


Figure 13.66: Screenshot of QualysGuard Malware Detection

The following are some additional web server malware infection monitoring tools:

- Sucuri Site Check (*https://sitecheck.sucuri.net*)
- SiteLock Malware Removal (*https://www.sitelock.com*)
- Quttera (*https://quttera.com*)
- Web Inspector (*https://www.webinspector.com*)
- SiteGuarding (*https://www.siteguarding.com*)

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.



Web Server Security Tools

- **OpenText Fortify WebInspect**

  Source: *https://www.opentext.com*

  OpenText Fortify WebInspect is an automated dynamic application security testing solution that discovers configuration issues as well as identifies and prioritizes security vulnerabilities in running applications. It mimics real-world hacking techniques and provides a comprehensive dynamic analysis of complex web applications and services. WebInspect dashboards and reports provide organizations with visibility and an accurate risk posture of its applications.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

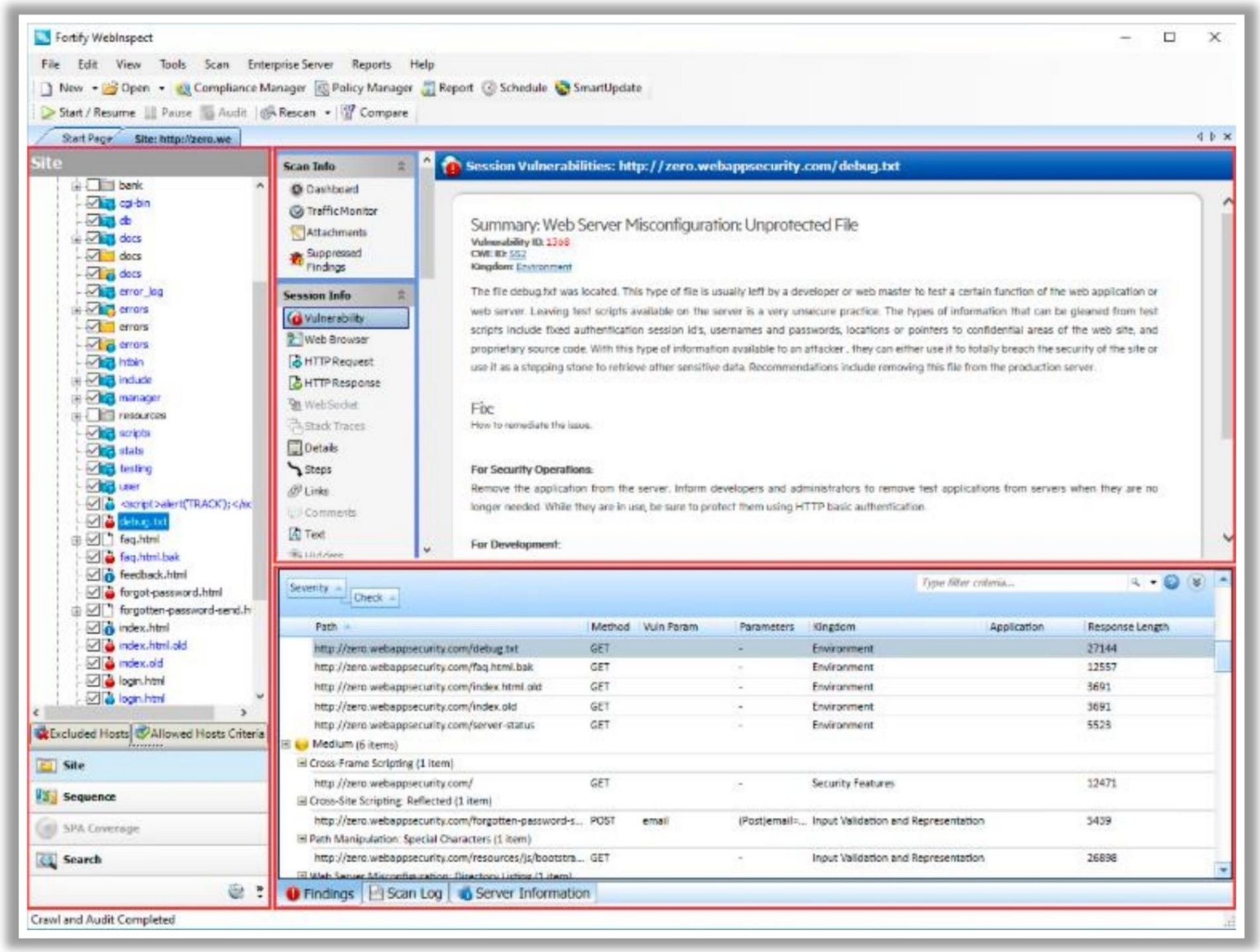
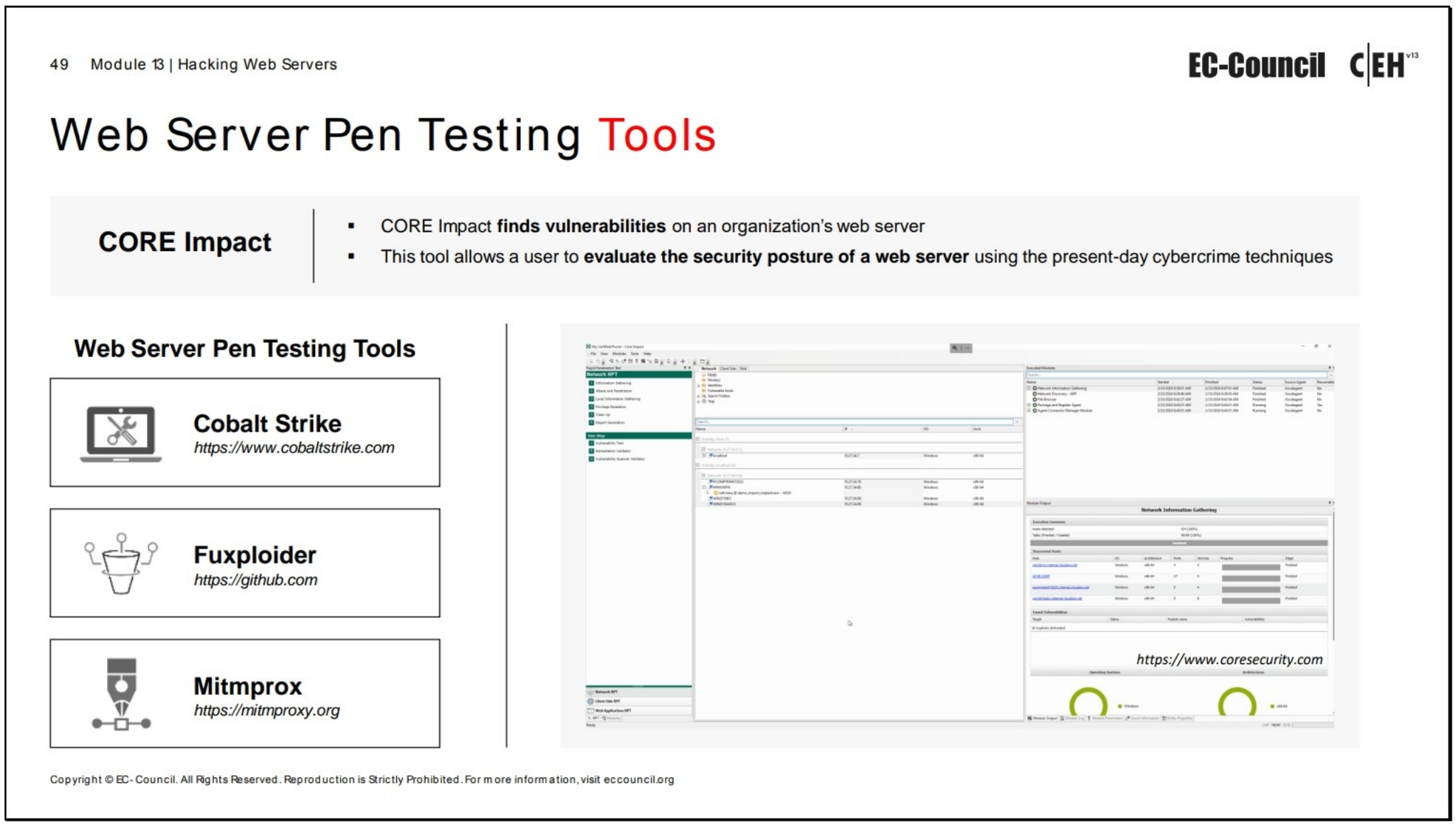


Figure 13.67: Screenshot of Fortify WebInspect

The following are some additional web server security tools:

- Acunetix Web Vulnerability Scanner (*https://www.acunetix.com*)
- NetIQ Secure Configuration Manager (*https://www.netiq.com*)
- SAINT Security Suite (*https://www.carson-saint.com*)
- Sophos Intercept X for Server (*https://www.sophos.com*)
- UpGuard (*https://www.upguard.com*)

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.



Web Server Pen Testing Tools

- **CORE Impact**

  Source: *https://www.coresecurity.com*

  CORE Impact finds vulnerabilities in an organization's web server. This tool allows a user to evaluate the security posture of a web server by using the same techniques currently employed by cyber criminals. It scans for possible vulnerabilities in the web server, imports scan results, and runs exploits to test the identified vulnerabilities. It can also scan network servers, workstations, firewalls, routers, and various applications for vulnerabilities; identify which vulnerabilities pose real threats to the network; determine the potential impact of exploited vulnerabilities; and prioritize and execute remediation efforts.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

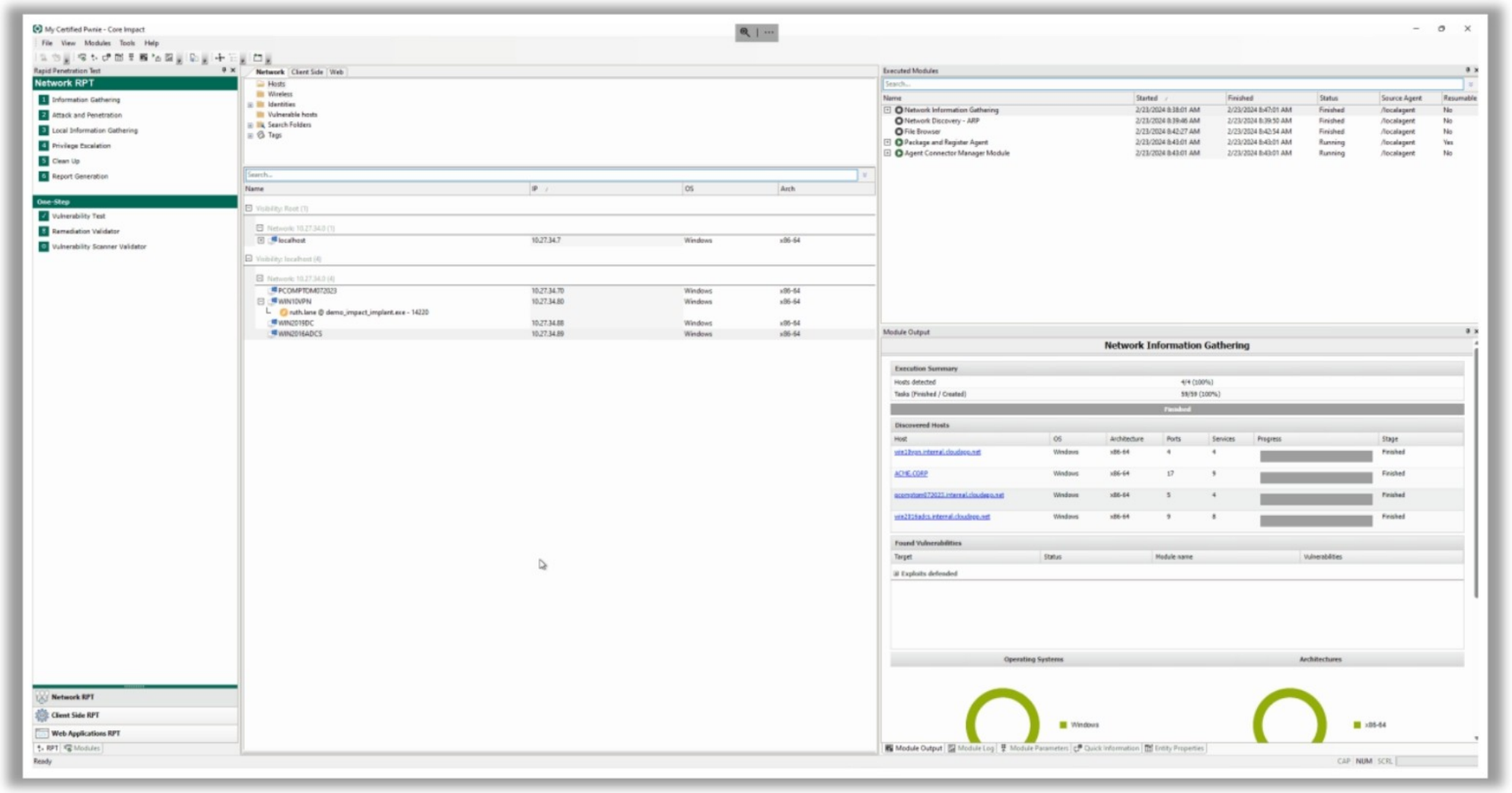


Figure 13.68: Screenshot of CORE Impact

The following are some additional web server pen testing tools:

- Cobalt Strike (*https://www.cobaltstrike.com*)
- Fuxploider (*https://github.com*)
- Mitmprox (*https://mitmproxy.org*)

Patch Management

Developers always attempt to find bugs in a web server and fix them. Bug fixes are distributed in the form of patches, which provide protection against known vulnerabilities. Unpatched or vulnerable patches can create a security loophole in the web server. This section describes the role of patches, upgrades, and hotfixes in securing web servers. This section also provides guidance for choosing proper patches, upgrades, hotfixes, and their appropriate sources for secure patch management.

Patches and Hotfixes

A patch is a small piece of software designed to fix problems, security vulnerabilities, and bugs as well as improve the usability or performance of a computer program or its supporting data. A patch can be considered a repair job for a programming problem. A software vulnerability is the weakness of a software program that makes it susceptible to malware attacks. Software vendors provide patches that prevent exploitations and reduce the probability of threats exploiting a specific vulnerability. Patches include fixes and updates for multiple known bugs or issues. A patch is a publicly released update that is available for all customers. A system without patches is much more vulnerable to attacks than a regularly patched system. If an attacker can

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

identify a vulnerability before it is fixed, then the system might be susceptible to malware attacks.

A hotfix is a package used to address a critical defect in a live environment and contains a fix for a single issue. It updates a specific product version. Hotfixes provide quick solutions and ensure that the issues are resolved. Apply hotfixes to software patches on production systems.

Vendors update users about the latest hotfixes through email or make them available on their official website. Hotfixes are updates that fix a specific customer issue and are not always distributed outside the customer organization. Vendors occasionally deliver hotfixes as a set of fixes called a combined hotfix or service pack.

What is Patch Management?

Patch management is an area of systems management that involves acquiring, testing, and installing multiple patches (code changes) in an administered computer system. Patch management is a method of defense against vulnerabilities that cause security weaknesses or corrupt data. It is a process of scanning for network vulnerabilities, detecting missed security patches and hotfixes, and then deploying the relevant patches as soon as they are available to secure the network. It involves the following tasks:

- Choosing, verifying, testing, and applying patches
- Updating previously applied patches with current patches
- Listing patches applied previously to the current software
- Recording repositories or depots of patches for easy selection
- Assigning and deploying the applied patches

An automated patch management process includes the following steps.

- **Detect**: Use tools to detect missing security patches.
- **Assess**: Asses the issue(s) and its associated severity by mitigating the factors that may influence the decision.
- **Acquire**: Download the patch for testing.
- **Test**: Install the patch first on a test machine to verify the consequences of the update.
- **Deploy**: Deploy the patch to computers and ensure that applications are not affected.
- **Maintain**: Subscribe to receive notifications about vulnerabilities when they are reported.

Installation of a Patch

The installation of a patch entails the following tasks.

- **Identifying Appropriate Sources for Updates and Patches**

  It is important to identify appropriate sources for updates and patches. Patches and updates that are not installed from trusted sources can render the target server even

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

more vulnerable to attacks, instead of hardening its security. Thus, the selection of appropriate sources for updates and patches plays a vital role in securing web servers.

The following are some methods for identifying appropriate sources for updates and patches.

- Create a patch management plan that fits the operational environment and business objectives.
- Find appropriate updates and patches on the home sites of the applications or OS vendors.
- The recommended method of tracking issues relevant to proactive patching is to register to the home sites to receive alerts.

- **Installation of a Patch**

  Users can access and install security patches via the World Wide Web. Patches can be installed in two ways.

  - **Manual Installation**

    In this method, the user downloads the patch from the vendor and installs it.

  - **Automatic Installation**

    In this method, applications use an auto update feature to update themselves.

- **Implementation and Verification of a Security Patch or Upgrade**
  - Before installing any patch, verify the source.
  - Use a proper patch management program to validate file versions and checksums before deploying security patches.
  - The patch management tool must be able to monitor the patched systems.
  - The patch management team should check for updates and patches regularly.

Patch Management Best Practices

- Define roles, responsibilities, and procedures for patch management, including timelines for applying patches and handling emergencies.
- Develop a comprehensive policy outlining procedures for evaluating, testing, approving, and deploying patches.
- Outline systems, applications, and devices, including servers, workstations, and networking equipment, require patching.
- Maintain an updated inventory of all hardware and software assets to ensure that no device or application is overlooked during the patching process.
- Assess and prioritize patches based on the severity of the vulnerabilities they address.
- Group assets by criticality, application type, or other relevant criteria for prioritizing patching efforts.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

- Use tools to automate the discovery of applicable patches in the systems and ensure timely updates.
- Implement a testing process to verify that patches do not cause issues in existing systems.
- Leverage patch management software to streamline the patching process, from discovery to deployment.
- Create and follow a regular schedule for patching to ensure updates are applied in a timely manner.
- Create a procedure for fast-tracking the deployment of patches for critical vulnerabilities that are being actively exploited.
- Stay informed about new vulnerabilities and available patches by subscribing to security advisories and feeds.
- Limit access to patch management tools and systems to authorized personnel.
- Ensure that systems are backed up before applying patches to facilitate recovery in case of issues.
- Ensure that patch management is part of standard IT operations.
- Verify that patches have been successfully applied after deployment and are functioning as intended.
- Use tools or systems to track patch status to ensure that all assets are appropriately patched.
- Regularly perform vulnerability scanning to identify unpatched vulnerabilities and verify patch effectiveness.
- Protect the patch management system itself against attacks to prevent compromise.
- Regularly review and refine patch management processes to improve efficiency.
- Include third-party applications patches in the organization's patch management strategy.
- Have a plan for quickly rolling back patches in case they cause unforeseen issues.
- Use a controlled test environment to verify patches before deploying them to production systems.
- Ensure patches do not cause compatibility issues with existing applications and configurations.
- Implement scheduled patching to minimize disruption and align with maintenance windows.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Patch Management Tools

- **GFI LanGuard**

  Source: *https://www.gfi.com*

  The GFI LanGuard patch management software scans the user's network automatically as well as installs and manages security and non-security patches. It supports machines across Microsoft®, MAC OS X®, and Linux® operating systems, as well as many third-party applications. It allows auto-downloads of missing patches as well as patch rollback, resulting in a consistently configured environment that is protected from threats and vulnerabilities.

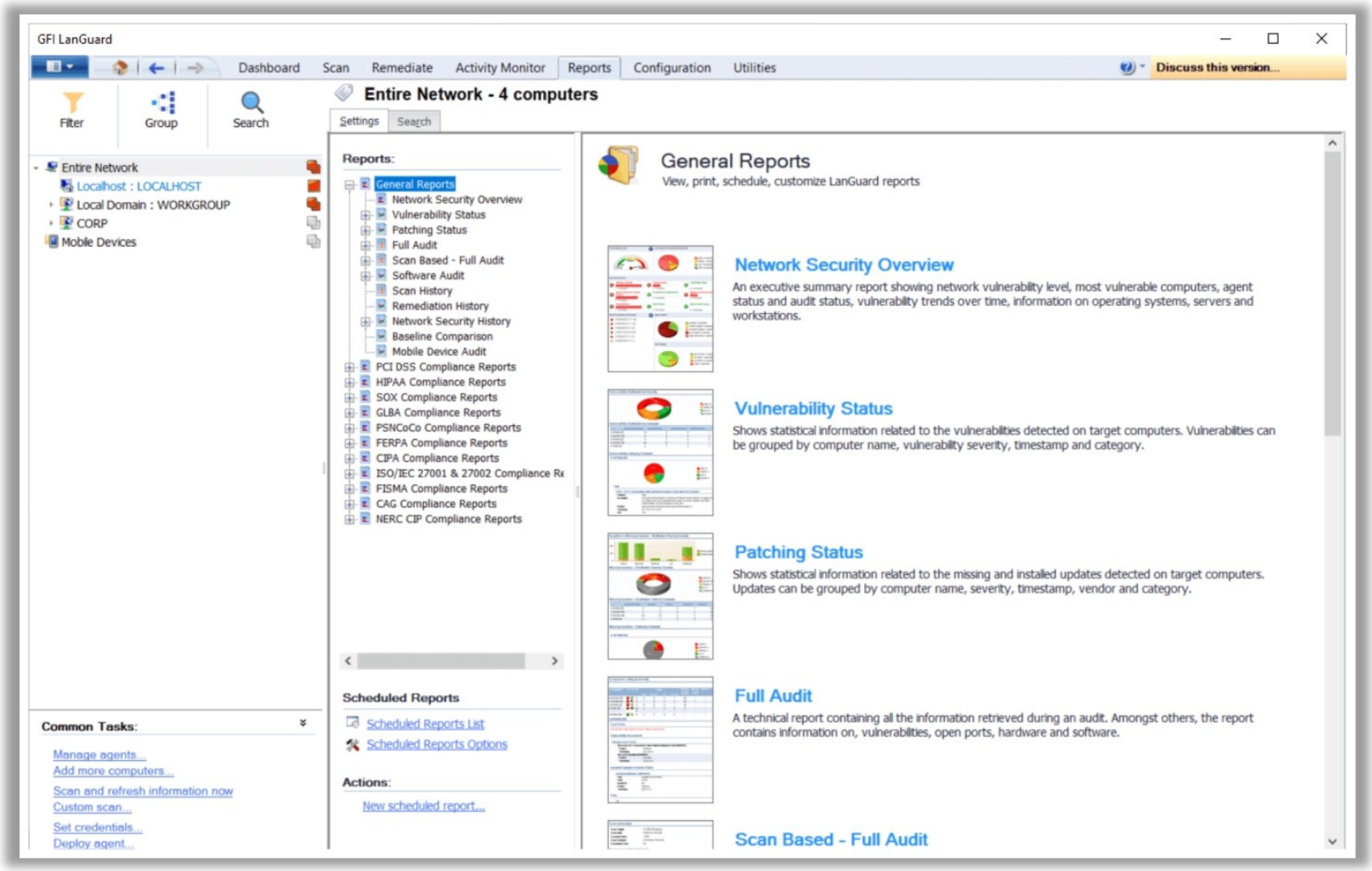


Figure 13.69: Screenshot of GFI LanGuard patch management software

The following are some additional patch management tools:

- Symantec Client Management Suite (*https://www.broadcom.com*)
- Solarwinds Patch Manager (*https://www.solarwinds.com*)
- Kaseya Patch Management (*https://www.kaseya.com*)
- Software Vulnerability Manager (*https://www.flexera.com*)
- Ivanti Patch for Endpoint Manager (*https://www.ivanti.com*)

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Module Summary

In this module, we have discussed the following:

- Web server concepts
- Various web server threats and attacks in detail
- Web server attack methodology in detail, including information gathering, web server footprinting, vulnerability scanning, and web server passwords hacking
- Various countermeasures that are to be employed to prevent web server hacking attempts by threat actors
- Detailed discussion on securing web servers using various security tools

In the next module, we will discuss in detail how attackers, as well as ethical hackers and pen-testers, hack web applications

Copyright © EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit eccouncil.org

Module Summary

In this module, we discussed in detail the general concepts related to web servers; various web server threats and attacks; the web server attack methodology, including information gathering, web server footprinting, vulnerability scanning, and web server passwords hacking; and various web server hacking tools. Additionally, we discussed various countermeasures that can be employed to prevent web server hacking attempts by threat actors. We conclude the module with a detailed discussion on how to secure web servers using various security tools.

In the next module, we will discuss in detail how attackers, including ethical hackers and pen testers, hack web applications.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.